

- Expediente N.º: EXP202210465

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

<u>ANTECEDENTES</u>	4
<u>PRIMERO</u>	4
<u>SEGUNDO</u>	5
<u>TERCERO</u>	5
<u>CUARTO</u>	5
<u>QUINTO</u>	6
<u>SEXTO</u>	16
<u>SÉPTIMO</u>	16
<u>OCTAVO</u>	16
<u>Previa. Sobre la incoación del expediente sancionador a Telefónica</u>	16
<u>I. Sobre los hechos que motivan la incoación del presente acuerdo de inicio de procedimiento sancionador</u>	18
<u>II. Sobre los fundamentos de derecho</u>	32
<u>NOVENO</u>	58
<u>DÉCIMO</u>	66
<u>UNDÉCIMO</u>	66
<u>Previa. Sobre la continuación del presente expediente sancionador</u>	66
<u>Primera. Aclaración sobre la descripción de hechos probados realizada por la AEPD</u>	67
<u>Segunda. Del incidente en ***APP.1 y las medidas de seguridad: Telefónica contempla medidas técnicas y organizativas que resultan apropiadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito</u>	67
<u>Tercera. Superación de la esfera de responsabilidad de Telefónica: circunstancias excepcionales que han hecho posible la superación por terceras personas de las políticas de seguridad implantadas</u>	69
<u>Cuarta. Sobre las cuestiones previas que han sido planteadas por la AEPD en el marco de este expediente</u>	69
<u>Quinta. Sobre las presuntas infracciones cometidas por parte de Telefónica: vulneración del principio de tipicidad</u>	69
<u>Sexta. La conducta de Telefónica no es antijurídica</u>	70
<u>Séptima. Ausencia de culpabilidad</u>	70

Octava. Incumplimiento del principio de proporcionalidad.....	70
HECHOS PROBADOS.....	71
PRIMERO: Primera notificación de brecha de datos personales.....	71
SEGUNDO: Segunda notificación de brecha de datos personales.....	72
TERCERO: Obran en el expediente los siguientes correos electrónicos:.....	73
CUARTO: Cronología y descripción del ataque:.....	74
1.- Fecha de inicio del ataque: 9 de septiembre de 2022.....	75
2. Período del 16 al 20 de septiembre de 2022:.....	75
3. 28 de septiembre de 2002.....	76
QUINTO: Actividades de tratamiento afectadas por el incidente y sobre la aplicación ***APP.1.....	76
SEXTO: Causas que hicieron posible la brecha.....	77
SÉPTIMO: medidas de seguridad previas al incidente.....	78
NOVENO: Medidas posteriores al incidente de seguridad.....	79
DÉCIMO: Análisis de riesgos de la aplicación afectada por la brecha de datos personales:.....	80
DÉCIMOPRIMERO: Metodología del análisis de riesgos.....	81
DÉCIMO SEGUNDO: Ausencia de análisis de riesgos para los derechos y libertades de las personas y de evaluación de Impacto en protección de datos.....	82
DÉCIMO TERCERO: Ausencia de doble factor de autenticación.....	82
DÉCIMO CUARTO: Número de personas afectadas y tipo de datos afectados.....	82
DECIMO QUINTO: Comunicación a los afectados.....	82
FUNDAMENTOS DE DERECHO.....	83
I Competencia.....	83
II Cuestiones previas.....	83
III Sobre la naturaleza de los datos afectados por la quiebra.....	84
IV Alegaciones al acuerdo de inicio.....	87
Primero. - Consideraciones previas y aclaración sobre la descripción de los hechos realizada por la AEPD en el Acuerdo de Inicio.....	87
Segundo. - Del incidente en ***APP.1 y las medidas de seguridad. Telefónica considera que contempla medidas técnicas y organizativas que resultan apropiadas para garantizar una seguridad adecuada de los datos personales. incluida la protección contra el tratamiento no autorizado o ilícito.....	91

<u>Tercero.- Superación de la esfera de responsabilidad de Telefónica:</u>	
<u>Circunstancias excepcionales que han hecho posible la superación por terceras personas de las políticas de seguridad implantadas.....</u>	<u>96</u>
<u>Cuarta.- Sobre las cuestiones previas planteadas por la AEPD.....</u>	<u>97</u>
<u>Quinto.- Sobre las presuntas infracciones cometidas por parte de Telefónica:</u>	
<u>Vulneración del principio de tipicidad.....</u>	<u>107</u>
<u>V Alegaciones a la propuesta de resolución.....</u>	<u>123</u>
<u>Previa. Sobre la continuación del presente expediente sancionador.....</u>	<u>123</u>
<u>Primera. Aclaración sobre la descripción de hechos probados realizada por la AEPD.....</u>	<u>125</u>
<u>Segunda. Del incidente en ***APP.1 y las medidas de seguridad: Telefónica contempla medidas técnicas y organizativas que resultan apropiadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito.....</u>	<u>125</u>
<u>Tercera. Superación de la esfera de responsabilidad de Telefónica: circunstancias excepcionales que han hecho posible la superación por terceras personas de las políticas de seguridad implantadas.....</u>	<u>128</u>
<u>Cuarta. Sobre las cuestiones previas que han sido planteadas por la AEPD en el marco de este expediente.....</u>	<u>128</u>
<u>Quinta. Sobre las presuntas infracciones cometidas por parte de Telefónica: vulneración del principio de tipicidad.....</u>	<u>128</u>
<u>Sexta. La conducta de Telefónica no es antijurídica.....</u>	<u>133</u>
<u>Séptima. Ausencia de culpabilidad.....</u>	<u>134</u>
<u>Octava. Incumplimiento del principio de proporcionalidad.....</u>	<u>135</u>
<u>VI Integridad y confidencialidad.....</u>	<u>136</u>
<u>VII Tipificación de la infracción del artículo 5.1.f) del RGPD.....</u>	<u>138</u>
<u>VII Sanción por la infracción del artículo 5.1.f) del RGPD.....</u>	<u>139</u>
<u>IX Artículo 32 del RGPD.....</u>	<u>140</u>
<u>X Tipificación de la infracción del artículo 32 del RGPD.....</u>	<u>146</u>
<u>XI Sanción por la infracción del artículo 32 del RGPD.....</u>	<u>147</u>
<u>XII Medidas.....</u>	<u>148</u>
<u>RESUELVE:.....</u>	<u>148</u>

RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

ANTECEDENTES

PRIMERO:

Con fecha 26 de septiembre de 2022 se notificó a la División de Innovación Tecnológica de la Agencia Española de Protección de Datos una brecha de seguridad de los datos personales remitido por TELEFONICA DE ESPAÑA SAU con NIF A82018474 (en adelante, Telefónica) como responsable del tratamiento.

En el escrito recibido se informa de lo siguiente:

- Fecha de inicio de la brecha: 16 de septiembre de 2022.
- Fecha de detección de que la brecha afecta a datos personales: 23 de septiembre de 2022.
- Fecha de resolución: 20 de septiembre de 2022.
- Los datos no están cifrados.
- Resumen del incidente: “(…)”
- Número aproximado de personas físicas sobre las que se tratan datos personales, referido exclusivamente al tratamiento sobre el que se ha producido la brecha de datos personales: 6.000.000
- Número de personas que han visto sus datos afectados por la brecha: 1.021.253
- Categorías de datos afectados: Datos de contacto, credenciales de acceso o identificación (usuario y / o contraseña).
- Como consecuencia del incidente, se ha visto afectada la Confidencialidad
- No se ha puesto en conocimiento de las autoridades policiales.
- La comunicación a los afectados está pendiente de decidir.

SEGUNDO:

Como consecuencia de los hechos conocidos, con fecha 30 de septiembre de 2022, la Directora de la Agencia Española de Protección de Datos ordenó a la Subdirección General de Inspección de Datos (SGID) realizar las oportunas investigaciones previas con el fin de determinar una posible vulneración de la normativa de protección de datos.

TERCERO:

Tras el análisis de la notificación de brecha de datos personales y en virtud de las funciones y potestades de esta Agencia a las que refiere el artículo 47 de la Ley Orgánica 3/2018 así como el artículo 58 del Reglamento (UE), con fecha 30 de septiembre de 2022 se ordena a Telefónica que lleve a cabo la comunicación de la

brecha de datos personales a los interesados conforme al artículo 34 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), sin dilación indebida, para que, una vez tengan conocimiento de esta, puedan adoptar las medidas que consideren oportunas para evitar aquellos riesgos que pudieran afectar a su persona.

Frente a dicha Resolución, Telefónica presentó con fecha 13 de octubre de 2022 recurso de reposición, alegando que no se disponía del análisis forense completo y que los datos afectados por el incidente se consideran *no identificables para un tercero ajeno a telefónica*, el cual fue desestimado mediante Resolución de 20 de octubre de 2022.

CUARTO:

Con fecha 26 de octubre de 2022 se recibe nueva notificación de la brecha que completaba la notificación inicial. Esta nueva notificación recoge la siguiente información:

- En la descripción se indica: “(…)”
- Se afirma que la fecha de inicio de la brecha es el 09 de septiembre de 2022.
- Se afirma que el incidente se detecta el 20 de septiembre por la advertencia de un miembro de la organización.
- Se afirma que la brecha se da por resuelta el 20 de septiembre de 2022.
- Se afirma que se detecta el 23 de septiembre de 2022 que la brecha ha afectado a datos personales.
- Se indica que, en total, se han visto afectadas un total de 1.407.257 personas, todas ellas residentes en España.
- Se afirma que se podría haber evitado la brecha adoptando medidas adicionales, pero que no se produce por deficiencia de medidas actuales.
- Se afirma que las nuevas medidas reactivas implantadas han sido **“***MEDIDA.1” y “***MEDIDA.2”**.
- Se afirma que se dispone de Análisis de Riesgos y Registro de Incidentes.
- Se afirma que se ha puesto el incidente en conocimiento de las autoridades policiales.
- Se afirma que se comunicará a las personas afectadas a más tardar el 28 de octubre de 2022.
- No existe encargado de tratamiento afectado por la brecha.

Junto a la notificación se aporta la siguiente documentación:

- *“Informe incidente de privacidad acceso no autorizado a *****APP.1**”*

QUINTO:

La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del RGPD, y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de

los derechos digitales (en adelante, LOPDGDD), teniendo conocimiento de los siguientes extremos:

Del análisis del documento “Informe incidente de privacidad acceso no autorizado a *****APP.1**”, aportado por Telefónica en la segunda notificación de la brecha ante esta Agencia en fecha 26 de octubre de 2022 se extrae la siguiente información relevante:

- Los accesos ilícitos fueron detectados en una de las aplicaciones internas del portal del empleado de Telefónica denominado *****PORTAL.1 (***URL.1)**. El acceso a este portal era público desde internet y utilizaba método de autenticación basado en credenciales que cada empleado posee (usuario y contraseña).
- El 23 de septiembre de 2022 el CSIRT-TE (Equipo de respuesta a incidentes de seguridad de Telefónica) informa al DPO de Telefónica de un incidente de seguridad. Indican que es este mismo día cuando se confirma que las peticiones realizadas por los atacantes habían obtenido respuesta, confirmándose la afectación de datos personales, no obstante, se afirma también que en este instante se desconocía el listado completo de datos afectados y asociados a las numeraciones fijas que habían sido consultadas aleatoriamente por el atacante. Como acreditación de esto se aporta captura de pantalla de un correo electrónico interno enviado el 23 de septiembre de 2022 a las 22:17 por parte del equipo de seguridad (CSIRT) con el siguiente contenido: “(...)”.
- Se afirma que la información afectada fue la siguiente: teléfono fijo, datos técnicos y de configuración del Equipo de Cliente (...). Toda esta información se utilizaba para fines de soporte y mantenimiento al cliente por parte de los equipos técnicos de Telefónica.
- Se afirma que el día 20 de septiembre de 2022 fue realmente cuando se detecta por parte del equipo de ... un número de peticiones más elevada de lo habitual, que tras análisis realizado se obtuvo que eran efectuadas por parte del usuario *****USUARIO.1** a través del portal *****URL.1, (...)**, procediéndose a bloquear el usuario en la aplicación hasta analizar qué estaba provocando esas peticiones. Se aporta también captura de pantalla de un correo electrónico enviado por los responsables de ... este mismo día 20 de septiembre de 2022 a las 9:05 horas con el siguiente contenido: “(...)”.
- Se afirma textualmente lo siguiente “(...)”
- Se afirma que el día 21 de septiembre de 2022 se recibió aviso en el área de seguridad (CSIRT) por parte del usuario con el cual se habían realizado las peticiones masivas, notificando la incidencia de seguridad. Durante los días 21 y 22 de septiembre de 2022 desde este equipo de seguridad se analiza el caso (...) y se consulta a las áreas afectadas para obtener más información sobre el caso.
- Se afirma que el día 23 de septiembre de 2022, teniendo en cuenta la información recabada de las distintas áreas se convoca reunión de urgencia por parte del equipo de seguridad, en dicha reunión se obtienen evidencias de que se trataba de un incidente real, solicitando los logs de la aplicación afectada para su análisis por parte del equipo de seguridad, (...). Es este mismo día cuando desde el CSIRT- TE se informa preventivamente al DPD de Telefónica España.

- Durante los días siguientes continuaron los análisis por parte del equipo de seguridad para detectar si se habían producido más accesos no autorizados, comprobándose el día 29 de septiembre de 2022 que hay una segunda intromisión sospechosa con un nuevo usuario comprometido (*****USUARIO.2**), se cambió la contraseña y se comunicó al empleado. Este día se procede a bloquear todos los usuarios con acceso a la aplicación *****APP.1** de forma preventiva.
- Se afirma que una vez finalizado los análisis forenses concluyen que los accesos maliciosos se dieron en tres bloques temporales, del 9 al 11 de septiembre, del 16 al 20 de septiembre y el 28 de septiembre, (...)”, todos estos accesos tenían como propósito obtener datos de equipamientos de clientes (...). Las peticiones maliciosas del día 28 de septiembre se detectaron por las medidas desplegadas por el equipo de seguridad, (...).
- Afirman que se había obtenido información de 1.612.926 numeraciones fijas que se correspondían con 1.407.257 personas físicas afectadas.
- En relación con la causa del incidente Telefónica afirma: “(...)”.
- En el informe del incidente Telefónica realiza una evaluación del nivel de riesgo de la brecha de seguridad siguiendo la guía de brechas de esta Agencia. De este análisis se extrae:
 - Se afirma que las categorías de datos afectados son: Teléfono fijo asociado a los siguientes datos técnicos y de configuración del equipo del cliente: (...).
 - Se afirma que estos datos afectados no tienen la misma consideración para Telefónica que para un tercero ajeno a la compañía, ya que para Telefónica la numeración sí es un dato seudónimo pero este dato no permite a un tercero identificar de forma directa o indirecta a un particular de forma razonable.
 - Se afirma que para Telefónica el número de teléfono fijo es un dato seudónimo en la medida que no puede atribuirse a un interesado sin utilizar información adicional con la que cuenta Telefónica. Sin embargo, se afirma que este dato no permite a un tercero identificar de forma directa o indirecta a una persona física de forma razonable, por lo que Telefónica concluye que no se puede considerar que se haya visto afectado por el incidente ningún dato personal que permita de forma razonable a un tercero identificar directa o indirectamente a una persona física.
- En relación con el resto de los datos filtrados sobre el equipamiento del cliente afirman que son datos que no permiten la identificación, ni si quiera al asociarse a un número de teléfono fijo:
 - La dirección MAC tan solo identifica un dispositivo;
 - El nombre de la red wifi (SSID) no está asociado de manera única a una numeración fija, sino que puede corresponder a más de una numeración;
 - Las contraseñas de la red Wifi (SSID) filtradas constan en el propio router sin cifrar, tratándose de una práctica comercial habitual.
- En el informe del incidente se realiza también un análisis de las posibles consecuencias para los afectados siguiendo la guía de la AEPD, concluyendo un nivel de severidad BAJO: *“Las personas no se verán afectadas o pueden encontrar algunos inconvenientes muy limitados y reversibles que superarán sin ningún problema (tiempo de reingreso de información, molestias,*

irritaciones, etc.”, y justificando para ello “que los datos obtenidos no pueden ser considerados datos identificables sin la aplicación de un esfuerzo desproporcionado para los terceros que han accedido a ellos sin autorización, y que entre los datos afectados no se encuentra información sensible considerada como tal por el RGPD”. y un nivel de probabilidad de materialización de las consecuencias BAJO o IMPROBABLE, atendiendo a los siguientes puntos:

“1.- La red Wifi, en su configuración por detecto, se encuentra cifrada de extremo a extremo.

2.- El acceso a cada red wifi solo podría realizarse cuando el intruso se encuentre físicamente en la zona de cobertura del domicilio (dirección postal), dato que no se ha filtrado.

3.- Para que el intruso se encuentre físicamente en la zona de cobertura del domicilio de instalación del router sería necesario que el tercero contase con la dirección postal a la que corresponden las claves Wifi (dato que no se ha extraído de los sistemas de Telefónica) y 4.- Sería necesaria una acción adicional”.

- Se afirma que las actividades de tratamiento afectadas por la brecha son:
(...)
- En relación con las medidas de seguridad preventivas afirman lo siguiente:
(...)
- En relación con las medidas reactivas de mitigación afirman lo siguiente:
(...)
- En relación con la fecha de detección afirman:
 - El día 23 de septiembre de 2022 es cuando desde el equipo del CSIRT, tras analizar logs de acceso confirman la afectación del listado de datos técnicos y de configuración de los equipos asociados a las numeraciones de teléfono fijo de clientes Telefónica.
- En relación con los medios de detección afirman:
 - Por parte del equipo de API Gateway se detectó que un número de peticiones más elevado de lo habitual realizada por un usuario hacia números de teléfono fijo consecutivos. Se verifica con el usuario que no era él quien estaba realizando los accesos.
 - El incidente fue reportado por el usuario el día 21 de septiembre de 2022 a las 09:54, (tras haber sido alertado por el equipo de ...), a través de correo electrónico remitido al buzón de Incidentes del CSIRT-TE. En este momento comienzan investigaciones internas por parte del equipo de seguridad.
 - El día 23 de septiembre de 2022 a las 22.17h se confirma que las peticiones realizadas por el atacante han obtenido respuesta, confirmándose la afectación de datos de carácter personal en el incidente.
 - Afirman que la fecha de inicio de la brecha fue el 9 de septiembre de 2022 y no el 16 de septiembre de 2022 como se había especificado en la notificación inicial de la brecha.

Teniendo en cuenta toda la información anterior obtenida del informe documentado de la brecha, en fecha 2 de noviembre de 2022 se realiza un nuevo requerimiento de información a Telefónica marcado por la siguiente línea de investigación:

- Que se acredite la comunicación realizada a los afectados.
- Obtener copia de los análisis de riesgos de los tratamientos afectados por la brecha de seguridad.
- Que se acredite el correo electrónico de la incidencia notificada por el empleado al equipo de seguridad CSIRT, así como la acreditación de la comunicación que se realiza al DPD.
- Obtener los detalles sobre los casos de uso de la aplicación afectada (*****APP.1**).
- Obtener la descripción técnica de las APIS consumidas en el ataque con objeto de acreditar el alcance de datos afectados.
- Obtener registros de logs en los que se detectaron las peticiones maliciosas que se realizaron a las APIS, con objeto de acreditar el alcance de datos afectados.

En fecha 28 de noviembre de 2022 se recibe respuesta en esta Agencia al requerimiento de información. Del análisis de esta respuesta se extrae:

- En relación con la acreditación de la comunicación a los afectados:
 - Afirman que el medio utilizado mayoritariamente ha sido el correo electrónico y en algunos otros el correo postal cuando no se disponía del dato email.
 - Afirman que se han enviado 89.244 cartas postales y se acredita este hecho aportando certificado de Correos con fecha de registro el día 31 de octubre de 2022.
 - Afirman que se han enviado 1.313.395 correos electrónicos, aportando detalles de las fechas en las que se han realizado los envíos, que están comprendidas entre el 27 de octubre de 2022 y el 2 de noviembre de 2022.
 - Afirman que ha sido necesario realizar la comunicación en fases y en las fechas anteriormente indicadas para así disponer y garantizar una atención adecuada ante las posibles llamadas de petición de información por parte de los clientes, habiendo sido necesario reforzar el número de personas que atienden al canal telefónico y proporcionarles formación adecuada para que pudiesen dar respuesta a las solicitudes de información y dudas de los clientes. Afirman que otro de los motivos para llevar a cabo la comunicación por fases fue el poder atender correctamente a los clientes afectados y evitar la caída de los diferentes medios de gestión habilitados para el cambio de contraseña que se sugería en el contenido de la comunicación (por una posible excesiva demanda).
 - Afirman que los usuarios afectados eran clientes tanto de Telefónica Movistar como de Telefónica O2.
 - Acreditan el siguiente contenido de la comunicación para los clientes de Telefónica Movistar:

(...)

- Acreditan el siguiente contenido de la comunicación para los clientes de Telefónica O2:

(...)

- En relación con nuestra solicitud para que aporten los análisis de riesgos para los tratamientos afectados por la brecha, adjuntan un documento de cuyo análisis se extrae:
 - En este documento se afirma: “(...)”.
 - El documento no está firmado, tiene fecha de 24 de noviembre de 2021 y en este se afirma: “AA.RR. realizado en el siguiente período de tiempo: julio-octubre 2021”.
 - En el apartado referente al objeto del análisis se afirma: “(...)”.
 - En relación con la metodología se afirma: “(...)”.
 - Se anexa una relación de controles de seguridad implantados en los activos afectados.
 - Se analiza la siguiente relación de amenazas y se concluye un nivel de riesgo residual asignándole a cada una de ellas un nivel de probabilidad e impacto:
(...)
- En relación con nuestra solicitud para que acrediten el correo electrónico que el usuario afectado envió al equipo de seguridad de Telefónica (CSIRT-TE) notificando la incidencia, se nos aporta captura de pantalla, de su análisis se extrae:
 - El usuario afirma en el correo que tuvo constancia del incidente tras serle notificado vía email el día 20 de septiembre de 2022.
 - El correo de la incidencia va dirigido al equipo de seguridad (CSIRT-TE) y tiene fecha de 21 de septiembre de 2022 a las 9:54.
 - El texto completo del correo es el siguiente: “(...)”
- En relación con nuestra solicitud para que se acredite la comunicación del incidente que desde el equipo de seguridad (CSIRT-TE) se dirigió al DPD, aportan captura de pantalla del correo electrónico remitido con el siguiente contenido:
 - “(...)”
- En relación con la solicitud para que aporten información sobre los distintos casos de uso de las aplicaciones afectadas por la brecha, contestan lo siguiente:
 - Que el portal web *****PORTAL.1** permite acceso a diferentes sistemas internos, entre ellos el afectado por el incidente, la aplicación *****APP.1**, a través de la cual el equipo de personas que atiende incidencias técnicas de los clientes puede consultar la información necesaria para el diagnóstico y tratamiento de averías en los equipamientos de conectividad.
 - Aportan distintas capturas de pantalla que muestran tanto los casos de uso de la aplicación *****APP.1** a través de su interfaz gráfica como las consultas lanzadas por los atacantes, que fueron automatizadas a través de un script, quedando constatado que los atacantes no hicieron uso de la interfaz gráfica de la aplicación sino que utilizaron consultas directas automatizadas que atacaban su funcionalidad sin hacer uso de las opciones de menú, y utilizando un barrido de números de teléfono aleatorios que obtenían datos sobre el equipamiento instalado en el cliente en caso de coincidir este número con el de algún cliente de Telefónica.

- En relación con nuestra solicitud para que aporten la descripción técnica de las APIS que consumieron los atacantes al lanzar las consultas automatizadas, nos aportan un documento con todos los detalles técnicos de estas no obteniéndose información adicional relevante para la presente investigación.
- En respuesta a la solicitud para que aporten pruebas de algunos registros de logs a través de los cuales detectaron el ataque, aportan captura de pantalla con registros detectados en fecha 16 de septiembre de 2022, de su análisis se constata el tipo de datos a los que pudieron acceder los atacantes, que coincide con los indicados en la notificación de la brecha, quedando constatado que en cada petición automática lanzada por los atacantes se incluía un número de teléfono aleatorio y en caso de que este número coincidía con algún cliente de Telefónica se obtenía como resultado de la consulta los siguientes datos:

(...)

SEXTO:

De acuerdo con el informe recogido de la herramienta AXESOR, la entidad TELEFONICA DE ESPAÑA SAU es una gran empresa y con un volumen de negocios (...).

SÉPTIMO:

Con fecha 26 de septiembre de 2023, la Directora de la Agencia Española de Protección de Datos acordó iniciar procedimiento sancionador a la parte reclamada, por la presunta infracción de los artículos 5.1.f) y 32 del RGPD, tipificadas, respectivamente, en los artículos 83.4 83.5 del RGPD.

OCTAVO:

Notificado el citado acuerdo de inicio conforme a las normas establecidas en la Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), Telefónica presentó escrito de alegaciones en el que, en síntesis, manifestaba lo siguiente:

Previa. Sobre la incoación del expediente sancionador a Telefónica

Señala Telefónica que ha cumplido con las previsiones de la normativa que resulta de aplicación en relación con la gestión del incidente en el sistema interno de Telefónica *****APP.1**, del que trata este Acuerdo de inicio, y que ha colaborado con la Agencia en todo momento, proporcionando toda la información que exige la normativa y que se ha venido solicitando.

Indica Telefónica que, a pesar de lo indicado anteriormente, parece que la Agencia no tiene en cuenta que se trata de un incidente en particular y parece concluir, erróneamente, que lo anterior supone que Telefónica no cuenta con unas medidas de seguridad que resulten adecuadas con carácter general. En este sentido y en relación con el contenido sobre el que versa el Acuerdo de inicio, traslada Telefónica que la AEPD no ha analizado en ningún momento la metodología ni los protocolos de actuación de Telefónica en relación con la implantación de medidas de seguridad en los tratamientos de datos de carácter personal. Es decir, parece que se aprovecha la

existencia de un incidente para tramitar una especie de "causa general" en relación con la insuficiencia de medidas de seguridad adecuadas.

Resalta Telefónica que existe total y absoluta falta de responsabilidad de ella en relación con las infracciones imputadas pues la consumación de este tipo de delitos requiere necesariamente de una captación previa de los datos del interesado, en este caso a través de una técnica muy sofisticada dirigida en su mayoría a numeraciones de móviles personales de los empleados. Lo anterior evidencia que el atacante ya contaba con esta información con carácter previo y que Telefónica no pudo detectar el ataque realizado en los dispositivos personales de los empleados. Posteriormente, los datos obtenidos sobre credenciales personales fueron utilizados por los atacantes profesionales para acceder de forma ilícita a un sistema interno de Telefónica.

Señala Telefónica que los defraudadores que llevan a cabo este tipo de actividades no son sólo personas aisladas, o grupos más o menos organizados, sino que, tras las oportunas investigaciones policiales, se ha podido saber que se trata de ciberdelincuentes perfectamente preparados y con recursos suficientes para dedicarse a este tipo de prácticas indeseables.

Sostiene Telefónica que es otra víctima más de los actos delictivos realizados por terceros que la propia Policía Nacional ha considerado que representan "un grave riesgo para la Seguridad Nacional". En ese sentido, por parte de Telefónica se colabora en las investigaciones policiales iniciadas por la Guardia Civil (*****EXPEDIENTE.1**), cuyo objeto es tanto la detección de los responsables de los hechos como determinar su alcance y conexiones con otras actividades similares.

Indica Telefónica que, en la actualidad, como perjudicada por las actividades investigadas por la Guardia Civil, está personada como acusación particular en las Diligencias (...). Así, El Jefe de Instrucción (...) consideró, (...), que las actividades delictivas que afectaron a Telefónica están conectadas con las actividades que afectaron al "Punto Neutro Judicial (PNJ)" (la red de telecomunicaciones que conecta los órganos judiciales con otras institucionales del Estado).

Manifiesta Telefónica que todo ello demuestra que las actividades delictivas que impactaron en Telefónica afectaron también a otras entidades e instituciones del Estado, acreditándose la complejidad y sofisticación del ataque ejecutado por personas especialmente preparadas para estas actividades delictivas

I. Sobre los hechos que motivan la incoación del presente acuerdo de inicio de procedimiento sancionador:

Primera. Aclaración sobre la descripción de hechos realizada por la AEPD en el acuerdo de inicio

Señala Telefónica que existen una serie de errores en la descripción de los hechos que realiza la AEPD en relación con el incidente de seguridad en *****APP.1** que aclara a continuación. Por ello, Telefónica indica que, tal y como consta en el "Informe incidente de privacidad acceso no autorizado a *****APP.1**" (en adelante Informe del Incidente o Informe), que aportó junto a la comunicación completa del Incidente, los hechos tuvieron lugar en las siguientes fechas:

- El día 20/09/2022: fue realmente cuando se detectó por parte del equipo de ... (aplicación que gestiona las peticiones a sistemas) un número de peticiones más elevada de lo habitual a *****APP.1. (...)** y se procedió a bloquearlo, hasta analizar qué estaba sucediendo, y a restablecer sus credenciales corporativas.

Como consta en el Informe, y en la notificación completa del Incidente, en la comunicación inicial presentada a la AEPD se reportó que la fecha en la que se inició este Incidente fue el 16/09/2022. No obstante, una vez concluido el informe forense final, se corrigió este aspecto al confirmarse que realmente fue el 20/09/2022.

Es decir, fue ese mismo día 20/09/2022 cuando se detectó el Incidente y se tomaron medidas de contención (...). Al analizar datos de días atrás, para saber desde cuando se estaban produciendo los accesos, se pudo comprobar que comenzaron el 16/09/2022, pero no fue esta la fecha de detección.

- El día 21/09/2022: el equipo de respuesta ante incidentes de Telefónica (CSIRT-TE) recibió un aviso de lo que en ese momento no se sabía si podía ser un incidente de seguridad o una simple incidencia provocada por algún sistema que tuviera un automatismo con ese usuario, circunstancias que se han dado en otras ocasiones.

Es decir, el CSIRT-TE fue informado sin dilación indebida, y cuando ya se habían adoptado determinadas medidas por parte de ..., no 5 días después. Desde ese mismo día, comenzó a analizarse el caso con los datos aportados por el usuario y se consultó a las áreas afectadas para obtener más información.

- El día 23/09/2022: teniendo en cuenta la información recabada de las distintas áreas, se convocó por parte de seguridad una reunión de urgencia para tratar el posible incidente. En dicha reunión, se obtuvieron evidencias de que se tratase un incidente real. Como sabe la Agencia, fue ese mismo día cuando se informó desde el CSIRT- TE de forma preventiva al DPO de Telefónica España.

Señala Telefónica que posteriormente cumplió con lo previsto en la normativa de protección de datos y el día 26 de septiembre de 2022 presentó el formulario inicial para notificar la existencia de un incidente de seguridad.

Por lo expuesto anteriormente, Telefónica concluye lo siguiente:

- No es cierto que las medidas de contención se produjeran 4 días más tarde, ya que el mismo día que se detectaron las consultas masivas (día 20 de septiembre) el usuario desde el cual se habían producido las consultas fue bloqueado.
- No es cierto que hasta que el empleado no cambió sus credenciales no cesaron las peticiones masivas ya que el usuario, como se ha indicado anteriormente, se bloqueó en el mismo momento de la detección.
- Tampoco es cierto que se estuvieran detectando consultas masivas muy superiores a las habituales y no se actuara por parte de Telefónica. Tras la detección de las consultas masivas el día 20 de septiembre, desde los equipos de seguridad se

actuó con la mayor celeridad y el mismo día de la detección el usuario fue bloqueado. Lo que sí es cierto, y es lo que ha podido confundir a la Agencia, es que tras hacer la investigación se detectó que el día 16 de septiembre también se habían realizado consultas masivas. Estas consultas eran, en todo caso, previas a la detección del incidente (que fue el 20 de septiembre).

Recuerda Telefónica que *****APP.1** permite que el equipo de personas que atiende las incidencias técnicas de los clientes pueda consultar la información necesaria para el diagnóstico y tratamiento de averías en los equipamientos de conectividad (router, descodificador de la tv, amplificador wifi, etc.).

Señala Telefónica que, sin embargo, en este caso el acceso no autorizado no se produjo a todo el sistema, sino que se produjo tan solo a determinados datos de configuración de algunos equipamientos de conectividad proporcionados por Telefónica. Es decir, (...):

En definitiva, entiende Telefónica que es importante que la AEPD tenga clara la secuencia de los hechos y la sofisticación del ataque realizado, que no consistió simplemente en obtener unas credenciales (a través de una técnica sofisticada de fraude dirigida a numeraciones personales de los empleados, tal y como se detallará más adelante) y acceder a un sistema pudiendo consultar toda la información que desease, sino que el atacante conocía con anterioridad las numeraciones personales de los empleados a los que remitió los SMS y también conocía el funcionamiento (...).

(...)

Segunda. Del incidente en *****APP.1** y las medidas de seguridad: Telefónica contempla medidas técnicas y organizativas que resultan apropiadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito.

(...)

Señala Telefónica que, posteriormente, y en la medida en la que el atacante debía conocer el funcionamiento (...).

Telefónica está en desacuerdo con que la AEPD llega a la conclusión de que las medidas de seguridad de Telefónica no resultaban adecuadas para garantizar la confidencialidad de los datos personales que trata, basándose tan solo en un resultado (la existencia de un ataque dirigido que provocó el Incidente de seguridad).

Entiende Telefónica que, de la información facilitada en el marco de este Incidente, ha quedado sobradamente demostrado que las medidas de seguridad implantadas por parte de Telefónica en lo que respecta al tratamiento de datos personales de sus clientes son apropiadas y resultan razonables para garantizar una seguridad adecuada. No obstante, no se pueden analizar las actuaciones llevadas a cabo por Telefónica ni las medidas implantadas, sin tener en consideración la continua innovación de las técnicas de fraude y la sofisticación de los atacantes a la hora de perpetrar y evolucionar sus técnicas (tal y como se detallará también en la siguiente alegación).

Además, señala Telefónica que la Agencia no ha analizado en ningún momento la metodología ni los protocolos de actuación con los que cuenta Telefónica en relación con la implantación de medidas de seguridad en los tratamientos de datos de carácter personal. Es decir, tan solo se ha basado en lo sucedido en un incidente puntual para tramitar una especie de "causa general" y argumentar la presunta insuficiencia de medidas de seguridad, estableciendo una clara obligación de resultado y exigiendo una infalibilidad de medidas que carecen totalmente de sentido.

En concreto, señala Telefónica que la AEPD parece que reprocha en el Acuerdo de Inicio que Telefónica (...) -

Indica Telefónica que, en ese sentido, es importante dejar claro que tanto el Grupo Telefónica como Telefónica de España están plenamente concienciados y preocupados por garantizar la seguridad y por el cumplimiento de la normativa en el tratamiento de datos que hacen. Un ejemplo de lo anterior es la existencia de diferentes políticas y manuales con los que cuentan en esta materia.

(...)

Indica Telefónica que el enfoque sobre la gestión de riesgos en Telefónica, tal y como se describe en este Manual, se basa en definir y aplicar un proceso de análisis de riesgos de seguridad que permita identificar, analizar y evaluar los distintos riesgos de seguridad para alcanzar los objetivos, disminuir situaciones indeseadas y alcanzar la mejora continua del nivel de seguridad.

(...)

En dicho estándar internacional, se define un catálogo de amenazas y en cada una de ellas se detalla la probabilidad de materialización y el nivel de degradación (potencial daño que una amenaza puede causar a un activo determinado) en cada dimensión de seguridad. Además, ese estándar también cuenta con un catálogo de controles en cada dimensión de seguridad, el nivel de mitigación de la probabilidad y/o degradación para cada amenaza y el tipo de activo en el que aplica el objetivo de control.

En concreto, la metodología de análisis de riesgos de seguridad de Telefónica se basa en los siguientes pasos:

(...). Lo anterior evidencia que Telefónica, concienciada con la necesidad de evolucionar sus medidas de seguridad, cuenta con numerosas iniciativas para hacerlo. (...)

A continuación, Telefónica incluye un recopilatorio de las principales medidas con las que cuenta para cumplir con las obligaciones previstas en la normativa de protección de datos. El hecho de que existan estas medidas justifica también el motivo por el que en este caso se concluyó que la materialización del riesgo de acceso al sistema con credenciales válidas podría ocurrir tan solo bajo circunstancias excepcionales:

2.1. Telefónica cuenta con certificados que acreditan la gestión de la seguridad, atendiendo a lo previsto en la normativa

Señala Telefónica que, en su compromiso de cumplir con la normativa que resulta de aplicación y de dotar de la mayor seguridad y calidad a sus servicios, cuenta con diferentes certificados que acreditan la buena gestión de la seguridad de la información.

Por ejemplo:

(...)

Concluye Telefónica que los certificados con los que cuenta acreditan su buena gestión de la seguridad de la información.

2.2 Medidas de concienciación a empleados

Telefónica considera fundamental la concienciación de los empleados en lo referente a la seguridad de la información, ya que son una fuente más de detección de posibles incidentes y uno de los eslabones a los que hay que proteger (frente a técnicas de phishing, smishing...). Dentro de esta labor de concienciación, liderada desde el área de seguridad de la información de Telefónica, se realizan por ejemplo las siguientes acciones:

- Formación continua, mediante píldoras y consejos de seguridad, cursos de ciberseguridad, talleres específicos como “pescando al Phishing”, etc.
- Campañas periódicas de concienciación específicas de Phishing/Smishing/Qrishing2 a todos los empleados para dar formación sobre este tipo de ataques.
- Concienciación relacionada con este tipo de ataques, a través de seminarios web y talleres participativos.
- Formación sobre las pautas de actuación en caso de recibir notificaciones de origen dudoso, incluida la forma de comunicarse con los equipos de respuesta y gestión de incidentes de Telefónica.
- Información y noticias en canales de comunicación internos de Telefónica.

Además, indica Telefónica que, con el objetivo de medir el nivel de concienciación de los empleados y determinar si es necesario implementar medidas adicionales, se les realizan encuestas anuales. También se realizan campañas de simulacro de phishing, enviando correos o SMS a todos los empleados con temáticas actuales y simulando lo que podría ser una campaña maliciosa.

En caso de que haya empleados que fallen en el simulacro, se les avisa y se les aplican medidas de refuerzo adicional.

Aporta Telefónica imágenes de “pantallazos” de correos al respecto.

En definitiva, concluye Telefónica que es una empresa muy concienciada con que la seguridad es una cuestión de todos los empleados y no sólo de determinadas áreas de la compañía.

2.3 Medidas de control de acceso

(...)

2.4 Medidas para el control de dominios web y correos que puedan incluir contenido malicioso

(...)

2.5 Medidas para la protección de los dispositivos proporcionados a los empleados

(...)

Concluye Telefónica que todo lo anterior no hace más que evidenciar que cuenta con unas medidas que resultan apropiadas para garantizar la confidencialidad de los datos personales que trata.

2.6. Información que el sistema *****APP.1** almacena y riesgo asociado para los derechos y libertades de las personas físicas

Señala Telefónica que las medidas de seguridad aplicadas a *****APP.1** también eran adecuadas teniendo en cuenta la categoría de datos almacenada en el sistema y los posibles riesgos que podrían llegar a existir para los derechos y libertades de los interesados.

(...)

Es evidente que no se trata de datos sensibles, ni datos cuya pérdida de control pudiera implicar graves consecuencias para los interesados, ya que:

(...)

En cualquier caso, y de cara a la evaluación de riesgos, si un tercero quisiera explotar la información mencionada, debe tenerse en cuenta que:

(...)

Concluye Telefónica que lo anterior evidencia que las medidas de seguridad de *****APP.1** también eran apropiadas para garantizar la seguridad, teniendo en cuenta la categoría de datos que se almacenaba y la valoración de posibles riesgos para los derechos y libertades de los interesados.

2.7 Revisión y actualización de las medidas técnicas y organizativas de manera continua

Indica Telefónica que actúa con total diligencia a la hora de revisar y actualizar las medidas técnicas y organizativas implantadas cuando es necesario y/o conveniente para garantizar al máximo la seguridad del tratamiento de los datos personales de sus clientes, así como el respeto y cumplimiento de los principios rectores que rigen la normativa de protección de datos y, en particular, el Reglamento General de Protección de Datos.

Señala Telefónica que se realiza un análisis de riesgos de seguridad de los sistemas de información que soportan los tratamientos de datos para determinar si el nivel de riesgos es el adecuado. En caso negativo, se ponen en marcha planes de tratamiento de riesgos para conseguirlo.

Advierte Telefónica que para valorar de una manera justa y objetiva la adecuación del proceso de revisión y actualización de las medidas de seguridad adoptadas por la entidad, es necesario determinar el momento en el cual aparece un nuevo riesgo. Es decir, no se puede analizar las actuaciones llevadas a cabo por Telefónica sin tener en consideración que el auge de este tipo de fraudes es notoriamente reciente y las características del fraude cometido en este caso en concreto.

Manifiesta Telefónica que ante este tipo de ataques que persiguen la comisión de un delito por parte de un tercero, la compañía lleva a cabo numerosos esfuerzos diarios para proteger a sus clientes:

(...)

De lo expuesto concluye Telefónica que tiene establecidas medidas técnicas y organizativas que resultan adecuadas y que se revisan y actualizan de manera continua para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito.

En definitiva, considera Telefónica que el relato contenido en esta alegación segunda permite demostrar que ha actuado en todo momento con el más absoluto respeto por las obligaciones que le impone la normativa nacional y europea en materia de protección de datos y que ello evidencia que en ningún caso podría considerarse que se encuentra ante la comisión de las presuntas infracciones que señala la AEPD en su Acuerdo de inicio.

Tercera. Superación de la esfera de responsabilidad de Telefónica: circunstancias excepcionales que han hecho posible la superación por terceras personas de las políticas de seguridad implantadas.

Indica Telefónica que en este caso los atacantes accedieron a *****APP.1** con credenciales legítimas, obtenidas por una campaña muy sofisticada de smishing dirigida a numeraciones personales de los empleados. Es decir, señala Telefónica que es una de las herramientas más avanzadas con las que cuentan los ciberdelincuentes para suplantar la identidad de un tercero y cometer un delito.

Señala Telefónica que el atacante conocía con carácter previo los números de teléfono personales de los empleados (que pudo obtener de cualquier ataque a otra institución). Lo anterior provocó que para Telefónica fuese imposible detectar que los empleados estaban recibiendo dichos SMS al enviarse a dispositivos privados. En consecuencia, no pudo establecer unas medidas de forma proactiva que detuviesen el ataque en una fase más temprana.

Aclara Telefónica que, cuando el ataque se dirige a numeraciones o cuentas de correo corporativas, Telefónica cuenta con medios para detectarlo a través de las diferentes

medidas de seguridad que tiene implementadas, y que se han detallado en la alegación anterior (como la monitorización de dominios web para detectar páginas que puedan incluir contenido fraudulento). Una vez detectado, se adoptan las medidas necesarias, se resetean las credenciales que se puedan ver implicadas y se comunica inmediatamente a los empleados. Aporta Telefónica imágenes de avisos que ha remitido a sus empleados cuando se ha detectado alguna campaña de smishing, a través de canales internos de comunicación.

Desgraciadamente, recuerda Telefónica que tanto ella como otras empresas e instituciones públicas deben enfrentarse cada vez más a terceros cuya intención es la comisión de este tipo de delitos. Dichos terceros siempre van por delante, y mejoran continuamente sus técnicas con dicho objetivo, aprovechando para ello las posibilidades que ofrece el uso de la tecnología y la ingeniería social.

Como muestra de lo indicado señala Telefónica las constantes noticias que aparecen en los medios y las recomendaciones y análisis de diferentes organismos, que cada vez con mayor asiduidad, muestran esta problemática. Aporta Telefónica varios ejemplos de ello publicados en diferentes páginas web, incluso de la propia AEPD.

En definitiva, señala Telefónica que los suplantadores hacen uso de las mencionadas técnicas de ingeniería social o del descuido de los propios usuarios, a la hora de compartir información en Internet o de permitir que otros accedan a ella, para obtener los datos que necesitan y después dirigirse a las empresas y poder efectuar este tipo de ataques.

Recuerda Telefónica que deben tenerse en cuenta las características del ataque y de los ciberdelincuentes que provocaron este Incidente. En estos momentos, varios atacantes han sido detenidos y existe una investigación policial en torno a sus prácticas en el marco de la denominada **“***INVESTIGACIÓN.1” y ***INVESTIGACIÓN.2”**.

Señala Telefónica que ello evidencia la constante evolución y sofisticación de las técnicas utilizadas por los defraudadores y la difícil postura que asumen las diferentes empresas e instituciones que se convierten en objetivos de este tipo de delitos. Ante esta situación, Telefónica no puede sino establecer medidas técnicas y organizativas apropiadas en función de los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas en la medida que éstos se producen, sin que pueda ser exigible que dichas medidas eviten cualquier tipo de riesgo futuro.

En definitiva, Telefónica entiende que es fundamental que la AEPD tenga en cuenta la continua innovación de las técnicas de fraude y la sofisticación de los suplantadores a la hora de perpetrar y evolucionar dichas técnicas. Es evidente que en este caso el ataque sufrido fue ejecutado por actores avanzados, como parte de un ataque dirigido. Estos atacantes se caracterizaban por adquirir un conocimiento profundo y detallado de las operativas y las redes de las organizaciones atacadas. No estamos hablando de un atacante oportunista, sino de una operación bien diseñada y que partía de un conocimiento previo de la empresa, probablemente adquirido por otros medios no informáticos con anterioridad.

En consecuencia, Telefónica se convierte en una víctima más de este tipo de delinquentes. Por ello, como ya hemos trasladado, esta parte colabora en las investigaciones policiales iniciadas por la Guardia Civil (*****EXPEDIENTE.1**), cuyo objeto es tanto la detección de los responsables de los hechos como determinar su alcance y conexiones con otras actividades similares.

En la actualidad, especifica Telefónica que (como perjudicada por las actividades investigadas por la Guardia Civil) está personada como acusación particular (...).

Según Telefónica, todo lo anterior demuestra que las actividades delictivas que impactaron en Telefónica afectaron también a otras entidades e instituciones del Estado, acreditándose la complejidad y sofisticación del ataque ejecutado por personas especialmente preparadas para estas actividades delictivas.

II. Sobre los fundamentos de derecho

Primera. Sobre las cuestiones previas planteadas por la AEPD

Recuerda Telefónica que en el segundo apartado de los fundamentos de derechos del Acuerdo de inicio (relativo a “cuestiones previas”), la AEPD señala que *“en el caso que nos ocupa, la brecha de seguridad sufrida ha afectado a datos personales tratados por Telefónica en su condición de responsable del tratamiento, al determinar los fines y medios respectos de esos tratamientos, en virtud del artículo 4.7 del RGPD”*.

En línea con lo anterior, reseña Telefónica que en el tercer apartado de los fundamentos de derecho, entra a valorar *“la naturaleza de los datos afectados por la quiebra” y concluye que “con la dicción actual del RGPD se infiere de forma automática que el número de teléfono fijo es un dato de carácter personal respecto del titular de la línea- es un identificador-, que se basta y se sobra para hacerle identificable”*.

En relación con la naturaleza de los datos afectados por el incidente, Telefónica sostiene que los atacantes que realizaron las consultas de forma no autorizada introdujeron numeraciones de teléfonos fijos que ya conocían de forma aleatoria. Es decir, que los atacantes ya contaban con las numeraciones de forma previa. Por ello, y pese a lo indicado por la AEPD en el Acuerdo de inicio, Telefónica entiende que deberían tenerse en cuenta en este procedimiento las siguientes consideraciones de cara a valorar si realmente estos datos pueden tener la consideración de datos personales para terceros ajenos a Telefónica:

- Sobre la numeración fija, no asociada a ningún otro dato personal

Recuerda Telefónica que el pasado 26 de septiembre de 2022 procedió a notificar el Incidente del que deriva este Expediente, atendiendo a lo previsto en la normativa de protección de datos. Una vez realizado el análisis, pudo comprobarse que se habían producido consultas no autorizadas introduciendo numeraciones de teléfono fijo de forma aleatoria (numeraciones que ya conocían los atacantes).

Para analizar la naturaleza de este dato, indica Telefónica que, por un lado, debe partirse del concepto de seudonimización previsto en el Reglamento (UE) 2016/679

del parlamento europeo y del consejo de 27 de abril de 2016 relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (en adelante, Reglamento general de protección de datos o RGPD), que lo define como: *“el tratamiento de datos personales de manera tal que ya no puedan atribuirse a un interesado sin utilizar información adicional, siempre que dicha información adicional figure por separado y esté sujeta a medidas técnicas y organizativas destinadas a garantizar que los datos personales no se atribuyan a una persona física identificada o identificable”*.

Por último, añade Telefónica que la seudonimización y el cifrado son consideradas por el artículo 32 del RGPD como parte de las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo que puede aplicar el responsable de tratamiento. Siendo en este caso, una medida de seguridad aplicada en el sistema al que el atacante tuvo acceso.

En definitiva, insiste Telefónica que para esta entidad (operador de servicios de comunicaciones electrónicas), una numeración telefónica fija es un dato seudónimo, en la medida en la que no puede atribuirse a un interesado sin utilizar información adicional, pero que, unido a dicha información adicional con la que cuenta Telefónica permite identificar a sus clientes. Motivo por el cual Telefónica procedió a realizar la comunicación inicial del Incidente detallado.

Sin perjuicio de lo anterior, entiende Telefónica que es importante que la Agencia se plantee si los datos que se han visto afectados como consecuencia del Incidente de seguridad realmente permitirían que cualquier tercero pueda identificar directa o indirectamente a la persona física. Para ello, debemos partir del, considerando 26 y de la definición del artículo 4 del RGPD que define dato personal como: “toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona”.

Teniendo en cuenta lo anterior, Telefónica no comparte que la numeración telefónica fija permita a un tercero identificar de forma directa o indirecta a un particular de forma razonable, ya que:

- El número de teléfono fijo lo ha introducido un tercero de forma completamente aleatoria, sin ni siquiera saber si dicha numeración pertenecía a Telefónica. En cualquier caso, es una información con la que ya contaban los atacantes.
- Un número de teléfono fijo corresponde a un hogar, que puede estar compuesto por múltiples personas, y no permite identificar por sí mismo a una persona física.
- Dichas numeraciones fijas pueden consultarse en otros organismos, como puede ser la Comisión Nacional de Mercados y la Competencia (en adelante,

CNMC), que traslada información sobre el operador al que pertenece la numeración a través del siguiente enlace <https://numeracionyoperadores.cnmc.es/portabilidad/fija> sin que dicha consulta se considere un tratamiento de datos de carácter personal

- El teléfono fijo no ha sido obtenido de forma directa de los sistemas de Telefónica, ni se han obtenido otros datos que, asociados a dicho número, permitan identificar a una persona física. En caso de que esa numeración introducida correspondiese a Telefónica, los datos obtenidos tan solo han sido datos técnicos de algunos equipamientos de conectividad proporcionados por TDE e instalados en el domicilio del cliente (router, descodificador de la televisión, amplificador wifi, etc.), sin que los mismos se encuentren asociados a otros datos que permitan la identificación de los clientes, tal y como se detallará en el siguiente apartado.

Recuerda Telefónica que sobre si el número de teléfono puede constituir un dato personal se ha pronunciado la AEPD y la Audiencia Nacional en varias ocasiones entre las que se encuentran las siguientes:

- El Informe Jurídico 0285/2006, al indicar que *“desde el punto de vista de la protección de datos personales, el número de teléfono constituirá un dato de carácter personal cuanto resulte adscrito al concreto titular del mismo, o se asocie a datos identificativos adicionales como pueden ser la dirección y esta se almacene con el número llamante, de acuerdo con la definición de datos personales incluida en el artículo 3.a) de la Ley Orgánica, que comprende “cualquier información concerniente a personas físicas identificadas o identificables”*.

- En el mismo sentido, la Sentencia la Audiencia Nacional, Sala de lo Contencioso Administrativo, de 17 septiembre 2008 Recurso Contencioso-Administrativo 353/2007 (incluso en relación con las numeraciones móviles que habitualmente pertenecen a una única persona física y no a un hogar como se ha señalado anteriormente en relación con las numeraciones fijas) señala que:

“En el presente caso la Agencia Española de Protección de Datos no ha razonado, y menos ha acreditado, que a través del número de teléfono móvil se haya identificado al titular del mismo o que a partir del citado número fuese posible tal identificación, de forma que el citado número de teléfono ayuno de otras circunstancias que identifiquen o pudiesen permitir identificar al titular del mismo impide que pueda encajarse en la definición legal de dato de carácter personal. Siendo así, procede la estimación del recurso y la anulación de la resolución impugnada con los efectos derivados de tal anulación”.

Indica Telefónica que este criterio ha sido ratificado por la Audiencia Nacional en sentencia de 8 de marzo de 2002. Según se cita en la misma, *“para que exista un dato de carácter personal (en contraposición con dato disociado) no es imprescindible una plena coincidencia entre el dato y una persona concreta, sino que es suficiente con que tal identificación pueda efectuarse sin esfuerzos desproporcionados”* y *“para determinar si una persona es identificable, hay que considerar el conjunto de los*

medios que puedan ser razonablemente utilizados por el responsable del tratamiento o por cualquier otra persona, para identificar a dicha persona”.

- La Resolución de Archivo de Actuaciones, de 20 de octubre de 2008, de la Agencia Española de Protección de Datos. Expediente N.º: E/00357/2008 se establece que *“el concepto de dato personal, según la definición de la LOPD, requiere la concurrencia de un doble elemento: por una parte, la existencia de una información o dato y, por otra, que dicho dato pueda vincularse a una persona física identificada o identificable”*, y recuerdan la Sentencia de la Audiencia Nacional de 17/09/2008, que ya hemos mencionado, y concluye que *“aplicando la citada doctrina jurisprudencial al presente caso resulta que los números de teléfono publicados no pueden ser considerados datos de carácter personal ya que no se encontraban asociados a ningún dato que identificara a sus titulares o que los hiciera identificables”*.

- Por último, la Sentencia del Tribunal Supremo, Sala Tercera, de lo Contencioso administrativo, Sección 3ª, Sentencia 815/2020 de 18 Jun. 2020, Rec. 1074/2019 que establece que *“la grabación de la voz asociada a otros datos como el número de teléfono o su puesta a disposición de otras personas que pueden identificar a quien pertenece ha de considerarse un dato de carácter personal sujeto a la normativa de protección del tratamiento automatizado de los mismos”*.

A contrario sensu, entiende Telefónica que, según lo indicado por el propio Tribunal Supremo, puede concluirse que en la medida en la que dicho número de teléfono no se encuentra asociado a ningún otro dato que permita identificar a los clientes, no puede considerarse dato personal.

En relación con lo anterior, también es importante tener en cuenta que a nivel europeo se ha concluido que tan solo puede considerarse que nos encontramos ante un dato personal cuando el tercero *“disponga de medios legales que le permitan identificar a la persona interesada gracias a la información adicional de que dispone el proveedor de acceso a Internet de dicha persona”*. Así lo han establecido las siguientes sentencias:

- Sentencia del Tribunal de Justicia (Sala Segunda) de la Unión Europea de 19 de octubre de 2016 (Asunto C-582/14) que establece que: *“El artículo 2, letra a), de la Directiva 95/46/CE del Parlamento Europeo y del Consejo, de 24 de octubre de 1995, relativa a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos, debe interpretarse en el sentido de que una dirección de protocolo de Internet dinámica registrada por un proveedor de servicios de medios en línea con ocasión de la consulta por una persona de un sitio de Internet que ese proveedor hace accesible al público constituye respecto a dicho proveedor un dato personal, en el sentido de la citada disposición, cuando éste disponga de medios legales que le permitan identificar a la persona interesada gracias a la información adicional de que dispone el proveedor de acceso a Internet de dicha persona”*.

- En el mismo sentido, la Sentencia del Tribunal General (Sala Octava ampliada) de la Unión Europea de 26 de abril de 2023 (asunto T-557/20) que

señala lo siguiente: *“Por lo tanto, al no haber investigado el SEPD si Deloitte disponía de medios legales y factibles en la práctica para poder acceder a la información adicional necesaria para volver a identificar a los autores de los comentarios, el SEPD no podía concluir que la información transmitida a Deloitte constituía información sobre una «persona física identificable» en el sentido del artículo 3, punto 1, del Reglamento 2018/1725”.*

Telefónica entiende por todo ello que, en cualquier caso, un dato solo podría tener la consideración de dato personal para un tercero cuando éste dispusiese de medios legales que le permitieran identificar a la persona interesada gracias a la información adicional que tuviese el tercero de dicha persona.

Concluye Telefónica que, por todo lo anterior, como consecuencia del Incidente no se puede considerar que se haya visto afectado ningún dato que permita que, de una forma razonable, cualquier otra persona diferente a Telefónica pueda identificar directa o indirectamente a una persona física (y mucho menos con medios legales).

- Sobre los datos del equipamiento de conectividad

Recuerda Telefónica que, entre los datos técnicos y de configuración del equipamiento de la conectividad del cliente que se pudieron consultar al introducir de forma aleatoria las numeraciones fijas se encontraban, por ejemplo:

- (...)

Alega Telefónica que estos datos no permiten la identificación de los clientes ni si quiera al asociarse a un número de teléfono fijo. Por ejemplo, la MAC tan solo identifica un dispositivo; el nombre de la red wifi no está asociado de manera única a una numeración fija sino que puede corresponder a más de una numeración; y las contraseñas del Wifi constan en el propio router sin cifrar, tratándose de una práctica comercial habitual.

Entiende Telefónica que en la medida en la que los datos de carácter personal son cualquier información referente a personas físicas identificadas o identificables, y en este caso no podría determinarse la identidad de una persona física tan solo con los datos obtenidos al introducir el número de teléfono, debe tenerse presente que los datos que se han visto afectados no pueden ser considerados datos de carácter personal para los terceros que han accedido a ellos sin autorización.

Concluye Telefónica que debe tenerse en cuenta que:

- El número de teléfono fijo no se encuentra asociado a ningún otro dato que permita identificar a los clientes;
- Los datos obtenidos al introducir dicho número, y el propio número, no pueden ser considerados datos de carácter personal para los terceros que han accedido a ellos sin autorización. No podría determinarse la identidad de una persona física tan solo con dichos datos de configuración de algunos equipos (router, decodificador de la tv, amplificador wifi, etc.) como MAC, detalles del fabricante del dispositivo, configuración de los puertos de la conexión o

nombres de la red wifi y su contraseña. Insistimos en que se trata de datos que no se encontraban asociados a otros datos que permitieran la identificación de los clientes, y menos de una forma legal.

Segunda. sobre las presuntas infracciones cometidas por parte de telefónica: vulneración del principio de tipicidad.

Alega Telefónica la ausencia de tipicidad, sobre los siguientes argumentos: que se expondrán con mayor detalle a lo largo de este apartado:

2.1 Sobre la conducta de Telefónica: en ningún caso podría considerarse subsumible en ninguno de los preceptos que esta agencia considera vulnerados.

Recuerda Telefónica que para que una conducta pueda ser reprochada se exige que esta sea típica, antijurídica y culpable. Dicho principio de tipicidad se encuentra previsto en el artículo 27 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público (en adelante, Ley 40/2015) e implica no solo la sujeción del procedimiento sancionador a los dictados de las leyes que describen ilícitos e imponen sanciones, sino también su sujeción estricta.

A juicio de Telefónica, dicho principio se está vulnerando por no ser la conducta realizada por Telefónica subsumible en ninguno de los preceptos cuya infracción se imputa. Para dejar claro lo anterior, recordemos que los artículos que la AEPD considera vulnerados: artículo 5.1 f) del RGPD y artículo 32 del RGPD:

Indica Telefónica que ninguno de los supuestos mencionados se produce en este caso, pues, en general, cuenta con unas medidas técnicas y organizativas apropiadas en lo que respecta al tratamiento de datos personales en sus sistemas, tal y como ha quedado probado en los hechos de este escrito.

Manifiesta Telefónica que dichas medidas técnicas y organizativas son apropiadas y garantizan un nivel de seguridad que es adecuado al riesgo teniendo en cuenta el estado de la técnica, los costes de aplicación y la naturaleza, el alcance, el contexto, y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, ya que:

- ✓ Las medidas técnicas y organizativas implantadas son el resultado de un minucioso y continuo proceso de estudio que abarca múltiples disciplinas y áreas del conocimiento (asesoría jurídica, seguridad, prevención del fraude). Este proceso cumple con todas las garantías y con el máximo respeto y observancia de los principios rectores relativos al tratamiento de datos personales y las medidas de seguridad que se contemplan en los artículos 5. 1 f) y 32 del RGPD.

Además, Telefónica cuenta con políticas de seguridad y manuales operativos de valoración de riesgos de seguridad que detallan una metodología basada en estándares internacionales. De dicha documentación, puede concluirse que esta parte tiene establecidas medidas técnicas y organizativas que resultan apropiadas y que, de hecho, se han aplicado en este caso concreto. Todo ello,

puesto que ha quedado probado que por parte de Telefónica se habían analizado los sistemas afectados por el Incidente y se disponía de un análisis de riesgos que valoraba las medidas aplicadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito.

Asimismo, ha quedado probado que dichas medidas se revisan y actualizan cuando es necesario a fin de garantizar la seguridad del tratamiento de los datos personales de los clientes y el cumplimiento de las exigencias recogidas en el RGPD.

✓ En concreto, y en relación con la evaluación de riesgos de este caso concreto, recordemos que:

- El sistema *****APP.1** almacena información que tan solo se utiliza para fines de soporte y mantenimiento al cliente por parte de los equipos técnicos de Telefónica.
- En cuanto a los datos comprometidos por el incidente, los atacantes tan solo tuvieron acceso a datos técnicos y de configuración del equipamiento de conectividad, asociados a un número de teléfono fijo del que ya disponía el atacante (dirección MAC del router, VLANs asociadas a servicios, fabricante del dispositivo y firmware, SSIDs (nombre de la Red WiFi), estándar de cifrado, contraseña de las redes inalámbricas y rangos de direccionamiento de la red interna).

Para Telefónica, una numeración telefónica fija es un dato seudónimo, en la medida en la que no puede atribuirse a un interesado sin utilizar información adicional, pero que, unido a dicha información adicional con la que cuenta esta parte permite identificar a sus clientes.

En ese sentido, es importante recordar que la seudonimización y el cifrado son consideradas por el artículo 32 del RGPD como parte de las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo que puede aplicar el responsable de tratamiento. Siendo en este caso, una medida de seguridad aplicada en el sistema al que el atacante tuvo acceso.

Terceros ajenos a Telefónica no podrían determinar la identidad de una persona física tan solo con los datos obtenidos al introducir el número de teléfono (y menos de una forma legal).

Teniendo en cuenta lo indicado, es evidente que no se vieron afectados otros datos que permitieran una identificación directa de los interesados, como podían ser el nombre y apellidos, dirección postal, datos de facturación y cuenta bancaria, detalles de llamadas u otro tipo de información sensible de la que dispone Telefónica o se pudiera encontrar en el sistema mencionado.

- En cuanto al carácter sensible de estos datos, en este caso no hubo colectivos vulnerables ni menores afectados que hubiese que tener en consideración.

Además, y pese a que Telefónica es operador de servicios de comunicaciones electrónicas, no se vieron afectados datos de tráfico ni que se encontrasen sujetos al secreto de las comunicaciones.

- No se tienen evidencias de que se haya realizado ningún tipo de explotación adicional de los datos mencionados. Sin perjuicio de lo anterior, se ha valorado en todo momento qué sucedería si los terceros que accedieron a la información detallada quisieran explotar los datos para la comisión de un delito y se ha podido concluir que era y es improbable que existieran consecuencias para los interesados, teniendo en cuenta el detalle de lo sucedido y la información obtenida (este análisis constaba en el Informe del Incidente, con el que ya cuenta la Agencia, y volveremos a referirnos a él al tratar el principio de proporcionalidad).

Teniendo en cuenta el ejercicio de ponderación mencionado en los párrafos anteriores, concluye Telefónica que cuenta con unas medidas de seguridad apropiadas que garantizan un nivel de seguridad que es adecuado al riesgo (en particular, para impedir el acceso o uso no autorizado de los datos personales de los clientes) y que Telefónica realizó un análisis de riesgos adecuado en este caso.

Señala Telefónica que las causas que han originado el Incidente no pueden atribuirse bajo ningún concepto a una ausencia de previsión y control ni, por tanto, a un incumplimiento de las obligaciones establecidas en la normativa en materia de protección de datos. Por el contrario, se han producido determinados actos de terceros, a los que ya hemos hecho referencia en los hechos y que detallaremos de nuevo al tratar la ausencia de culpabilidad de Telefónica.

Alega Telefónica que la norma no exige la infalibilidad de las medidas de seguridad, sino que estas sean apropiadas. Infalibilidad que sí parece estar exigiéndose a Telefónica, atendiéndose tan solo al resultado producido en este caso y asumiendo de esa forma la existencia de una obligación de resultados y una responsabilidad objetiva (sobre la que nos pronunciaremos con mayor detalle más adelante) como justificación suficiente para considerar que existen dos infracciones y que son muy grave y grave respectivamente.

Señala Telefónica que incluso el Grupo de trabajo sobre protección de datos del artículo 29, en las “Directrices sobre la notificación de las violaciones de la seguridad de los datos personales de acuerdo con el Reglamento 2016/679” reconoce que, aunque se implementen las medidas de seguridad pueden existir riesgos, al indicar que: “(...) *un elemento clave de cualquier política en materia de seguridad de los datos es poder, en la medida de lo posible, prevenir una violación y, cuando a pesar de todo se produzca, reaccionar de forma rápida*”.

Por su parte, recuerda Telefónica que el CIPL (Centre for Information Policy Leadership), en sus comentarios acerca de las directrices sobre la notificación de violaciones de datos personales del Grupo de Trabajo del Artículo 29 (“*Comments by the Centre for Information Policy Leadership On the Article 29 Working Party’s “Guidelines on personal data breach notification under Regulation 2016/679” Adopted on 3 October 2017*”) ilustra bien la diferencia entre mitigación del riesgo e infalibilidad,

al indicar que no puede ser una obligación para las organizaciones garantizar la seguridad absoluta de las operaciones de tratamiento de datos (*"It cannot be an obligation for organisations to guarantee absolute security of data processing activities"*).

Señala Telefónica que, en el mismo sentido, la Sentencia de la Audiencia Provincial de Valladolid (Sección 1ª) núm. 74/2010 de 10 marzo (AC 2010\368), en relación con el presunto incumplimiento de medidas de seguridad por parte de un banco, expone que:

"En cualquier sistema operativo, incluso en el tradicional, existen riesgos y lo determinante para atribuir responsabilidades será si en el utilizado se daban garantías suficientes, sin que pueda llegarse a la conclusión contraria por el mero hecho de que posteriormente se hayan mejorado los sistemas de seguridad, que es de lógica que se vayan modernizando y perfeccionando ante nuevas prácticas defraudatorias que hacen ineficaces los anteriores".

Destaca Telefónica que es fundamental destacar que el Tribunal Supremo establece que la obligación de las empresas de adoptar las medidas necesarias para garantizar la seguridad de los datos personales no puede considerarse una obligación de resultado (Sentencia 543/2022 del Tribunal Supremo de 15 de febrero de 2022):

"La obligación de adoptar las medidas necesarias para garantizar la seguridad de los datos personales no puede considerarse una obligación de resultado, que implique que producida una filtración de datos personales a un tercero exista responsabilidad con independencia de las medidas adoptadas y de la actividad desplegada por el responsable del fichero o del tratamiento."

En las obligaciones de resultado existe un compromiso consistente en el cumplimiento de un determinado objetivo, asegurando el logro o resultado propuesto, en este caso garantizar la seguridad de los datos personales y la inexistencia de filtraciones o quiebras de seguridad. En las obligaciones de medios el compromiso que se adquiere es el de adoptar los medios técnicos y organizativos, así como desplegar una actividad diligente en su implantación y utilización que tienda a conseguir el resultado esperado con medios que razonablemente puedan calificarse de idóneos y suficientes para su consecución, por ello se las denomina obligaciones "de diligencia " o "de comportamiento".

La diferencia radica en la responsabilidad en uno y otro caso, pues mientras que en la obligación de resultado se responde ante un resultado lesivo por el fallo del sistema de seguridad, cualquiera que sea su causa y la diligencia utilizada. En la obligación de medios basta con establecer medidas técnicamente adecuadas e implantarlas y utilizarlas con una diligencia razonable.

En estas últimas, la suficiencia de las medidas de seguridad que el responsable ha de establecer ha de ponerse en relación con el estado de la tecnología en cada momento y el nivel de protección requerido en relación con los datos personales tratados, pero no se garantiza un resultado (...)

Ya hemos razonado que la obligación que recae sobre el responsable del fichero y sobre el encargado del tratamiento respecto a la adopción de medidas necesarias para garantizar la seguridad de los datos de carácter personal no es una obligación de resultado sino de medios, sin que sea exigible la infalibilidad de las medidas adoptadas. Tan solo resulta exigible la adopción e implantación de medidas técnicas y organizativas, que conforme al estado de la tecnología y en relación con la naturaleza del tratamiento realizado y los datos personales en cuestión, permitan razonablemente evitar su alteración, pérdida, tratamiento o acceso no autorizado.”

En definitiva, concluye Telefónica que lo expuesto no hace más que evidenciar que el hecho de que las medidas de seguridad no puedan llegar a ser infalibles en ningún caso significa que no sean adecuadas. Así, la legalidad o no de una medida de seguridad (es decir su adecuación) viene determinada por su contribución a la reducción de la probabilidad de ocurrencia del incidente, no en asegurar un resultado. Todo lo anterior confirma la falta de tipicidad de la conducta reprochada legalmente.

2.2 Sobre la redacción de la normativa que resulta de aplicación: conceptos jurídicos indeterminados que contribuyen a incrementar la inseguridad jurídica e indefensión de Telefónica

Subraya Telefónica que el principio de tipicidad también implica la exigencia de que la norma tipifique de forma clara y precisa cuáles son las conductas que el ordenamiento califica como infracciones y cuáles las concretas sanciones previstas para tales ilícitos. La Sentencia del Tribunal Supremo de 26 de junio de 2001 (RJ 2001, 5740), que recuerda la doctrina del Tribunal Constitucional a tal efecto, señala que:

“La doctrina del Tribunal Constitucional y la jurisprudencia de esta Sala han visto en el principio de legalidad una doble garantía: una de orden material y alcance absoluto, referida tanto al ámbito estrictamente penal como administrativo, que refleja la importancia de la seguridad jurídica en dichos campos limitativos de derechos y que supone la imperiosa necesidad de predeterminación normativa de las conductas infractoras y de las sanciones correspondientes, es decir la existencia de preceptos jurídicos (“lex previa”) que permitan predecir con suficiente grado de certeza (“lex certa”) aquellas conductas infractoras y se sepa a qué atenerse en cuanto a la aneja responsabilidad y a la eventual sanción; otra, de carácter formal, relativa a la exigencia de que exista una norma del suficiente rango que se identifica con el rango legal (por todas STC 61/1990, de 29 de marzo (RTC 1990, 61) [RTC 1990, 61])”.

Por ello, señala Telefónica que otra exigencia unida al principio de tipicidad es la importancia de que la norma reguladora no efectúe formulaciones vagas, abiertas o excesivamente amplias de los ilícitos y sanciones, que carezcan de la suficiente determinación, ya que “se permitiría al órgano sancionador actuar con un excesivo arbitrio y no con el prudente y razonable que permitiría una debida especificación normativa” (STC 61/1990, de 29 de marzo).

A tenor de lo anterior, alega Telefónica, en relación con los artículos del RGPD que se consideran vulnerados en el presente procedimiento sancionador, la ambigüedad e

indeterminación de los conceptos recogidos en dichos preceptos, tales como: “seguridad adecuada”, “medidas técnicas y organizativas apropiadas” o “nivel de seguridad adecuado al riesgo”. Dichos conceptos no son definidos en la normativa de protección de datos, y esta Administración, en su aplicación e interpretación, actúa de manera arbitraria exigiendo a Telefónica una responsabilidad objetiva, al centrarse tan solo en el resultado producido en un Incidente en concreto y sin tener en cuenta que no puede exigirse la infalibilidad de las medidas adoptadas (tal y como se ha detallado en el punto 2.1 de este apartado).

Recuerda Telefónica que es el artículo 9.3 CE el que dispone que: “La Constitución garantiza el principio de legalidad, la jerarquía normativa, la publicidad de las normas, la irretroactividad de las normas sancionadoras no favorables o restrictivas de derechos individuales, la seguridad jurídica, la responsabilidad y la interdicción de la arbitrariedad de los poderes públicos”.

Como señala la STC 104/2009, de 4 de mayo (RTC 2009, 104) “la garantía material implica que la norma punitiva permita predecir con suficiente grado de certeza las conductas que constituyen infracción y el tipo y grado de sanción del que puede hacerse merecedor quien la cometa, lo que conlleva que no quepa constitucionalmente admitir formulaciones tan abiertas por su amplitud, vaguedad o indefinición, que la efectividad dependa de una decisión prácticamente libre y arbitraria del intérprete y juzgador”.

En relación con las infracciones y las sanciones administrativas, y con los aplicadores del Derecho administrativo sancionador, la Sentencia núm. 145/2013 de 11 julio del Tribunal Constitucional (Pleno) (RTC 2013\145) indica que cuando existen estos conceptos indeterminados éstos están obligados a “atenerse, no ya al canon de interdicción de arbitrariedad, error patente o manifiesta irrazonabilidad derivado del art. 24 CE, sino a un canon más estricto de razonabilidad, lo que es determinante en los casos en que la frontera que demarca la norma sancionadora es borrosa por su carácter abstracto o por la propia vaguedad y versatilidad del lenguaje (STC 297/2005, de 21 de noviembre [RTC 2005, 297] , FJ 8, y las Sentencias que allí se citan)”.

En definitiva, concluye Telefónica que la AEPD está propiciando una situación de inseguridad jurídica y dificultando la defensa de Telefónica, pudiendo vulnerarse en consecuencia determinados principios que se encuentran garantizados constitucionalmente (artículos 24, 25 y 9.3 de la Constitución Española).

2.3 Subsidiariamente: sobre la interpretación y aplicación de la normativa realizada por la AEPD. Error en la tipificación y calificación de la infracción y consecuente determinación de la sanción

En primer lugar, Telefónica considera que la apreciación de las dos infracciones (del artículo 5.1 f) y 32 del RGPD) también evidencia un error en la tipificación y calificación de los hechos que realiza la AEPD y en la consecuente determinación de la sanción, pues es evidente que ambos preceptos regulan la seguridad de los datos personales, haciéndolo el primer precepto de una forma más genérica que el segundo, como puede apreciarse a continuación:

Artículo 5.1 f) RGPD: *"1. Los datos personales serán: (...) f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales (...). Artículo 32 del RGPD: "(...) el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo (...)"*

Entiende Telefónica que en el artículo 5 del RGPD se recogen los principios que rigen, con carácter general, el tratamiento de datos personales. Atendiendo a dicha generalidad, en su apartado f) se hace referencia a la necesidad de "una seguridad adecuada". En ese sentido, en ningún caso podría considerarse aplicable a este caso el artículo 5.1 f) del RGPD, cuya redacción es tan genérica que la Administración podría defender que cualquier vulneración del Reglamento puede subsumirse como infracción del mismo. Más allá de lo anterior, recordemos que en ningún caso puede exigirse la infalibilidad de unas medidas de seguridad, ni que sirvan para obtener un resultado concreto. Es decir, el simple hecho de que tenga lugar un incidente de seguridad no puede llevar a la AEPD a la conclusión de que se vulnera el mencionado principio del RGPD.

Por su parte, señala Telefónica que el artículo 32 del RGPD ("seguridad del tratamiento") recoge con carácter más específico la referencia a las "medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo" que la AEPD considera vulneradas. Por tanto, es el artículo 32 del RGPD el que realmente hace referencia a las "medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo". Además, dicho precepto se encuentra recogido en la Sección 2 del Capítulo IV del RGPD, que con mayor grado de especialidad contiene las previsiones relativas a la "Seguridad de los datos personales".

Asimismo, señala Telefónica que, por su parte, la LOPDGDD en su artículo 73 f), a diferencia del artículo 72.1 a), prevé como infracción grave "f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679".

Concluye por ello Telefónica que, en caso de considerarse la existencia de infracción, en ningún caso podría calificarse la conducta de Telefónica como muy grave. Lo contrario supondría un evidente error en la calificación de los hechos que han tenido lugar en este caso. Este error en la calificación de los hechos desencadena también el consecuente error en la graduación de las sanciones que se proponen, ya que se reiteran de forma constante y se duplican.

Telefónica alega que de ello se aprecia una clara reiteración en la voluntad de agravar las dos presuntas infracciones con los mismos fundamentos. En la medida en la que en ningún caso podría considerarse que la conducta de Telefónica es muy grave, por infracción del artículo 5.1f), tampoco podrían tenerse en las agravantes que se aplican a ese precepto.

En conclusión, alega Telefónica que no cabe realizarle imputación alguna, ya que no puede subsumirse su conducta en ninguno de los preceptos que la AEPD considera vulnerados. Más allá de lo anterior, todavía es más evidente que en ningún caso

podría calificarse dicha conducta como muy grave, ya que en caso de entender la Agencia que las medidas técnicas y de seguridad no son adecuadas debería atenderse a lo indicado en este apartado.

Tercera. La conducta de Telefónica no es antijurídica

Telefónica rechaza la antijuridicidad de su conducta en base a los argumentos que se resumen a continuación, y que han quedado plasmados en los hechos de este escrito:

- Telefónica cuenta con medidas técnicas y organizativas diseñadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito. Por ejemplo, cuenta con:

- (...)

- Telefónica cuenta con múltiples mecanismos para detectar el acceso ilegítimo a datos personales, que se adaptan de forma constante. Por ejemplo:

- (...)

En cualquier caso, recuerda Telefónica que la norma no exige la infalibilidad de dichas medidas, sino que las mismas contribuyan a reducir el riesgo.

Cuarta. Ausencia de culpabilidad

Entiende Telefónica que tampoco concurre el requisito de culpabilidad en su actuación, es decir, que no existe el elemento subjetivo de culpa requerido para la imposición de sanciones administrativas.

Señala Telefónica que su actitud revela una inequívoca voluntad de proceder conforme a Derecho, sin existir en modo alguno intencionalidad de infringir la norma y teniendo en todo caso voluntad de cumplimiento. Es doctrina reiterada la que considera que los principios inspiradores del orden penal son de aplicación al derecho administrativo sancionador, señalando que uno de los principales componentes de la infracción administrativa es el elemento de la culpabilidad, lo que presupone que la acción u omisión ha de ser en todo caso imputable a su autor por malicia, imprudencia, negligencia o ignorancia inexcusable. Es decir, es necesaria la constatación de la intervención culpable por parte de Telefónica, que no se ha producido. En tanto no exista conducta culpable, no puede imponerse sanción alguna. A ello se refiere el artículo 28 de la Ley 40/2015 al disponer que *“Sólo podrán ser sancionadas por hechos constitutivos de infracción administrativa las personas físicas y jurídicas, así como, cuando una Ley les reconozca capacidad de obrar, los grupos de afectados, las uniones y entidades sin personalidad jurídica y los patrimonios independientes o autónomos, que resulten responsables de los mismos a título de dolo o culpa”*.

Señala Telefónica que dicha Ley ha venido a sustituir con “culpa” la anterior “simple inobservancia”, lo que supone el reconocimiento de que la simple inobservancia no podía ser entendida efectivamente como la admisión en el derecho administrativo sancionador de la responsabilidad objetiva. La jurisprudencia mayoritaria de nuestro

Tribunal Supremo (a partir de sus sentencias de 24 y 25 de enero y 9 de mayo de 1983) y la doctrina del Tribunal Constitucional (después de su STC 76/1990) destacaban que el principio de culpabilidad, aún sin reconocimiento explícito en la Constitución, se infiere de los principios de legalidad y prohibición de exceso (artículo 25.1 CE) o de las exigencias inherentes a un Estado de Derecho, y requiere la existencia de dolo o culpa.

En este sentido, por ejemplo, la Sentencia del Tribunal Supremo de 16 de diciembre de 2015, señala que: *“En concreto, sobre la culpa, este Tribunal ha declarado que, en efecto, la Constitución española consagra sin duda el principio de culpabilidad como principio estructural básico del Derecho Penal y ha añadido que, sin embargo, la consagración constitucional de este principio no implica en modo alguno que la Constitución haya convertido en norma un determinado modo de entenderlo (STC 150/1991). Este principio de culpabilidad rige también en materia de infracciones administrativas, pues en la medida en que la sanción de dicha infracción es una de las manifestaciones del ius puniendi del Estado resulta inadmisibles en nuestro ordenamiento un régimen de responsabilidad objetiva o sin culpa (STC 76/1990)”*.

Señala Telefónica que la falta de culpabilidad en el caso examinado se manifiesta en torno a que:

- La conducta de Telefónica se desempeñó con toda la diligencia profesional exigible, que actuó con buena fe, y que, por ello mismo, no cabe imputársele un actuar culposo. Es decir, la actitud de Telefónica, tal y como ha quedado manifestado en el presente escrito, revela una inequívoca voluntad de proceder conforme a Derecho sin existir en modo alguno intencionalidad de infringir la norma y teniendo en todo caso voluntad de cumplimiento (desarrollado a continuación en el punto 4.1).
- Las conductas que han provocado las consecuencias expuestas en el Acuerdo de Inicio en ningún caso son imputables a Telefónica (desarrollado a continuación en el punto 4.2).

4.1 La actuación diligente y de buena fe de Telefónica

Entiende Telefónica que todo lo expuesto en el presente escrito es plenamente demostrativo del rigor y diligencia con la que ha actuado, recordemos que:

- Telefónica ha actuado con toda la diligencia exigible a la hora de implantar unas medidas técnicas y organizativas (conforme al estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, la probabilidad y gravedad de los riesgos) que resultan apropiadas para garantizar una seguridad adecuada.

Asimismo, Telefónica trabaja constantemente en la mejora de las medidas de las que dispone con el objetivo de evitar la comisión de cualquier tipo de fraude, en la formación y en la adaptación de los protocolos de seguridad dentro de la organización. Recordemos que el detalle de medidas con las que

cuenta Telefónica ha quedado detallado en la alegación segunda de los hechos de este escrito.

En relación con estas medidas, como ya se ha trasladado, debe quedar claro que la norma no exige su infalibilidad sino que éstas sean apropiadas (como ya se ha indicado en la alegación primera de estos Fundamentos). Sin embargo, insistimos en que la Agencia tan solo se centra en el resultado producido, sin tener en cuenta las circunstancias completamente ajenas a Telefónica que han tenido lugar, exigiendo en consecuencia una responsabilidad objetiva.

- Telefónica ha venido actuando en todo momento de buena fe, y de forma proactiva.

- Telefónica también actuó con total diligencia en la gestión del Incidente, que procedió a comunicar a los interesados, indicándoles claramente las medidas que debían adoptar para cambiar su contraseña y resolviendo todas las dudas que les surgieron con posterioridad. Desde la comunicación, y en tan solo 10 días, desde el buzón del DPO de Telefónica se llegaron a enviar unos 1.700 emails aproximadamente. Asimismo, se adaptaron las operativas de atención al cliente para que pudiera proporcionarse a los interesados la información que necesitasen en relación con el Incidente.

De todo lo anterior subraya Telefónica su buena fe y su diligencia profesional, pues no sólo en ningún momento tuvo ánimo ni intención de incumplir sus obligaciones, sino que actuó en plena creencia de su respeto y plenamente convencida de la efectividad de las medidas de seguridad, establecidas para reducir el riesgo que estaba implicado y ayudando a los interesados a solventar el mínimo riesgo que pudiera existir. Todo ello, amparado en la consideración de que la amenaza de (...). Nuestro Alto Tribunal también ha abordado la buena fe en numerosas ocasiones, así lo hacía ya en la Sentencia del Tribunal Supremo de 17 de diciembre de 1988 que disponía que: *“no es justo sancionar a quien obra de buena fe procediendo dejar sin efecto la sanción cuando el actuar del inculpado fue debido a una determinada creencia excluyente de la culpabilidad”*.

4.2 Circunstancias excepcionales y ajenas a Telefónica. Acciones intencionadas de terceros para la comisión de un delito

Concluye Telefónica que las causas que han originado la situación descrita en el Acuerdo de inicio no pueden imputarse bajo ningún concepto a una ausencia de previsión y control por parte de Telefónica ni, por tanto, a un incumplimiento de las obligaciones establecidas en la normativa en materia de protección de datos. Por el contrario, dichas causas vienen derivadas de determinadas acciones de terceros ajenos a la esfera de actuación y de responsabilidad de Telefónica.

Reseña Telefónica que todo lo anterior evidencia la ausencia de culpabilidad y que la AEPD parece estar centrándose tan solo en el resultado, al considerar que existe infracción por el hecho de “sufrir un ataque informático (...)”. Prácticas de las que en cualquier caso no es responsable Telefónica. Como indica la propia Agencia, se trata de un “ataque informático”.

Recuerda Telefónica lo previsto en el artículo 27 del Código Penal (en adelante, CP), por lo que los responsables de la comisión de un delito son los “autores y los cómplices”, siendo autores “quienes realizan el hecho por sí solos, conjuntamente o por medio de otro del que se sirven como instrumento” (artículo 28 CP). Y está claro que esos autores son terceros, que nada tienen que ver con Telefónica.

Entiende Telefónica que sólo puede concluirse que estamos ante acciones de terceros con voluntad de causar un perjuicio mediante la comisión de conductas delictivas. Telefónica ha actuado en todo momento de buena fe y con la diligencia debida desde la decisión de sobreponerse a los perjuicios que terceros pueden ocasionar, circunstancias que en ningún momento estuvo en situación de evitar. Lo anterior supone que nos encontramos ante un supuesto de fuerza mayor, por encajar las circunstancias descritas en dicho concepto, que determina la falta de responsabilidad o culpabilidad en la conducta infractora.

Destaca Telefónica que en nuestro derecho, no existe una definición pormenorizada de los casos comprendidos dentro de este concepto y cualquier aproximación a una enumeración ha resultado a la postre interpretada como una cita non numerus clausus, ampliada por la vía de la analogía o la interpretación jurisprudencial. Por ello, la más adecuada es la fijada en nuestro Código Civil por cuanto la define por sus características, como aquellos “sucesos que no hubieran podido preverse, o que, previstos, fueran inevitables” (art. 1105 CC), rasgos que ya se ha visto se producen en nuestro caso.

Entiende Telefónica que difícilmente la comisión de un delito como es un ciberataque puede ser impedido por Telefónica, más teniendo en cuenta que los atacantes mejoran constantemente sus técnicas y las características de estos atacantes, tal y como se ha indicado. Sobre la fuerza mayor, como eximente de la responsabilidad, debido a la inevitabilidad previa o imprevisibilidad del suceso interesa destacar:

- Sentencia de la Audiencia Provincial de Málaga (Sección 5ª) núm. 154/2010 de 22 marzo: *“La doctrina jurisprudencial entiende la fuerza mayor y el caso fortuito que contempla el artículo 1105 del Código Civil, en cuanto eximentes de responsabilidad como sucesos que, respectivamente, no hubieran podido preverse, o que, previstos, fueran inevitables”*.
- Sentencia de la Audiencia Provincial de Barcelona (Sección 15ª) de 10 octubre 2002 (JUR 2004\14118): *“La eximente de responsabilidad que configura el art.1105 del CC (...) en cuanto determina la ausencia de culpa, debe apreciarse ponderando la inevitabilidad del suceso en consideración a la diligencia exigible (...)”*.
- Sentencia de la Audiencia Provincial de Barcelona (Sección 15ª) de 31 diciembre 2002 (JUR 2004\14170): *“La eximente de responsabilidad que configura la norma citada (cuya general expresión en nuestro ordenamiento se contiene en el art.1105 del Código Civil [LEG 1889, 27] (...)) se configura como la negación de la culpa, ausencia que debe ser apreciada ponderando la inevitabilidad previa o imprevisibilidad del suceso en consideración a la diligencia exigible (...), que no es la media o común del «buen padre de familia», sino la del buen profesional, siendo éste el modelo de conducta a observar en la ejecución de su prestación”* ▪ Telefónica ha actuado siempre con

plena y fundada creencia excluyente de toda responsabilidad y en cumplimiento de la legislación aplicable.

Más en particular, y sobre la consideración de un ciberataque como causa de fuerza mayor, es fundamental que se tenga en cuenta la Sentencia 37/2022 de 14 Mar. 2022 (Rec. 13/2022 de la Audiencia Nacional, Sala de lo Social). Esta Sentencia comienza recordando la doctrina judicial civilista, STS (Sala de lo Civil) de 22 de noviembre de 2018, que señala que es *“una fuerza superior a todo control y previsión que debe ponderarse a efectos de su concurrencia con la normal y razonable previsión que las circunstancias exijan adoptar en cada supuesto concreto”*. Continúa señalando que:

“Sobre esta nota se ha entendido que debe procederse a una evaluación estudiándose la singularidad en cada caso concreto pues se trata de un concepto jurídico que debe deducirse del conjunto de circunstancias que motiven el hecho o acontecimiento que sobreponiéndose a la voluntad del obligado lo determinan a quebrantar la obligación que le corresponda, ya que siendo la posibilidad de prever los sucesos un concepto amplio, hay que entenderlo en su aplicación legal y práctica, como excluyente de aquellos sucesos totalmente insólitos o extraordinarios que, aunque no imposibles físicamente, no son de los que puede calcular una conducta prudente.

Sobre la concurrencia de causa de fuerza mayor como consecuencia del ataque de virus ransomware en XXXXXXXX, S.A.U. El análisis de los elementos configuradores de la fuerza mayor de los apartados anteriores permite concluir que el ataque informático a través de un virus ransomware que se traduce en el “secuestro” de la información clave de la empresa, afectando de forma determinante a su operatividad, puede ser calificado como un supuesto de fuerza mayor.

En efecto, concurren todos los elementos configuradores que permiten concluir la existencia de causa de fuerza mayor: imposibilidad, existencia de una relación causal entre el incumplimiento de la obligación contractual y el hecho obstativo, inimputabilidad y (al menos) inevitabilidad. Elementos aplicados a la situación concreta descrita en la solicitud de constatación de fuerza mayor, formulada por la empresa. (...) no puede afirmarse como se recoge en la resolución recurrida, que el ataque por ser previsible no puede constituir causa de fuerza mayor y ello por cuanto:

- La fuerza mayor no se reduce a los supuestos de carácter imprevisible, sino también a aquellos que, siendo previsibles, resultan inevitables.

- Cuando se trata de supuestos previsibles, la inevitabilidad debe analizarse ponderando, de un lado, las medidas implantadas por la empresa para la evitación del ataque y, de otro, la complejidad de la circunstancia externa que provoca la imposibilidad objetiva. Analizadas las medidas de seguridad, por consultora externa en informe forense, se constata como eran las propias de un comerciante diligente, sin que pueda imputarse comportamiento negligente y, además, si quiera se conocen medidas alternativas que hubiera podido impedir el ataque del virus, lo que revela su carácter inevitable, debiendo, por tanto, subsumirse en el supuesto de fuerza mayor”.

Teniendo en cuenta lo anterior, concluye que:

“el ataque informático a través de un virus ransomware en una actividad empresarial que gravita sobre una “arquitectura” esencialmente digital como la que lleva a cabo la demandante puede subsumirse en el concepto de fuerza mayor por lo siguiente:

- Primero, el origen humano del hecho obstativo no impide que pueda subsumirse un hecho imposibilitante en el concepto de fuerza mayor;*
- Segundo, concurre una imposibilidad absoluta y objetiva sobre una de las prestaciones esenciales empresariales del contrato de trabajo (dar ocupación efectiva);*
- Tercero, existe una relación causal entre el incumplimiento de la obligación y el hecho obstativo;*
- Cuarto, dado el nivel de diligencia preventiva adoptado por la demandante puede afirmarse que concurre la nota de inimputabilidad y (como mínimo) la de inevitabilidad. En este supuesto, pese a tratarse de un riesgo conocido (y, por ende, previsible), se dan suficientes elementos para entender que el nivel de diligencia empresarial para prevenir este riesgo ha sido el suficientemente elevado como para descartar que su conducta empresarial pueda calificarse como negligente (y por ello imputable), Especialmente porque las medidas que conforman la “Política de seguridad de la información” de la compañía constituyen medidas de precaución adecuadas dentro del grado de esfuerzo y coste de un “ordenado y diligente comerciante”.*

Concluye Telefónica que todo lo expuesto evidencia que no ha concurrido en este caso el elemento esencial de culpabilidad en la conducta de Telefónica, requisito del derecho sancionador, ya que:

- Es evidente y ha quedado probado a lo largo del presente escrito que la actuación de esta parte ha sido diligente en la implantación y adaptación de sus medidas de seguridad.
- En cualquier caso, y ante un ataque dirigido, dicho ataque se produce por multitud de factores que son ajenos a la voluntad y capacidad de actuación de Telefónica, en la medida en la que es evidente que se ha tratado de terceros que tienen la voluntad de cometer un delito, acción que resulta inevitable para Telefónica.

Por lo tanto, reitera Telefónica que en este caso no hay nexo causal por acción u omisión, entre Telefónica y el resultado final, debido a la intervención de terceros con entidad suficiente para alterar ese nexo. No existiendo conducta antijurídica, ni típica, ni culpable de Telefónica en los hechos imputados insistimos en que no debería haberse incoado el procedimiento sancionador, ni debe imponerse a Telefónica sanción alguna.

Quinta. Incumplimiento del principio de proporcionalidad

Alega Telefónica que, en el hipotético caso de que la AEPD carente del adecuado soporte legal y con el único objetivo de imponer una multa, considere sancionar económicamente a Telefónica, el importe de tal sanción deberá ser estimado atendiendo en todo caso al principio de proporcionalidad que rige la potestad sancionadora.

A la necesidad de proporcionalidad se refiere la Sentencia del Tribunal Supremo de 2 de junio de 2003, según la cual el principio de proporcionalidad *“tiende a adecuar la sanción, al establecer su graduación concreta dentro de los márgenes posibles, a la gravedad del hecho constitutivo de la infracción, tanto en su vertiente de antijuricidad como de culpabilidad, ponderando en su conjunto las circunstancias objetivas y subjetivas que integran el presupuesto de hecho sancionable y, en particular, como resulta del artículo 131.3 de la Ley 30/92, la intencionalidad o reiteración, la naturaleza de los perjuicios causados y la reincidencia”*.

Reseña Telefónica que el desarrollo de este principio fundamental no se circunscribe exclusivamente al ámbito jurisprudencial. Los órganos legislativos nacionales y europeos también han tenido en cuenta este principio jurídico a la hora de configurar la normativa de protección de datos, en la que podemos encontrar múltiples referencias al principio de proporcionalidad.

En concreto, debido a la importancia que reviste este principio jurídico, señala Telefónica que el propio Reglamento General de Protección de Datos se encarga de introducirlo en sus Considerandos 4, 129 y 148. A las consideraciones generales contenidas en dichos Considerandos, que ilustran grosso modo el sentido interpretativo con el que se debe analizar el Reglamento, se le añaden las disposiciones particulares que afectan de manera específica a la imposición de multas administrativas. Así, de las condiciones generales para la imposición de multas administrativas se ocupa el Reglamento General de Protección de Datos en su artículo 83. En concreto, el primero de los apartados de este precepto establece que *“Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias”*.

Por su parte, el apartado 2 establece que *“las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j)”*.

Alega Telefónica que de la interpretación de los preceptos expuestos que realiza la AEPD en su Acuerdo de inicio se desprende una clara vulneración del principio de proporcionalidad que debería regir la potestad sancionadora. Dicha vulneración se materializa en la voluntad de imponer a Telefónica una sanción económica que resulta de todo punto ineficaz y desproporcionada.

En concreto, Telefónica considera que no se han tenido debidamente en consideración las previsiones de los artículos 83.1 y 83.2 del RGPD a la hora de determinar el importe de la multa administrativa propuesta. En concreto, la AEPD ha reiterado

constantemente los mismos argumentos para justificar la presunta aplicación de diferentes agravantes y no ha tenido en cuenta la concurrencia de los criterios de graduación que, bajo las premisas del mencionado al artículo 83, permitirían apreciar una reducción del importe de la sanción en caso de que se apreciara a una infracción de la normativa.

5.1 De las agravantes apreciadas por esta agencia en el acuerdo de inicio

- Naturaleza, gravedad y duración (en relación con la presunta infracción del artículo 5.1 f)

- En primer lugar, y sobre la consideración de que *“la naturaleza de la infracción es grave puesto que acarrea una pérdida de confidencialidad y, por tanto, de disposición y control irremediable sobre los datos personales”*, entiende Telefónica que la AEPD está exigiendo una vez más una obligación de resultados en relación con el hecho de impedir la existencia de una violación de seguridad.

Señala Telefónica que, siguiendo este razonamiento, el simple hecho de que un delincuente consiguiera atacar un sistema y provocar un incidente de seguridad supondría que nos encontramos ante una infracción grave, exigiendo en consecuencia una responsabilidad objetiva a cualquier responsable del tratamiento y como justificación suficiente. Como hemos venido trasladando a lo largo del escrito, es evidente que en este caso el resultado del delito cometido por un tercero queda fuera de la esfera de responsabilidad de Telefónica. En cualquier caso, en este caso, el Incidente no ha supuesto ninguna pérdida de control irremediable sobre los datos personales de los clientes (teniendo en cuenta la categoría de datos afectados y los posibles riesgos para los interesados, a los que ya nos hemos referido en los hechos y volveremos a referirnos a continuación).

- En segundo lugar, y sobre el número de personas afectadas, indica señala Telefónica que se limita la AEPD a indicar que “son muy numerosos los afectados, pues asciende a más de un millón de clientes de Telefónica: 1.407.257” de forma constante, sin tener en cuenta que con independencia del número de teléfonos que devolvieron datos al atacante, los datos obtenidos no permiten que un tercero pueda identificar a dicha persona física, ya que se trata de datos que son solo usados para soporte y mantenimiento del router de Telefónica.

Reitera Telefónica que no se ha tenido en cuenta la categoría de datos afectados, pues solo se produjo un acceso no autorizado a los datos de configuración de algunos equipos de conectividad que Telefónica pone a disposición de sus clientes (router, decodificador de la tv, amplificador wifi, etc.) al introducir de forma aleatoria numeraciones de teléfono fijo (ni si quiera se obtuvo esa numeración directamente de Telefónica, sino que los atacantes ya contaban con esos datos).

Insiste Telefónica en que no se vio afectado ningún dato que permitiera identificar a una persona por parte de terceros ajenos a Telefónica. Además, no se vieron afectados otros datos como podían ser el nombre y apellidos, dirección postal, datos de facturación y cuenta bancaria, detalles de llamadas u otro tipo de información sensible de la que dispone Telefónica o se pudiera encontrar en los equipos mencionados.

- En cuanto al nivel de los daños y perjuicios sufridos, advierte señala Telefónica que se limita la AEPD a señalar que es “Alto”, teniendo en cuenta los datos sustraídos. Es decir, la AEPD extrae una serie de conclusiones sobre las consecuencias para los interesados, que no prueba en ningún momento. Más allá de que vuelve a utilizar el argumento de que se trata de un número muy considerable de clientes. Sin embargo, desde Telefónica no se tienen evidencias de que se haya realizado ningún tipo de explotación adicional de los datos mencionados. Por ello, las posibles consecuencias que la AEPD menciona en su Acuerdo de inicio no se han visto materializadas.

Reseña señala Telefónica además que la categoría de datos afectados por el incidente no entra en la categoría de datos sensibles recogida en el art. 9 del RGPD, ni datos cuya pérdida de control pudiera implicar graves consecuencias para los interesados. Es decir, tan solo se trataban datos de configuración de algunos equipos de conectividad que Telefónica pone a disposición de sus clientes al introducir de forma aleatoria numeraciones de teléfono fijo.

Sin perjuicio de lo anterior, y para valorar la gravedad de las consecuencias, para saber qué sucedería si los terceros que accedieron a la información detallada quisieran explotar los datos para la comisión de un delito, recuerda señala Telefónica el análisis realizado por ella cuanto tuvo lugar el Incidente. En ese caso, habría que tener en cuenta que:

- La red Wifi, en su configuración por detecto, se encuentra cifrada de extremo a extremo. Es decir, entre cualquier dispositivo que se conecte al router y dicho router;
- El acceso a cada red Wifi solo podría realizarse cuando el intruso se encuentre físicamente en la zona de cobertura del domicilio de instalación del router. Hay que tener en cuenta que encontrarse en una zona de cobertura fuera del domicilio puede resultar bastante complejo en función de las características del domicilio o edificio, pudiendo llegar a necesitarse incluso medios adicionales para obtenerla, como antenas especiales;
- Para que el intruso se encuentre físicamente en la zona de cobertura del domicilio de instalación del router sería necesario que el tercero contase con la dirección postal a la que corresponden las claves Wifi (dato que no se ha extraído de los sistemas de Telefónica).

Más allá de lo anterior, es importante recordar que el nombre de la red Wifi (SSID, Service Set Identifier) y clave WIFI no son únicos. El SSID de los routers de Telefónica puede estar repetido en el equipamiento de cientos de clientes distintos, lo cual dificulta poder geolocalizar la dirección exacta de donde se encuentra físicamente la red WIFI, que como hemos indicado no se trataba de un dato que fuese extraído de los sistemas de Telefónica.

Además, recordemos que Telefónica comunicó a los interesados la existencia del Incidente y les recomendó el cambio de contraseña para incrementar la seguridad de su red y evitar un posible acceso no deseado, ofreciendo para ello un manual que mostraba los pasos para hacerlo de forma sencilla. En la medida en la que realizaran este cambio, el atacante dejaría de contar con esta información. En cualquier caso, debe tenerse en cuenta que una clave Wifi no

es un dato estático, es un dato que puede cambiar el cliente el cualquier momento.

- Como paso adicional, sería necesario que tuviese lugar otra acción intencionada por parte de los terceros para la comisión de un delito. Es decir, para que el atacante consiguiese conectarse a la red Wifi de un cliente, debería tener las habilidades necesarias para poder realizar una intrusión en su red interna, realizando un ataque adicional.

Las posibilidades de que este ataque permitiesen a los delincuentes obtener un resultado también dependerían de la seguridad de los dispositivos conectados a la red que tenga el cliente (si los dispositivos están actualizados, si los usuarios usan contraseñas robustas, etc.). Cuestión que iría más allá de la responsabilidad de Telefónica.

- En el hipotético caso de que el atacante consiguiese conectarse a través de un dispositivo no autorizado a una red concreta, los clientes tendrían la posibilidad de darse cuenta de dicho acceso. Telefónica dispone de determinados servicios gratuitos que notifican los accesos a la red cuando un nuevo dispositivo accede y protegen la navegación (se trata de servicios que pueden activarse de forma sencilla desde la propia aplicación de Movistar, desde la televisión de Movistar o incluso en el momento de instalación del router de TDE).

Además, debe tenerse en cuenta que entre los datos obtenidos por el atacante no estaba la contraseña de administración del router. Sin esta información no se podría realizar un ataque directo contra el router, haciendo cambios en su configuración.

Manifiesta señala Telefónica que si los atacantes hubiesen deseado atacar la red Wifi de una persona determinada existen otros mecanismos que pueden ser más efectivos y menos costosos para este tipo de delincuentes. Por ejemplo, un ataque dirigido a través de un malware (software malicioso) remitido por correo electrónico, que hubiese permitido comprometer un dispositivo y hubiese facilitado la intrusión, permitiendo el acceso remoto desde Internet sin tener que estar expuesto a estar cerca de la víctima.

Concluye Telefónica que conocer la clave de la red Wifi de un cliente puede facilitar la tarea de superar una primera barrera de seguridad (que es el acceso a la red interna del cliente), pero no permite el acceso a datos personales del mismo. (...)

Por todo lo anterior, indica Telefónica que en la medida en la que se trataba de datos que no se encontraban asociados a otros datos que permitieran la identificación de los clientes y, teniendo en cuenta la valoración de riesgos expuesta, es improbable que pudieran existir consecuencias para los interesados. Muestra de lo anterior es que más de un año después de lo sucedido, Telefónica no ha tenido constancia de ningún tipo de publicación ni explotación de estos datos por parte de terceros ajenos a Telefónica, como ya se había indicado.

Concluye Telefónica que es evidente que el resultado del fraude que parece que la AEPD pretende imputar a Telefónica, queda fuera de la esfera de responsabilidad de

Telefónica. Por ello, la apreciación de la agravante contemplada en el artículo 83.2.a) no puede fundarse en la perpetración de este tipo de delitos. Se estaría incumpliendo así el principio de personalidad de las sanciones administrativas, estrechamente relacionado con los conceptos de dolo y culpa, pues el principio de personalidad de las sanciones es una manifestación del elemento subjetivo de la culpa (entendida en sentido amplio), a su vez necesario para que exista infracción y la subsiguiente sanción.

- Agravantes que se han tenido en consideración para ambas infracciones:

Indica Telefónica que la AEPD señala que se pueden apreciar las siguientes agravantes en relación con las presuntas infracciones de los artículos 5.1 f) y 32 del RGPD:

1. Negligencia en la infracción

Recuerda Telefónica que la AEPD considera que puede apreciarse la agravante prevista en el artículo 83.2.b) RGPD (negligencia en la infracción) tanto para la presunta infracción del artículo 5.1 f) como la del artículo 32 del RGPD, dando en ambos casos los mismos argumentos. Tal consideración parece sostenerse en una supuesta ineficacia de las políticas de seguridad diseñadas por Telefónica.

Entiende Telefónica que es evidente que la AEPD concluye erróneamente que, por el hecho de haberse producido un incidente de seguridad (provocado por ciber atacantes que también atacaron a sistemas de otra empresas e instituciones como el Consejo General del Poder Judicial o la Agencia Tributaria), no existían medidas adecuadas. De esta forma, se está exigiendo una vez más una obligación de resultados (infalibilidad de las medidas) y en consecuencia una responsabilidad objetiva, considerando la existencia de negligencia por el resultado provocado por terceros ajenos a Telefónica.

Recuerda de nuevo Telefónica que:

- Había realizado, con carácter previo a que tuviera lugar el Incidente, un análisis de riesgos del sistema afectado, de conformidad con una metodología basada en un estándar internacional.
- Realiza periódicamente campañas de concienciación a empleados mediante el envío de correos simulando un ataque de phishing.
- Realiza charlas de formación para la detección y reporte de phishing a ciertos colectivos de empleados.
- En todas las aplicaciones accesibles desde el dominio público ***PORTAL.1.telefonica.es existe un control contra ataques de fuerza bruta que bloquea un usuario cuando se realizan más de 5 intentos de autenticación durante 30 minutos.

- Existe una política de caducidad de la contraseña de 90 días. Alcanzado ese tiempo, el usuario tiene que cambiar la contraseña, en caso contrario, el usuario es bloqueado.

- Se tenía un plan anterior al Incidente de despliegue de un Sistema WAF en la Aplicación ***URL.1. Lo anterior evidencia que Telefónica es una empresa totalmente concienciada con la necesidad de evolucionar las medidas de seguridad y cuenta con numerosas iniciativas de actualización de dichas medidas. Además, y teniendo en cuenta las características del Incidente, el plan fue ejecutado el día 6 de octubre de 2022.

Telefónica recuerda de nuevo la Sentencia 543/2022 del Tribunal Supremo de 15 de febrero de 2022, respecto de que la obligación de adoptar las medidas necesarias para garantizar la seguridad de los datos personales no puede considerarse una obligación de resultado, sino que es una obligación de medios y que no puede exigirse la infalibilidad de las medidas adoptadas.

Concluye por ello Telefónica que, atendiendo a la información trasladada en este escrito y en la documentación con la que ya cuenta la AEPD, en ningún caso podría considerarse que Telefónica no se ha comportado con la diligencia exigible, sino más bien todo lo contrario.

2. Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal

Indica Telefónica que la AEPD considera que procede graduar las sanciones a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 “Sanciones y medidas correctivas” de la LOPDGDD, y que el argumento utilizado para defender la aplicación de esta agravante es exactamente el mismo en la graduación de las dos infracciones imputadas, insistiendo la AEPD en el volumen de datos que trata esta compañía.

Telefónica recuerda que este expediente sancionador viene derivado de un incidente de seguridad concreto. Es decir, este expediente se centra en lo que ha sucedido en un único caso. Teniendo en cuenta lo anterior, resulta llamativo que, a la hora de imponer la sanción, la AEPD haga referencia a que se tratan datos de millones de personas, sin tener en cuenta que los hechos expuestos tan solo habrían afectado a un volumen determinado de clientes en relación con un incidente en concreto, provocado por terceros ajenos a Telefónica, y que ha quedado demostrado que en ningún caso supuso un riesgo para dichos interesados. En este sentido, esta parte no puede más que mostrar su absoluta disconformidad en relación con la apreciación de esta agravante.

Entiende Telefónica que no tiene ningún sentido ni puede sustentarse jurídicamente que por el solo hecho de tratar un volumen elevado de datos, cualquier infracción que se cometa derive en la aplicación directa y objetiva de circunstancias agravantes y que para aplicar circunstancias agravantes es necesario que se produzca una cualificación de la culpabilidad que no puede ser consecuencia inmediata del tamaño, sino que requiere una valoración de las circunstancias concretas del responsable para ver si procede o no procede y, en este caso, debe tenerse en cuenta que tan solo se está

valorando lo sucedido en relación con un único incidente de seguridad que no ha supuesto un riesgo para los derechos y libertades de los interesados. Entenderlo de otro modo iría en contra de la presunción de inocencia que la Constitución proclama y supondría considerar una conducta como infractora sin valorar las circunstancias concurrentes.

5.2 De las atenuantes que deberían haber sido apreciadas por la AEPD en el acuerdo de inicio

Llama la atención Telefónica que la AEPD tan solo haya tenido en cuenta la presunta existencia de agravantes pero no haya tenido en consideración la evidente existencia de las siguientes atenuantes, del artículo 83.2 del RGPD y del 76.2 de la LOPDGDD:

1. “b) la intencionalidad o negligencia en la infracción” (del artículo 83.2 del RGPD)

Reseña Telefónica que no se dan en este caso los requisitos de intencionalidad en la supuesta comisión de las infracciones o una actitud negligente. Todo lo contrario, ha quedado más que demostrada la diligencia en la forma de actuar de esta parte a lo largo de todo este escrito y, en concreto, al tratar la agravante señalada por la Agencia sobre la negligencia en el apartado anterior.

Recuerda Telefónica que el Incidente ha venido derivado de un ataque dirigido contra Telefónica, revelando la actitud de esta parte una inequívoca voluntad de proceder conforme a Derecho, sin existir en modo alguno intencionalidad de infringir la norma y teniendo en todo caso voluntad de cumplimiento.

2. “c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados” (del artículo 83.2 del RGPD)

Señala Telefónica que procedió a comunicar a todos los interesados lo sucedido, indicándoles las medidas que debían adoptar para cambiar su contraseña y resolviendo todas las dudas que les surgieron con posterioridad. En concreto, desde el buzón del DPO de Telefónica se llegaron a enviar unos 1.700 emails aproximadamente en los primeros 10 días y se implantaron operativas concretas para que desde los diferentes canales de Telefónica se pudiese dar respuesta a los interesados.

3. “g) las categorías de los datos de carácter personal afectados por la infracción” (del artículo 83.2 del RGPD)

Recuerda Telefónica que la categoría de datos afectados por el incidente no entra en la categoría de datos sensibles recogida en el art. 9 del RGPD, ni se trata de datos cuya pérdida de control pudiera implicar graves consecuencias para los interesados. Es decir, tan solo se trataban datos de configuración de algunos equipos de conectividad que Telefónica pone a disposición de sus clientes y que no permiten la identificación directa del interesado (recordemos que son el identificador único del dispositivo (la MAC), detalles del fabricante del equipo, configuración de los puertos de la conexión, nombre de la red wifi y su contraseña). Es decir, no se vieron afectados otros datos u otro tipo de información sensible de la que dispone Telefónica o se pudiera encontrar en los equipos mencionados, como podían ser el nombre y

apellidos, dirección postal, datos de facturación, cuenta bancaria o detalles de llamadas.

Reseña también Telefónica que hay que tener en cuenta que los nombres de las Wifis en la mayoría de los casos se repiten y que los rangos de direccionamiento de VLAN son internos y casi todos los clientes tienen las mismas. Es decir, se trata de información que tiene una vida útil limitada al ser datos que pueden ir cambiando con el tiempo.

4. “h) la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida” (del artículo 83.2 del RGPD)

Menciona Telefónica esta atenuante en la medida en la que ha quedado acreditado que fue Telefónica la que puso en conocimiento de la AEPD la existencia de este Incidente, dentro del plazo legalmente establecido y atendiendo a lo previsto en la normativa que resulta de aplicación, como ha quedado reflejado en la alegación previa de este escrito.

5. “j) la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42” (del artículo 83.2 del RGPD) y “h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado” (del artículo 76.2 h de la LOPDGDD)

Subraya Telefónica que suscribió el “Código de Conducta de Autocontrol sobre tratamiento de datos en la actividad publicitaria”. A través de este Código de Conducta se ha establecido, fundamentalmente, un procedimiento extrajudicial de resolución de controversias entre las entidades adheridas al Código y los interesados con motivo de tratamientos de datos realizados en el ámbito de la actividad publicitaria.

6. “k) cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción” (del artículo 83.2 del RGPD) y “c) Los beneficios obtenidos como consecuencia de la comisión de la infracción” (del artículo 76.2 c de la LOPDGDD)

Señala Telefónica que no ha obtenido ningún beneficio financiero, es más, TDE ha sido una víctima más de un delito que le ha provocado daños reputacionales.

Concluye Telefónica que, y llegado el caso en el que la Agencia decida mantener las sanciones pese a los argumentos esgrimidos por esta parte, estas atenuantes deberían ser tenidas en cuenta para la disminución de su importe.

Por todo lo expuesto, Telefónica solicita que:

- i. Se declare la inexistencia de responsabilidad por parte de Telefónica por las presuntas infracciones que se le imputan en este procedimiento, al no existir

conducta antijurídica, ni típica, ni culpable de Telefónica en los hechos imputados, ordenando el archivo del presente expediente sancionador.

ii. Subsidiariamente, y en caso de entender que las medidas técnicas y de seguridad no son adecuadas, debería atenderse a lo indicado en el apartado 2.3 de la alegación segunda de los fundamentos de derecho. De tal forma que, en caso de considerarse la existencia de infracción, en ningún caso podría calificarse la conducta de Telefónica como muy grave.

iii. Subsidiariamente, en caso de que no se estimase la primera pretensión, que se minore la sanción inicialmente propuesta en virtud de los criterios del art. 83 del RGPD y del 76.2 de la LOPDGDD.

iv. Que, en la alegación segunda de los hechos de este escrito, marcada como [CONFIDENCIAL], y en el Documento que se adjunta como Anexo 1, se aporta información de especial carácter sensible que debería ser protegida y declarada confidencial por la AEPD, en aras de prevenir futuros ilícitos por parte de las personas responsables de la tipología de hechos delictivos descritos en este escrito y porque en ellos se expone información y operativas que esta parte considera críticas y confidenciales. En consecuencia, su publicación podría perjudicar los intereses de Telefónica.

NOVENO:

Con fecha 10 de junio de 2024, la instructora del procedimiento acuerda abrir período de práctica de prueba, en la que se acuerda lo siguiente:

“1. Se dan por reproducidos a efectos probatorios las notificaciones de la brecha de datos personales realizadas por TELEFONICA DE ESPAÑA SAU (Telefónica) y su documentación, los documentos obtenidos y generados durante la fase de investigaciones previas, y el informe de actuaciones previas de investigación, que forman parte del procedimiento AI/00356/2022.

2. Asimismo, se da por reproducido a efectos probatorios, las alegaciones al acuerdo de inicio del procedimiento sancionador referenciado, presentadas por Telefónica, y la documentación que a ellas acompaña.

3. Se solicita a Telefónica que aporte la siguiente documentación y/o información:

- Con fecha 2 de noviembre de 2022, por el Inspector actuante durante las actuaciones previas de investigación, se requirió el análisis de riesgos de los tratamientos afectados por la brecha de seguridad.

Dado que el documento aportado no es un análisis de los riesgos de probabilidad y gravedad que el tratamiento de datos personales pueda suponer para los derechos y libertades de las personas físicas, de conformidad con el artículo 32 del RGPD, sino que constituye un análisis de riesgos desde el punto de vista exclusivamente de la seguridad de la información, se solicita que se aporten los análisis de riesgos o, en su caso, la Evaluación de Impacto en Protección de Datos, respecto de las actividades de tratamiento afectadas por

la brecha de datos personales de conformidad con el RGPD y realizada con anterioridad a la fecha de dicha brecha.

- Se aporte, asimismo, en caso de existir, informes de auditorías, pestenting, etc, que se hayan realizado en relación con las aplicaciones informáticas afectadas por el incidente (...).

- Si existía, a la fecha del incidente, implantado un sistema de doble factor de verificación para el acceso a las aplicaciones afectadas. En caso afirmativo, evidencias de ello.

- En la segunda notificación de la brecha de datos personales, presentada en 26 de octubre de 2022, se indica que, una vez concluido el análisis completo del incidente y tras comprobar que hay otro usuario comprometido, se detecta que la fecha de inicio del ataque se produjo desde el día 9 de septiembre de 2022, por lo que los accesos maliciosos se realizaron en tres bloques: del 9 al 11 de septiembre, del 16 al 20 de septiembre y el día 28 de septiembre de 2022. Dado que no consta en esta Agencia, se solicita información de los accesos maliciosos que se produjeron entre el 9 y el 11 de septiembre, (usuario afectado y su rol, accesos que se produjeron, datos personales afectados, por qué no se detectó entonces, etc).

- País de procedencia de las direcciones IP desde las que se llevó a cabo el ataque.

- Evidencias de la existencia, en su caso, de Protocolos de actuación en caso de violación de la seguridad de los datos personales (brecha de datos personales) en el momento de producirse el incidente.”

Con fecha 28 de junio de 2024 se recibió respuesta de Telefónica a las pruebas propuestas, en el que adjunta documentación e indica, en síntesis, lo siguiente:

1. En relación con la solicitud de aportar los análisis de riesgos o, en su caso, la Evaluación de Impacto en Protección de Datos, respecto de las actividades de tratamiento afectadas por la brecha de datos personales de conformidad con el RGPD y realizada con anterioridad a la fecha de dicha brecha, Telefónica indica lo siguiente:

*“El tratamiento de datos que tiene lugar al acceder a *****APP.1** no cuenta con una evaluación de impacto en protección de datos independiente, al no suponer un alto riesgo para los derechos y libertades de las personas físicas.*

Antes de entrar en mayor detalle, debemos hacer una aclaración en relación con el registro de actividades de tratamientos de Telefónica que, con el objetivo de cumplir con las diferentes obligaciones derivadas de la normativa, se encuentra organizado de la siguiente forma:

- Incluye todo el detalle de las actividades de tratamiento de datos que se realizan para cada uno de los fines de tratamiento, con el detalle exigido por la normativa.

- Para cada uno de esos fines puede ser necesario acceder a diferentes sistemas.
- Los sistemas que forman parte de una actividad de tratamiento podrán contar con un análisis de riesgos propio que es realizado por el área de seguridad.
- Asimismo, de cada actividad de tratamiento también se realiza un análisis de riesgos en privacidad (Pre-DPIA). En caso de que en ese análisis se concluya que es necesario realizar una evaluación de impacto (PIA), se realiza dicha PIA.

Una vez aclarado lo anterior, y sin perjuicio de que *****APP.1** no cuenta con una evaluación de impacto en protección de datos independiente, debemos recordar que la actividad de consulta a la información para la atención de averías de los clientes se encuentra englobada en las siguientes operaciones de tratamiento:

Código de tratamiento	Área solicitante	Operación del tratamiento	Descripción
OP_001	OPERACIONES	Atención técnica remota en primera línea (Telefónica, COL...) averías de cliente.	Atención técnica en primer nivel. Atención técnica remota en prima línea (Telefónica, COL...) averías de cliente. Recogida, Extracción, Registro, Modificación, Consulta, Comunicación, Todas estas actividades vinculadas a la prestación del servicio de atención y asistencia técnica al cliente en lo que a servicios Movistar refiere.
OP_002	OPERACIONES	Centros técnicos de atención al cliente.	Atención técnica especializada y remota de averías de cliente en un Segundo nivel de atención.

Estas operaciones de tratamiento abarcan un tratamiento de datos mucho más amplio y que no se ha visto afectado en su totalidad por el ataque que provocó el Incidente objeto de este Expediente. Es decir, es fundamental tener claro que:

- *****APP.1** tan solo es uno de los sistemas a los que se puede acceder para poder proporcionar una atención técnica a los clientes y,
- (...). En cualquier caso, y teniendo en cuenta la solicitud de la AEPD, se procede a proporcionar copia de las evaluaciones de impacto en protección de datos de las operaciones de tratamiento mencionadas (en adelante, Evaluaciones de Impacto o DPIA), como Documentos anexos 1 y 2.

(...) es importante matizar una serie de cuestiones sobre el alcance del Incidente y de los análisis que se aportan en este punto:

a) Sobre *****APP.1** y las categorías de datos incluidas en dicho sistema

*****APP.1** permite que el equipo de personas que atiende las incidencias técnicas de los clientes pueda consultar la información necesaria para el diagnóstico y tratamiento de averías en los equipamientos de conectividad (Router, descodificador de la tv, amplificador wifi, etc.).

(...)

(...)

Además, es importante insistir en que Telefónica ha valorado en todo momento qué sucedería si los terceros atacantes quisieran explotar los datos a los que tuvieron acceso para la comisión de un delito y, como se ha expuesto a lo largo de todo este Expediente, se concluyó que era y es improbable que existieran consecuencias para los interesados, teniendo en cuenta que:

• (...).

Teniendo en cuenta todo lo anterior, y en la medida en la que no era probable que el tratamiento entrañase un alto riesgo para los derechos y libertades de las personas físicas, en el momento de análisis de esta actividad se concluyó que no era necesario que el acceso a *****APP.1** contara con una evaluación de impacto en protección de datos independiente. Recordemos que en el “Informe de análisis de riesgo de *****APP.1**”, que ya tiene la Agencia, consta que el riesgo “para el activo se calcula como el nivel más alto de todos los riesgos identificados, siendo por tanto Moderado”.

b) Sobre las operaciones de tratamiento que incluyen el acceso a *****APP.1**

En primer lugar, es fundamental resaltar que la necesidad de realizar una evaluación de impacto en protección de datos en ambas operaciones de tratamiento surgió por las categorías de datos que resulta necesario tratar para solventar determinadas averías de los clientes (como son los datos de tráfico), tal y como puede comprobarse en las respuestas que se proporcionan en los análisis de riesgos en privacidad (Pre-DPIA) que también se adjuntan como Documentos anexos 3 y 4.

(...)

Sin embargo, y como ya ha quedado probado, *****APP.1** no almacena estas categorías de datos, sino que se encuentran alojadas en otros sistemas a los que se accede con la finalidad de realizar estas actividades de tratamiento, como son *****SISTEMA.1** y *****SISTEMA.2**. La información sobre estos sistemas consta en el apartado “sistemas” de los Documentos anexos 1 y 2

En definitiva, los riesgos que se identificaron en ambas Evaluaciones de Impacto estaban asociados al tratamiento de datos de categorías más sensibles (como datos de tráfico) que se realiza al acceder a los sistemas mencionados.

(...)

Por lo tanto, debe tenerse muy presente que los riesgos que constan en las Evaluaciones de Impacto que se aportan son los riesgos relativos a todo el tratamiento de datos que se realiza en el marco de las operaciones de tratamiento indicadas y no afectan directamente a *****APP.1**.

(...)

La metodología de gestión de riesgos (identificación, evaluación, tratamiento y seguimiento), que consta en el apartado 3 de los Documentos anexos 1 y 2, tiene como objetivo "identificar y evaluar los riesgos relacionados con el tratamiento, así como recoger las medidas previstas para mitigar los riesgos y evaluar el riesgo teniendo en cuenta la implementación de las medidas mitigadoras.

(...)

*Recordemos que en el caso del acceso a sistema ***APP.1, el riesgo máximo detectado fue de moderado, aunque no para el acceso no autorizado. Como ya hemos comentado, y atendiendo al "Informe de análisis de riesgos del sistema ***APP.1" que ya se aportó junto a la respuesta del Requerimiento de información, el riesgo concreto de "Acceso no autorizado a credenciales de usuario legítimas" se encontraba calificado como "Riesgo Residual bajo".*

*Por lo tanto, debe tenerse muy presente que los riesgos que constan en las Evaluaciones de Impacto que se aportan son los riesgos relativos a todo el tratamiento de datos que se realiza en el marco de las operaciones de tratamiento indicadas y no afectan directamente a ***APP.1.*

(...)

Sobre el riesgo 8 que consta en ambos documentos:

(...).

2. En relación con la solicitud de que se aporte, asimismo, en caso de existir, informes de auditorías, pestenting, etc, que se hayan realizado en relación con las aplicaciones informáticas afectadas por el incidente (...), Telefónica indica lo siguiente:

Telefónica ya ha proporcionado en alegaciones previas los diferentes certificados con los que cuenta en materia de gestión de la seguridad de la información. En ese sentido, es importante recordar que Telefónica, en su compromiso de cumplir con la normativa que resulta de aplicación y de dotar de la mayor seguridad y calidad a sus servicios, cuenta con certificados que acreditan la buena gestión de la seguridad de la información. Por ejemplo:

• (...)

En concreto, los certificados del sistema de gestión de seguridad de la información, como señala la propia AENOR, contribuyen a garantizar que "se identifican y valoran los procesos de negocio y/o servicios de TI, activos y sus riesgos, y que se adoptan los controles y procedimientos más eficaces y coherentes con la estrategia de negocio, considerando la mejora continua".

Por su parte, el Esquema Nacional de Seguridad establece una serie de medidas que garantizan la seguridad de los sistemas, los datos, las comunicaciones, y los servicios electrónicos. En ese sentido, contar con esta certificación garantiza que Telefónica dispone "de un sistema gestionado y controlado con medidas/controles que aseguren

la correcta protección de los sistemas de información ante amenazas e incidencias internas y externas”, tal y como también señala AENOR.

En definitiva, los certificados con los que cuenta Telefónica acreditan su buena gestión de la seguridad de la información.”

3. En relación con la solicitud de *si existía, a la fecha del incidente, implantado un sistema de doble factor de verificación para el acceso a las aplicaciones afectadas. En caso afirmativo, evidencias de ello*, Telefónica indica lo siguiente:

*“A fecha del incidente no había un sistema de doble factor de verificación para el acceso a *****APP.1** en la medida en la que no resultaba necesario, atendiendo al análisis de riesgos realizado. Sin perjuicio de lo anterior, en este punto es importante dejar claro que *****APP.1** contaba con unas medidas técnicas y organizativas apropiadas en lo que respecta al tratamiento de datos personales, tal y como ha quedado probado a lo largo de este Expediente.*

(...)

*En concreto, y en cuanto a la valoración del riesgo relativo al “Acceso no autorizado a credenciales de usuario legítimas. (Riesgo Residual bajo)”, al que ya hemos hecho referencia y que consta en el “Informe de Análisis de Riesgos. Sistema *****APP.1**”, recordemos que la probabilidad de materialización de esta amenaza se calificó como baja, atendiendo a los criterios de análisis de riesgos trasladados. En este caso se consideró que la materialización del riesgo tenía una probabilidad remota, entre el 0-10%. Es decir, que su materialización tan solo podría ocurrir bajo circunstancias excepcionales y por este motivo, a fecha del incidente no había un sistema de doble factor de verificación para el acceso a *****APP.1** en la medida en la que no resultaba necesario, atendiendo al análisis de riesgos realizado.*

4. En relación con la solicitud de *información de los accesos maliciosos que se produjeron entre el 9 y el 11 de septiembre, (usuario afectado y su rol, accesos que se produjeron, datos personales afectados, por qué no se detectó entonces, etc)*, Telefónica responde lo siguiente:

En la siguiente tabla se pueden comprobar los usuarios utilizados para realizar el ataque y las fechas de inicio y fin de dichos ataques. En concreto, en azul se encuentran marcados los accesos producidos entre el 9 y 11 de septiembre de 2022, en verde los accesos del 16 al 20 de septiembre y en rojo los accesos del día 28:

(...).

En ese periodo, el número de clientes y teléfonos consultados fue el siguiente:

- Número de clientes: 524.691.
- Número de teléfonos fijos distintos: 562.608.

En cuanto a los datos a los que se tuvo acceso, como ya sabe la AEPD, fueron los mismos que en el resto de los periodos mencionados: (...).

La dirección IP desde la que se llevó a cabo el ataque fue la ***IP.1, cuyo país de procedencia era Lituania y el proveedor de servicios de internet era UAB Cherry Server. En concreto, desde dicha IP se realizaron las consultas a ***APP.1 y la obtención de los datos.

Recordemos que, como medida de mitigación, cuando se detectaron las consultas maliciosas (...).

6. Respecto a la solicitud de *evidencias de la existencia, en su caso, de Protocolos de actuación en caso de violación de la seguridad de los datos personales (brecha de datos personales) en el momento de producirse el incidente*, Telefónica indica lo siguiente:

En el momento en el que se produjo el Incidente, Telefónica contaba con “(...)” para la gestión de brechas de seguridad con afectación de datos personales, que se adjunta como Documento anexo 5.

El objetivo de este documento era desarrollar las distintas etapas del proceso de notificación y comunicación ante brechas de seguridad y privacidad que puedan afectar a datos personales tratados por Telefónica España y comunicación del incidente, en su caso, a la AEPD y a los interesados afectados.

DÉCIMO:

Con fecha 22 de julio de 2024 se formuló propuesta de resolución, en la que se dio respuesta a las alegaciones planteadas frente al acuerdo de inicio y se propuso que se sancionara a Telefónica con sanción total de 1.300.000 € por la comisión de dos infracciones, en particular, por infringir lo dispuesto en los artículos 5.1.f) 32 del RGPD.

UNDÉCIMO:

Notificada la propuesta de resolución conforme a las normas establecidas en la LPACAP, la parte reclamada presentó escrito alegaciones en fecha 13 de agosto de 2024.

En sus alegaciones, en síntesis, la parte reclamada manifiesta:

Previa. Sobre la continuación del presente expediente sancionador.

Comienza su escrito insistiendo en que ha cumplido con las previsiones de la normativa que resultan de aplicación en relación con el cumplimiento del principio de confidencialidad, la definición de medidas de seguridad asociadas a los tratamientos de datos de carácter personal, así como en la gestión del incidente en el sistema interno de Telefónica ***APP.1 del que trata este expediente. A continuación, hace hincapié en que ha colaborado en todo momento con la AEPD y considera que ésta no está teniendo en cuenta toda la información y documentación aportada por ella. A este respecto, destaca que los únicos datos que han sido obtenidos por el atacante han sido datos técnicos de algunos equipamientos de conectividad proporcionados por Telefónica e instalados en el domicilio del cliente (router, descodificador de la televisión, amplificador WiFi, etc.). Prosigue analizando dichos datos para concluir que, ni el teléfono fijo permite identificar por sí mismo a una persona física ya que corresponde a un hogar que puede estar compuesto de varias personas, ni tampoco

los datos técnicos y de configuración del equipamiento, aun cuando se asocien a un número de teléfono fijo.

A continuación, afirma que las medidas de seguridad sí que resultaban adecuadas haciendo una breve referencia a los motivos por los que considera que esto es así e indicando que se desarrollaran más extensamente en lo largo del escrito de alegaciones. Sucintamente, alude al doble factor de autenticación para afirmar que contar con dicho sistema no hubiera sido garantía de que el incidente no se hubiera podido producir. Asimismo, afirma que el acceso desde una IP extranjera no se puede bloquear de forma arbitraria y basándose simplemente en la ubicación. A ello añade que cuenta con empleados que pueden necesitar acceder a sus sistemas desde fuera del territorio nacional y que Lituania no está considerado como un país conflictivo en cuanto a la realización de ciberataques.

En relación con las alertas relativas al volumen masivo de consultas argumenta que se trata de una situación que se puede producir en su empresa de manera habitual por la existencia de automatismos y procesos de extracción necesarios por lo que establecer limitaciones de consultar por usuarios podría provocar disfuncionalidades en el ejercicio de sus tareas.

Sobre el ***MEDIDA.2: comienza señalando que gran parte de los datos que se han visto afectados de carácter dinámico para a continuación aludir a las contraseñas de redes WiFi.

Por último, se refiere a las características del incidente para insistir en que consta acreditado que han sido víctimas de un ataque muy dirigido ejecutado por profesionales no siendo el riesgo de que un tercero tuviese conocimiento interno de los sistemas de Telefónica un riesgo probable. Reitera el carácter profesional de los atacantes y el hecho de que se estén llevando a cabo investigaciones policiales.

Primera. Aclaración sobre la descripción de hechos probados realizada por la AEPD.

Telefónica considera que existen una serie de errores en los hechos probados y reitera la alegación primera presentada frente al acuerdo de inicio del presente procedimiento sancionador. Así, afirma que no es cierto que las medidas de contención se produjeran 4 días más tarde, ni que cesaron las peticiones masivas hasta que el empleado cambió sus credenciales ya que el usuario se bloqueó en el mismo momento de la detección y tampoco que se estuvieran detectando consultas masivas muy superiores a las habituales y no se actuara por parte de Telefónica. Respecto a este último punto, matiza que, cuando se detectaron el 20 de septiembre las consultas masivas se bloqueó el usuario ese mismo día aun descubriendo tras hacer la investigación que el día 16 de septiembre también se habían realizado consultas masivas.

Segunda. Del incidente en *APP.1 y las medidas de seguridad: Telefónica contempla medidas técnicas y organizativas que resultan apropiadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito.**

Telefónica niega categóricamente que las causas que originaron el incidente puedan ser atribuidas a una ausencia de previsión o control por su parte. Consecuencia de lo

anterior, considera, es la inexistencia de un incumplimiento de las obligaciones en materia de protección de datos debiendo ser considerada como una víctima de actos ilícitos realizados por terceros. Reitera la explicación dada frente al acuerdo de inicio respecto a *****APP.1** e insiste en que la pérdida de control de la información por el sistema no genera un alto riesgo para los derechos y libertades de los usuarios. En este sentido, insiste en que el número de teléfono fijo es un dato que puede consultarse en las guías telefónicas y que, por lo tanto, la única información afectada sería la relativa a la configuración de los equipos de conectividad de Telefónica. Respecto a estas últimas reitera sus afirmaciones: nombre de la red WiFi (SSID) y clave WIFI no son únicos; se comunicó a los interesados la existencia del Incidente y se les recomendó el cambio de contraseña para incrementar la seguridad de su red y evitar un posible acceso no deseado; Las comunicaciones del usuario a través de la red Wifi, en su configuración por defecto, se encuentra cifradas de extremo a extremo; el acceso a cada red WiFi solo podría realizarse cuando el intruso se encontrase físicamente en la zona de cobertura del domicilio de instalación del router; para que el intruso se pudiera encontrar físicamente en la zona de cobertura del domicilio de instalación del router sería necesario que el tercero contase con la dirección postal a la que corresponden las claves WiFi (dato que no se ha extraído de los sistemas de Telefónica); y en *****APP.1** tampoco consta la contraseña de administración del router.

Todo lo anterior le lleva a considerar la conclusión de la AEPD de que tener acceso a la categoría de datos afectados por el Incidente podría llegarse incluso a “(...)” es desproporcionada.

En definitiva, Telefónica considera que ninguna medida de seguridad es completamente infalible, ni puede exigirse lo anterior, y que Telefónica sí había analizado el sistema afectado por el Incidente y se disponía de un análisis de riesgos que valoraba las medidas aplicadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito. Pone de manifiesto su práctica habitual ante estos tratamientos refiriéndose a la realización de un estudio de impacto para los derechos y libertades de las personas cuyos datos personales se están tratando en el correspondiente análisis de riesgos en privacidad (Pre-DPIA) y en la evaluación de impacto (PIA), en caso de resultar necesario. Asimismo, realiza los correspondientes análisis de riesgos en seguridad. Y, en relación con los datos afectados en este caso, afirma que, pese a que el riesgo residual de acceso no autorizado a credenciales de usuario legítimas era bajo, desde Telefónica ya se tenía un plan (anterior al Incidente) de medidas adicionales, como el despliegue de un Sistema WAF (*Web Application Firewall* según sus siglas en inglés. Herramienta especializada en filtrar, monitorizar y bloquear las conexiones) en *****URL.1** para tener incluso una mayor trazabilidad de acciones en este entorno. Por todo ello, se muestra en desacuerdo con las afirmaciones hechas en la propuesta.

A continuación, se refiere acceso desde una IP extranjera geolocalizada en Lituania para mostrar su desacuerdo con lo expuesto por esta Agencia en la propuesta. Explica que tiene empleados y empresas subcontratadas que pueden necesitar acceder a sus sistemas desde fuera del territorio nacional y que las medidas de bloqueo del acceso de direcciones IP por geolocalización no las considera efectivas puesto que pueden utilizar sistemas de anonimización de sus IPs.

Seguidamente, se refiere a las medidas con las que cuenta Telefónica para cumplir con sus obligaciones y a las que ya hizo referencia en sus alegaciones frente al acuerdo de inicio y que entiende que no han sido tenidas en cuenta. Según su opinión, la AEPD no ha tenido en cuenta si Telefónica ha actuado de forma diligente respecto al riesgo conocido en ese momento, sino que se ha centrado en la ausencia de unas determinadas medidas de seguridad que considera que hubieran sido las ideales.

A lo anterior suma su consideración de que los datos afectados no tenían por qué haber sido cifrados y concluye que sí que contaban con las medidas técnicas y organizativas adecuadas conforme a la normativa de aplicación.

Tercera. Superación de la esfera de responsabilidad de Telefónica: circunstancias excepcionales que han hecho posible la superación por terceras personas de las políticas de seguridad implantadas.

A este respecto, reitera lo ya indicado en sus alegaciones frente al acuerdo de inicio.

Cuarta. Sobre las cuestiones previas que han sido planteadas por la AEPD en el marco de este expediente.

En este apartado de sus alegaciones aduce que el Dictamen del año 2011 recogido por la AEPD en la propuesta no versa sobre una situación análoga a la aquí acontecida pues está relacionado con los servicios de geolocalización en los dispositivos móviles inteligentes, pero en este caso los atacantes no obtuvieron ningún tipo de localización de los clientes y en que nos encontramos ante la MAC de un equipamiento de conectividad que se encuentra situado en un domicilio concreto de un cliente. A ello añade un extracto del escrito de Diligencias Previas emitido por el Juzgado de Instrucción nº 31 de Madrid, relacionado con ese incidente, en el que se acuerda “el sobreseimiento provisional de las actuaciones”, en la medida en que *“los datos de índole privada de los titulares supuestamente afectados, se desconocen cuáles son estos y respecto de qué persona física o jurídica se han producido, siendo que el delito de revelación de secretos se hay sujeto a requisito de perseguibilidad de la denuncia previa”*.

Quinta. Sobre las presuntas infracciones cometidas por parte de Telefónica: vulneración del principio de tipicidad.

Bajo esta rúbrica, Telefónica reproduce la alegación hecha frente al acuerdo de inicio por este mismo motivo. Entiende que los hechos descritos no son subsumibles en los tipos descritos en los artículos 5.1.f y 32 del RGPD y que, por lo tanto, no cabe la tramitación de un procedimiento sancionador. Insiste en que se está asumiendo la existencia de una obligación de resultados y una responsabilidad objetiva.

Asimismo, en relación con la redacción de los preceptos normativos de aplicación, considera que la AEPD está actuando de forma arbitraria al centrarse tan solo en el resultado producido sin tener en cuenta que no puede exigirse la aplicación de unas medidas determinadas ni la infalibilidad de las medidas adoptadas.

Considera que, para poder entender infringidos los preceptos citados, sería necesario que no se aplicasen medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo” y, en general, no se garantizase una “seguridad

adecuada” en el tratamiento de datos personales. Cuestiones estas que entiende que no se producen en su caso porque, afirma, cuenta con unas medidas técnicas y organizativas apropiadas en lo que respecta al tratamiento de datos personales en sus sistemas, y dichas medidas son apropiadas y garantizan un nivel de seguridad que es adecuado al riesgo teniendo en cuenta el estado de la técnica, los costes de aplicación y la naturaleza, el alcance, el contexto, y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas.

Reitera que considera probado que sus medidas se revisan y actualizan cuando resulta necesario y que las causas que han dado lugar al presente incidente no son atribuibles en ningún caso a Telefónica.

Prosigue su escrito reproduciendo nuevamente sus alegaciones en lo referente a la redacción de la normativa de aplicación, insistiendo en que se ha producido una situación de inseguridad jurídica que dificulta su defensa y que implicaría una vulneración de principios constitucionales (artículos 24, 25 y 9.3 de la Constitución Española).

También reitera los argumentos esgrimidos frente al acuerdo de inicio en lo relativo a lo que considera un error en la tipificación y calificación de los hechos así como en la determinación de la sanción. Y ello porque entiende que no es aplicable a este caso lo dispuesto en el artículo 5.1.f) al regular la seguridad de los datos personales de una forma más genérica, mientras que el artículo 32 es más específico. Siguiendo con dicho hilo argumental, entiende que. Al no ser subsumible la actuación en lo dispuesto en el artículo 5.1.f), no podría ser calificada la infracción como muy grave.

Finaliza esta alegación reiterando también las argumentaciones relativas a la reiteración en la voluntad de agravar ambas infracciones con los mismos fundamentos.

Sexta. La conducta de Telefónica no es antijurídica.

Una vez más, Telefónica reitera lo alegado frente al acuerdo de inicio en lo referente a la inexistencia de antijuricidad en su conducta. En este sentido, insiste en que cuenta con medidas técnicas y organizativas diseñadas para garantizar una seguridad adecuada de los datos personales (Certificados, protocolos y manuales que acreditan la gestión de la seguridad, medidas de concienciación de empleados, de protección de los dispositivos, etc) y con múltiples mecanismos para detectar el acceso ilegítimo a datos personales,

Séptima. Ausencia de culpabilidad.

En su siguiente alegación reitera nuevamente los argumentos ya planteados sobre la inexistencia de culpa en su conducta. Insiste en que ha actuado de buena fe con toda la diligencia profesional exigible, de buena fe y que las circunstancias que han dado lugar a los hechos objeto del presente expediente son imputables a terceros que actuaron en la comisión de un delito.

Octava. Incumplimiento del principio de proporcionalidad.

A continuación, Telefónica reproduce nuevamente de manera prácticamente literal las argumentaciones sostenidas respecto a lo que considera una vulneración del principio

de proporcionalidad en la determinación de las sanciones, singularizando cada una de las circunstancias agravantes concurrentes en cada una de las dos infracciones, así como las circunstancias atenuantes que, a su juicio, deberían haber sido tenidas en cuenta.

Telefónica finaliza su escrito de alegaciones que se declare la inexistencia de responsabilidad por parte de Telefónica por las presuntas infracciones que se le imputan en este procedimiento, al no existir conducta antijurídica, ni típica, ni culpable de Telefónica en los hechos imputados, ordenando el archivo del presente expediente sancionador.

Subsidiariamente, y en caso de entender que las medidas técnicas y de seguridad no son adecuadas, debería atenderse a lo indicado en el escrito de alegaciones de tal forma que, en caso de considerarse la existencia de infracción, en ningún caso podría calificarse la conducta de Telefónica como muy grave, por ser contraria al artículo 5.1 f) del RGPD.

Subsidiariamente, en caso de que no se estimase la primera pretensión, que se minore la sanción inicialmente propuesta en virtud de los criterios del art. 83 del RGPD y del 76.2 de la LOPDGDD.

A la vista de todo lo actuado, por parte de la Agencia Española de Protección de Datos en el presente procedimiento se consideran hechos probados los siguientes,

HECHOS PROBADOS

PRIMERO: Primera notificación de brecha de datos personales

Con fecha 26 de septiembre de 2022, Telefónica notifica a la AEPD una brecha de datos personales en la que informa de lo siguiente (Número de registro: REGAGE22e00042226564):

“(…)”

Se indica que el número de personas físicas cuyos datos personales han resultado afectados es de 1.021.253, clientes de esta sociedad.

Indica como fecha de inicio de la brecha el 16 de septiembre de 2022.

Indica como fecha de resolución de la brecha el 20 de septiembre de 2022.

Indica como fecha de detección de la brecha, entendida como la fecha en la que el responsable tiene la certeza de que se han visto afectados datos personales: 23 de septiembre de 2022.

Se indica que los datos personales no están cifrados.

SEGUNDO: Segunda notificación de brecha de datos personales

Con fecha 26 de octubre de 2022 Telefónica presenta una nueva notificación completando la notificación inicial sobre la brecha de datos personales, indicando la siguiente información (Número de registro: REGAGE22e00048156613):

- “(...)”
- Se afirma que la fecha de inicio de la brecha es el 09 de septiembre de 2022.
- Se afirma que el incidente se detecta el 20 de septiembre por la advertencia de un miembro de la organización.
- Se afirma que la brecha se da por resuelta el 20 de septiembre de 2022.
- Se afirma que se detecta el 23 de septiembre de 2022 que la brecha ha afectado a datos personales.
- Se indica que, en total, se han visto afectados los datos personales de un total de 1.407.257 personas, todas ellas residentes en España.
- Se afirma que se podría haber evitado la brecha adoptando medidas adicionales, pero que no se produce por deficiencia de medidas actuales.
- Se afirma que las nuevas medidas reactivas implantadas han sido **“***MEDIDA.1” y “***MEDIDA.2”**.
- Se afirma que se dispone de Análisis de Riesgos y Registro de Incidentes.
- Se afirma que se ha puesto el incidente en conocimiento de las autoridades policiales.
- Se afirma que se comunicará a las personas afectadas a más tardar el 28 de octubre de 2022.
- No existe encargado de tratamiento afectado por la brecha.

Junto a la notificación se aporta la siguiente documentación:

*“Informe incidente de privacidad acceso no autorizado a *****APP.1**”, con la siguiente información relevante:*

- Los accesos ilícitos fueron detectados en una de las aplicaciones internas del portal del empleado de Telefónica denominado *****PORTAL.1 (***URL.1), ***APP.1**. El acceso a este portal era público desde internet y utilizaba método de autenticación basado en credenciales que cada empleado posee (usuario y contraseña).
- Se aporta captura de pantalla de un correo electrónico interno enviado el 23 de septiembre de 2022 a las 22:17 por parte del equipo de seguridad (CSIRT) con el siguiente contenido: “(...)”.

TERCERO: Obran en el expediente los siguientes correos electrónicos:

Correo 1: Obra la siguiente captura de pantalla de un correo electrónico enviado el miércoles 20 de septiembre de 2022 y que ha aportado Telefónica en su *“Informe incidente de privacidad acceso no autorizado a *****APP.1**”* aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales (Número de registro: REGAGE22e00048156613):

(...)

Correo 2: Captura de pantalla de correo electrónico, enviado el 21 de septiembre de 2022 dirigido por el empleado cuyo usuario ha sido utilizado para realizar el ciberataque y enviado al equipo de seguridad de Telefónica, aportado por la entidad como “Documento Anexo 3” en escrito de respuesta presentado el 28/11/2022 (Número de registro: REGAGE22e00054164415):

“(…)”

Este correo ha sido por aportado por Telefónica al requerírsele que acreditasen el correo electrónico que el usuario afectado envió al equipo de seguridad de Telefónica (CSIRT-TE) notificando la incidencia

Correo 3: A solicitud del Inspector actuante para acreditar la comunicación del incidente que desde el equipo de seguridad (CSIRT-TE) se dirigió al DPD, aportan captura de pantalla del correo electrónico enviado el 23 de septiembre y remitido por la entidad como “Documento Anexo 2” en escrito de respuesta presentado el 28/11/2022 (Número de registro: REGAGE22e00054164415) con el siguiente contenido:

(…)

CUARTO: Cronología y descripción del ataque:

Según información facilitada por Telefónica, la cronología del ataque es la siguiente:

1.- Fecha de inicio del ataque: 9 de septiembre de 2022

En su “*Informe incidente de privacidad acceso no autorizado a ***APP.1*” aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales (Número de registro: REGAGE22e00048156613), Telefónica manifiesta que “...una vez concluido el análisis completo del incidente, se extrae que, los accesos maliciosos se realizaron en tres bloques de días, del 9 a 11 de septiembre, del 16 al 20 de septiembre y el día 28 de septiembre”

En su escrito de respuesta, mediante escrito presentado el 28/06/2024 (Número de registro: REGAGE24e00048325431) a la solicitud de información realizada durante el período de práctica de pruebas abierto por la Instructora del presente procedimiento sancionador, en relación con la solicitud de *información de los accesos maliciosos que se produjeron entre el 9 y el 11 de septiembre, (usuario afectado y su rol, accesos que se produjeron, datos personales afectados, por qué no se detectó entonces, etc)*, Telefónica responde lo siguiente:

Para el periodo solicitado por la AEPD, del 9/9/2022 al 11/9/2022, el usuario utilizado fue *****USUARIO.1**.

En ese periodo, el número de clientes y teléfonos consultados fue el siguiente:

- Número de clientes: 524.691.
- Número de teléfonos fijos distintos: 562.608.

En cuanto a los datos a los que se tuvo acceso, fueron los mismos que en el resto de los periodos mencionados

2. Período del 16 al 20 de septiembre de 2022:

En la notificación de brecha realizada por Telefónica a la AEPD, el 26 de septiembre de 2022, (Número de registro: REGAGE22e00042226564), informa de lo siguiente:

“(…).”

3. 28 de septiembre de 2002.

En el “Informe incidente de privacidad acceso no autorizado a *****APP.1**” aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales (Número de registro: REGAGE22e00048156613), Telefónica manifiesta que:

“(…).”

QUINTO: Actividades de tratamiento afectadas por el incidente y sobre la aplicación *****APP.1**

Según indica Telefónica, en el informe “Informe incidente de privacidad acceso no autorizado a *****APP.1**” aportado el 26/10/2022 aportado junto con la segunda notificación de brecha de datos personales (Número de registro: REGAGE22e00048156613), las actividades de tratamiento afectadas por la brecha son las siguientes:

Código de tratamiento	Área solicitante	Operación del tratamiento	Descripción
OP_001	OPERACIONES	Atención técnica remota en primera línea (Telefónica, COL...) averías de cliente.	Atención técnica en primer nivel. Atención técnica remota en prima línea (Telefónica, COL...) averías de cliente. Recogida, Extracción, Registro, Modificación, Consulta, Comunicación, Todas estas actividades vinculadas a la prestación del servicio de atención y asistencia técnica al cliente en lo que a servicios Movistar refiere.
OP_002	OPERACIONES	Centros técnicos de atención al cliente.	Atención técnica especializada y remota de averías de cliente en un Segundo nivel de atención.

Respecto al aplicativo *****APP.1**:

En el “Informe incidente de privacidad acceso no autorizado a *****APP.1**”, aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales a la AEPD (Número de registro: REGAGE22e00048156613), así como en el escrito de respuesta, mediante escrito presentado el 28/06/2024 (Número de registro: REGAGE24e00048325431) a la solicitud de información realizada durante el período

de práctica de pruebas abierto por la Instructora del presente procedimiento sancionador, se indica:

- *****APP.1** es un aplicativo que “(...) ... Toda esta información se utiliza para fines de soporte y mantenimiento al cliente por parte de los equipos técnicos de Telefónica.”
- (...)
- El acceso a *****APP.1** se realiza a través de un acceso lógico mediante usuario y contraseña.

SEXTO: Causas que hicieron posible la brecha

En el “Informe incidente de privacidad acceso no autorizado a *****APP.1**”, aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales a la AEPD (Número de registro: REGAGE22e00048156613) se indica:

- “Los accesos maliciosos se realizaron en tres bloques de días, del 9 a 11 de septiembre, del 16 al 20 de septiembre y el día 28 de septiembre, (...).”
- “(...)”

En el escrito de respuesta, mediante escrito presentado el 28/06/2024 (Número de registro: REGAGE24e00048325431) a la solicitud de información sobre el país de procedencia de las direcciones IPs desde las que se llevó a cabo el ataque, realizada durante el período de práctica de pruebas abierto por la Instructora del presente procedimiento sancionador, Telefónica indica:

- “(...)”

SÉPTIMO: medidas de seguridad previas al incidente

En el “Informe incidente de privacidad acceso no autorizado a *****APP.1**”, aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales a la AEPD (Número de registro: REGAGE22e00048156613) se indica como medidas previas a la brecha de datos personales:

- (...).

OCTAVO: medidas reactivas de mitigación aplicadas

En el “Informe incidente de privacidad acceso no autorizado a *****APP.1**”, aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales a la AEPD (Número de registro: REGAGE22e00048156613) se indica:

- “(...)”.

Este bloqueo se produjo el 28/09/2022, fecha del último ataque.

- (...)

Este bloqueo se produjo el 20/09/2022.

- (...)

NOVENO: Medidas posteriores al incidente de seguridad

En el “Informe incidente de privacidad acceso no autorizado a *****APP.1**”, aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales a la AEPD (Número de registro: REGAGE22e00048156613) se indica como medidas de seguridad implantadas tras el incidente:

- (...)

Indica, asimismo, Telefónica en el citado informe las principales medidas de seguimiento en las que estaba trabajando en el momento de aportación de dicho informe:

- (...)

DÉCIMO: Análisis de riesgos de la aplicación afectada por la brecha de datos personales:

De la copia del “Informe de Análisis de Riesgos del Sistema *****APP.1**”, de fecha de 24 de noviembre de 2021, en el que se indica “AA.RR. realizado en el siguiente período de tiempo: julio-octubre 2021”, aportado por Telefónica en fecha 28 de noviembre de 2022 (número de registro de entrada REGAGE22e00054164415) junto con su escrito de respuesta ante requerimiento de información por el Inspector actuante en las investigaciones previas, se extrae la siguiente información:

Se analiza la siguiente relación de amenazas y se concluye un nivel de riesgo residual asignándole a cada una de ellas un nivel de probabilidad de impacto:

(...)

En su escrito de respuesta, mediante escrito presentado el 28/06/2024 (Número de registro: REGAGE24e00048325431) a la solicitud de información realizada durante el período de práctica de pruebas abierto por la Instructora del presente procedimiento sancionador, se indica lo siguiente:

- “(...)”.

DÉCIMOPRIMERO: Metodología del análisis de riesgos

La metodología de análisis de riesgos de seguridad de la entidad aportado al procedimiento (...).

En dicho estándar internacional, se define un catálogo de amenazas y en cada una de ellas se detalla la probabilidad de materialización y el nivel de degradación (potencial

daño que una amenaza puede causar a un activo determinado) en cada dimensión de seguridad. Además, ese estándar también cuenta con un catálogo de controles en cada dimensión de seguridad, el nivel de mitigación de la probabilidad y/o degradación para cada amenaza y el tipo de activo en el que aplica el objetivo de control.

En concreto, la metodología de análisis de riesgos de seguridad de Telefónica se basa en los siguientes pasos:

- (i) Identificación de activos, modelado y análisis de impacto al negocio. En lo que respecta a la valoración del impacto de una amenaza en un activo determinado, Telefónica aduce (...).

DÉCIMO SEGUNDO: Ausencia de análisis de riesgos para los derechos y libertades de las personas y de evaluación de Impacto en protección de datos.

En relación con la solicitud de aportar los análisis de riesgos o, en su caso, la Evaluación de Impacto en Protección de Datos, respecto de las actividades de tratamiento afectadas por la brecha de datos personales de conformidad con el RGPD y realizada con anterioridad a la fecha de dicha brecha, Telefónica indica lo siguiente, en su escrito de respuesta, de 28/06/2024:

*“El tratamiento de datos que tiene lugar al acceder a *****APP.1** no cuenta con una evaluación de impacto en protección de datos independiente, al no suponer un alto riesgo para los derechos y libertades de las personas físicas.*

DÉCIMO TERCERO: Ausencia de doble factor de autenticación

En el citado escrito de respuesta, ante la solicitud de información sobre *Si existía, a la fecha del incidente, implantado un sistema de doble factor de verificación para el acceso a las aplicaciones afectadas. En caso afirmativo, evidencias de ello*, Telefónica responde lo siguiente:

- (...)

DÉCIMO CUARTO: Número de personas afectadas y tipo de datos afectados

1.407.257 personas físicas, clientes de Telefónica, todas ellas residentes en España

Tipo de datos afectados:

En el “Informe incidente de privacidad acceso no autorizado a *****APP.1**”, se indica que la información afectada fue la siguiente:

- Teléfono fijo,
- Asociado al mismo: datos técnicos y de configuración (...).

DECIMO QUINTO: Comunicación a los afectados

En el escrito de respuesta al requerimiento de información realizado por esta AEPD, durante las actuaciones previas de investigación, presentado en fecha 28 de noviembre de 2022 (número de registro de entrada REGAGE22e00054164415), Telefónica manifiesta que ha comunicado a los afectados la brecha de datos personales, indicando lo siguiente:

- El medio utilizado mayoritariamente ha sido el correo electrónico y en algunos otros el correo postal cuando no se dispone del dato email.
- Se han enviado 89244 cartas postales y se acredita este hecho aportando certificado de Correos con fecha de registro el día 31 de octubre de 2022.
- Se han enviado 1.313.395 correos electrónicos, aportando detalles de las fechas en las que se han realizado los envíos, que están comprendidas entre el 27 de octubre de 2022 y el 2 de noviembre de 2022.
- Ha sido necesario realizar la comunicación en fases y en las fechas anteriormente indicadas para así disponer y garantizar una atención adecuada ante las posibles llamadas de petición de información por parte de los clientes. Afirman que otro de los motivos para llevar a cabo la comunicación por fases fue el poder atender correctamente a los clientes afectados y evitar la caída de los diferentes medios de gestión habilitados para el cambio de contraseña que se sugería en el contenido de la comunicación (por una posible excesiva demanda).
- Los usuarios afectados eran clientes tanto de Telefónica Movistar como de Telefónica O2.

FUNDAMENTOS DE DERECHO

I Competencia

De acuerdo con los poderes que el artículo 58.2 del RGPD, otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la LOPDGDD, es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *"Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."*

II Cuestiones previas

Telefónica es una gran empresa, operador de telecomunicaciones, y su desarrollo empresarial requiere de un tratamiento continuo y de volumen muy elevado de datos personales.

De acuerdo con lo establecido en el artículo 4.1 del RGPD, consta la realización de un tratamiento de datos personales, toda vez que Telefónica realiza, entre otros tratamientos, la recogida, conservación, consulta, utilización, supresión, etc., de datos personales de personas físicas, tales como: nombre, apellidos, DNI, dirección postal, número de teléfono, dirección de correo electrónico, datos bancarios, etc.

En el caso que nos ocupa, la brecha de seguridad sufrida ha afectado a datos personales tratados por Telefónica en su condición de responsable del tratamiento, al determinar los fines y medios respecto de esos tratamientos, en virtud del artículo 4.7 del RGPD.

El artículo 4 apartado 12 del RGPD define, de un modo amplio, las “violaciones de seguridad de los datos personales” (en adelante brecha de seguridad) como “todas aquellas violaciones de la seguridad que ocasionen la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.”

En el presente caso, consta una brecha de seguridad de datos personales en las circunstancias arriba indicadas, categorizada como una brecha de confidencialidad, al haberse producido un acceso indebido por un tercero no autorizado a datos personales tratados por Telefónica.

III Sobre la naturaleza de los datos afectados por la quiebra

El artículo 4 del RGPD define en su apartado 1) «datos personales» como *toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona.*

De ello se desprende que el concepto de dato personal requiere la concurrencia de un doble elemento: por una parte, la existencia de una información o dato y, por otra, que dicho dato pueda vincularse a una persona física identificada o identificable.

Sobre el concepto de persona identificable se pronuncia también el considerando 26 del RGPD que expone lo siguiente:

(26) Los principios de la protección de datos deben aplicarse a toda la información relativa a una persona física identificada o identificable. Los datos personales seudonimizados, que cabría atribuir a una persona física mediante la utilización de información adicional, deben considerarse información sobre una persona física identificable. Para determinar si una persona física es identificable, deben tenerse en cuenta todos los medios, como la singularización, que razonablemente pueda utilizar el responsable del tratamiento o cualquier otra persona para identificar directa o indirectamente a la persona física. Para determinar si existe una probabilidad razonable de que se utilicen medios para identificar a una persona física, deben tenerse en cuenta todos los factores objetivos, como los costes y el tiempo necesarios

para la identificación, teniendo en cuenta tanto la tecnología disponible en el momento del tratamiento como los avances tecnológicos. Por lo tanto, los principios de protección de datos no deben aplicarse a la información anónima, es decir información que no guarda relación con una persona física identificada o identificable, ni a los datos convertidos en anónimos de forma que el interesado no sea identificable, o deje de serlo. En consecuencia, el presente Reglamento no afecta al tratamiento de dicha información anónima, inclusive con fines estadísticos o de investigación.

Así pues, este concepto de dato personal no puede ser más amplio. La Audiencia Nacional en su sentencia de 08/03/2002, ha señalado que para que exista dato de carácter personal (en contraposición con dato disociado) no es imprescindible una plena coincidencia entre el dato y una persona concreta, sino que es suficiente con que tal identificación pueda efectuarse sin esfuerzos desproporcionados.

Con la dicción actual del RGPD se infiere de forma automática que el número de teléfono fijo es un dato de carácter personal respecto del titular de la línea -es un identificador-, que se basta y se sobra para hacerle identificable.

El Dictamen 4/2007 sobre el concepto de datos personales del Grupo de Trabajo del Artículo 29, adoptado el 20 de junio de 2007, determina respecto de lo que es identificable que *“la persona física es «identificable» cuando, aunque no se la haya identificado todavía, sea posible hacerlo (que es el significado del sufijo «ble»).* (...) *La identificación se logra normalmente a través de datos concretos que podemos llamar «identificadores» y que tienen una relación privilegiada y muy cercana con una determinada persona...”*.

En este sentido, en el supuesto del número de teléfono fijo debe recordarse la existencia de las guías de abonados, previstas en el art. 72 de la Ley 11/2002, de 28 de junio, General de Telecomunicaciones (a partir de ahora, LGTel), y desarrolladas mediante el Real Decreto 424/2005 de 15 abril, por el que se aprueba el Reglamento sobre condiciones para prestación de servicios de comunicaciones electrónicas, servicio universal y protección de usuarios (vigente en lo que no se oponga a la LGTel de conformidad con lo previsto en la disposición derogatoria única, apartado c).

Así el artículo 30.4 del citado RD 424/2005 indica que “Sin perjuicio de lo dispuesto en el artículo 67, en relación con los datos relativos a cada abonado, deberá figurar, al menos, la siguiente información: a) Nombre y apellidos o razón social. B) Número o números de abonado. C) Dirección postal del domicilio, excepto piso, letra y escalera. D) Terminal específico que deseen declarar, en su caso. ...”

Y continúa señalando en su apartado 6 que “...Los datos estarán relacionados por orden alfabético del primer apellido o razón social. Después del primer apellido se reflejará completo el segundo, seguido tras una coma, del nombre propio o de sus iniciales. Asociado a cada número figurará, además, la dirección del abonado, sin especificación de piso o letra, y, en su caso, un identificador del tipo de terminal (teléfono normal, fax, RDSI, videoconferencia, telefonía móvil, telefonía de texto para personas sordas, entre otros) que el abonado haya manifestado su deseo de que figure de forma tal que permita tener constancia del contenido de la solicitud y la identidad del solicitante”.

De todo ello se infiere que, el número de teléfono fijo sí se encuentra asociado a otros datos identificativos de una persona física.

Sobre este particular y a título meramente ilustrativo procede recordar el Dictamen 5/2000 sobre el uso de las guías telefónicas públicas para servicios de búsqueda inversa o multicriterio (Guías inversas) del Grupo de Trabajo del Artículo 29, adoptado el 13 de abril de 2000, que planteaba la facilidad para obtener otros datos personales a partir del número de teléfono del titular de la línea.

De esta forma, además, la identificación no tiene por qué ser directa ni completa, bastando una identificación indirecta que de cualquier manera haga identificable a una persona.

Y, por último, resulta que para que una persona sea identificable no es necesario que toda la información que permita identificar al interesado deba encontrarse en poder de una sola persona.

En el caso de un número de teléfono fijo y de que un tercero ajeno al responsable del tratamiento se haga con ellos, se considerará dato de carácter personal puesto que resulta posible la singularización de la persona, aunque la información no se refiera a una persona identificada- sí permite identificar al titular de la línea, en el sentido expuesto en el considerando 26 del RGPD:

(26) Los principios de la protección de datos deben aplicarse a toda la información relativa a una persona física identificada o identificable. Los datos personales seudonimizados, que cabría atribuir a una persona física mediante la utilización de información adicional, deben considerarse información sobre una persona física identificable. Para determinar si una persona física es identificable, deben tenerse en cuenta todos los medios, como la singularización, que razonablemente pueda utilizar el responsable del tratamiento o cualquier otra persona para identificar directa o indirectamente a la persona física. Para determinar si existe una probabilidad razonable de que se utilicen medios para identificar a una persona física, deben tenerse en cuenta todos los factores objetivos, como los costes y el tiempo necesarios para la identificación, teniendo en cuenta tanto la tecnología disponible en el momento del tratamiento como los avances tecnológicos. Por lo tanto los principios de protección de datos no deben aplicarse a la información anónima, es decir información que no guarda relación con una persona física identificada o identificable, ni a los datos convertidos en anónimos de forma que el interesado no sea identificable, o deje de serlo. En consecuencia, el presente Reglamento no afecta al tratamiento de dicha información anónima, inclusive con fines estadísticos o de investigación

Por tanto, por el mero hecho de existir la posibilidad de identificación de una persona física a partir de un identificador, esa información debe considerarse datos de carácter personal, independientemente de que se llegue a materializar dicha posibilidad. En el presente caso concreto, en cualquier caso, y sin perjuicio de que puedan existir otras formas, existen guía de abonados, como se ha señalado, que permiten sin dificultad la

identificación, incluso fuera del ámbito del responsable del tratamiento, constituyendo un dato de carácter personal.

Por otro lado, los datos personales a los que ha accedido el tercero en este caso concreto tiene también la consideración de datos de carácter personal.

El Grupo de Trabajo del Artículo 29 en su Dictamen 4/2007, sobre el concepto de dato personal, adoptado el 20 de junio, se refirió a esta cuestión en los siguientes términos:

“Por su parte, cuando hablamos de «indirectamente» identificadas o identificables, nos estamos refiriendo en general al fenómeno de las «combinaciones únicas», sean estas pequeñas o grandes. En los casos en que, a primera vista, los identificadores disponibles no permiten singularizar a una persona determinada, ésta aún puede ser «identificable», porque esa información combinada con otros datos (tanto si el responsable de su tratamiento tiene conocimiento de ellos como si no) permitirá distinguir a esa persona de otras...”

Conviene señalar que, si bien la identificación a través del nombre y apellidos es en la práctica lo más habitual, esa información puede no ser necesaria en todos los casos para identificar a una persona. Así puede suceder cuando se utilizan otros «identificadores» para singularizar a alguien.

Efectivamente, los ficheros informatizados de datos personales suelen asignar un identificador único a las personas registradas para evitar toda confusión entre dos personas incluidas en el fichero. También en Internet, las herramientas de control de tráfico permiten identificar con facilidad el comportamiento de una máquina y, por tanto, la del usuario que se encuentra detrás. En otras palabras, la posibilidad de identificar a una persona ya no equivale necesariamente a la capacidad de poder llegar a conocer su nombre y apellidos. La definición de datos personales refleja este hecho”.

Por tanto, hoy en día está extensamente superado que la posibilidad de identificar a una persona equivalga necesariamente a la capacidad de poder llegar a conocer su nombre y apellidos.

Y al referirse a los “medios de identificación”, el mismo Dictamen señala: “Por otra parte, se trata de una prueba dinámica, por lo que debe tenerse en cuenta el grado de avance tecnológico en el momento del tratamiento y su posible desarrollo en el período durante el cual se tratarán los datos...”.

La parte recurrente ha declarado que los atacantes accedieron además a información relativa a:

- MAC y detalles del fabricante del dispositivo;
- Configuración de los puertos de la conexión asociada al teléfono fijo;
- Nombres de la red wifi y su contraseña.

Por tanto, atendiendo a la definición contenida en las normas citadas, que consideran dato de carácter personal “cualquier información concerniente a personas físicas identificadas o identificables”, la información recabada en este caso se ajusta a dicho

concepto, al tratarse de información concerniente a personas físicas identificadas o identificables, ya que con los datos afectados por la quiebra es posible la identificación de los titulares de los mismos sin un esfuerzo exagerado o desproporcionado.

IV Alegaciones al acuerdo de inicio

En respuesta a las alegaciones presentadas por Telefónica frente al acuerdo de inicio, se indicó lo siguiente:

Primero. - Consideraciones previas y aclaración sobre la descripción de los hechos realizada por la AEPD en el Acuerdo de Inicio

En este apartado, Telefónica realiza las siguientes consideraciones:

Alega Telefónica que no es cierto, como se señala en el Acuerdo de Inicio, que el día 16 de septiembre de 2022 se detectara el ataque y que no fue hasta cuatro días más tarde, el 20 de septiembre, cuando se procede a bloquear al usuario comprometido, sino que realmente fue ese día 20 cuando se detectó por el equipo de ... (aplicación que gestiona las peticiones a sistemas) un número de peticiones más elevada de lo habitual a *****APP.1** y, tras las comprobaciones pertinentes se procedió a bloquearlo y a restablecer sus credenciales. Indica como prueba de ello el Correo 1 enviado por una persona del equipo de ... el 20/09/2022.

Asimismo, indica Telefónica que, si bien en la primera notificación se indicó como fecha de detección del incidente el 16 de septiembre de 2022, realmente se quería decir que era la fecha de inicio del ataque y que, una vez concluido el informe final, se corrigió este aspecto al confirmarse que realmente la fecha de detección fue el día 20 de septiembre de 2022.

También señala Telefónica que el equipo de respuesta ante incidentes de la entidad, el CSIRT-TE, fue informado sin dilación indebida y cuando ya se habían adoptado determinadas medidas por parte de ... y no 5 días después, como se indica en el Acuerdo de Inicio.

Por tanto, indica Telefónica que no es cierto que las medidas de contención se produjeran 4 días más tarde, ya que el mismo día en que se detectaron, 20 de septiembre, fue bloqueado el usuario desde el cual se habían producido las consultas.

Frente a ello, procede señalar que de los correos electrónicos enviados en relación con el incidente se desprende lo contrario.

Así, en el llamado Correo 1 en el Hecho Probado Tercero, enviado el 20/09/2022 indica que "(...)"

Por tanto, lo que refleja el citado correo es que una persona del equipo de ... lo que está diciendo el 20/09/2022 es que desde el 16/09/2022 el volumen de peticiones ha crecido de manera preocupante. Además, el correo no está dirigido al CSIRT-TE.

Por su parte, en el llamado Correo 2 en el Hecho Probado Tres, que el empleado cuyo usuario ha sido utilizado para realizar el ataque envía el día 21/09/2022 al CSIRT-TE, se indica lo siguiente:

“(…)”

Hay que tener en cuenta que la fecha de su envío, el 21/09/2020, era miércoles por lo que el viernes anterior a que se refiere era precisamente el día 16/09/2022.

Por último, en el llamado Correo 3 en el Hecho Probado Tercero, dirigido el 23/09/2022 y aportado por Telefónica precisamente para acreditar la comunicación del incidente por parte del CSIRT-TE a la Delegada de Protección de Datos, se indica que:

“(…)”

De lo expuesto, ha quedado acreditado lo que se indicó en el Acuerdo de Inicio, es decir, que:

- El 16 de septiembre de 2022, por parte del equipo responsable de APIS (...) se detecta un consumo anómalo provocado por peticiones masivas procedentes de la aplicación *****APP.1. (...)**.

- El día 20 de septiembre de 2022, se procede a bloquear el usuario del que proceden esas solicitudes tras verificarse, al volver dicho usuario de vacaciones, que no era este quien realizaba de forma legítima las peticiones.

- El día 21 de septiembre de 2022, dicho usuario traslada el incidente al equipo de seguridad de Telefónica (CSIRT).

- Durante los días 21,22 y 23 de septiembre de 2022 se analiza el incidente por parte del equipo de seguridad (CSIRT)

- El día 23 de septiembre de 2022 indican que es cuando se tiene constancia de la filtración de datos tras las peticiones lanzadas por los atacantes y se califica el incidente como brecha de seguridad. Este mismo día se informa de lo sucedido al DPD de Telefónica a través de correo electrónico.

Por tanto, se estaban realizando consultas masivas a través de un único usuario muy superiores a lo habitual a una aplicación de Telefónica desde la que se accede a través de un portal publicado en Internet, no procediéndose a realizar las primeras medidas de contención (bloqueo del usuario) hasta 4 días más tarde, cuando dicho usuario vuelve de vacaciones e indica que, por ello, no ha sido él. Y es este mismo usuario el que, al día siguiente, informa del incidente al CSIRT-TE, momento en el que el mismo tiene constancia por primera vez del incidente de seguridad sufrido (5 días más tarde)

No obstante, y a mayor abundamiento de lo anterior, se significa que, incluso en el supuesto de que la fecha de detección hubiera sido el 20/09/2022, ello es, asimismo, demostrativo de lo mismo: que no existía medidas preventivas adecuadas ni se generó ninguna alerta o evento de seguridad, con advertencia inmediata al CSIRT-TE de que se estaban produciendo durante 4 días unas solicitudes masivas muy superiores a las habituales (de 55.000 al día a 4 millones diarias) y además desde un único usuario, lo cual es reflejo de una clara conducta anómala y sospechosa de ser maliciosa. Asimismo, tampoco se detectó el ataque sufrido entre los días 9 al 11 de septiembre de 2022 y que afectaron a datos personales de más de medio millón de personas

clientes de Telefónica, ataque que posteriormente pudo comprobar la entidad con ocasión del análisis pormenorizado del ataque llevado a cabo entre los días 16 al 20 de septiembre. A este respecto, resaltar que en la fase de pruebas no ha respondido Telefónica por qué no se detectó en su momento el ataque sufrido entre el 9-11 septiembre. Es decir, no se detectaron numerosos accesos que se realizaron y fueron desde un único usuario (*****USUARIO.1**), que resulta ser el mismo que en el ataque producido entre los días 16 al 20 sept 2022.

Ello pone de manifiesto la ausencia de medidas preventivas adecuadas y de sistemas de alerta adecuados, tal y como se indicará más adelante, al argumentarse la falta de medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo.

Por otro lado, señala Telefónica que no es cierto lo indicado en el Acuerdo de Inicio en relación a que *“...quedando constatados que en cada petición automática lanzada por los atacantes se incluía un número de teléfono aleatorio y en caso de que este número coincidía con algún cliente de Telefónica se obtenía como resultado de la consulta los siguientes datos...”*, sino que el atacante automatizó las consultas al sistema con una serie de peticiones en las que introducía numeraciones de teléfonos fijos de clientes que también conocía con carácter previo. Asimismo, indica Telefónica que el ataque fue muy sofisticado pues el atacante conocía las numeraciones personales de los empleados a los que remitió los SMS, así como otras cuestiones del ataque referidas a que introdujo unas rutas concretas de URL y que sólo le permitieron acceder a determinada información almacenada en *****APP.1** y no a toda, etc.

A este respecto, procede señalar que es Telefónica quien indica, en su *“Informe incidente de privacidad acceso no autorizado a *****APP.1**”* aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales, que *“Los accesos maliciosos se realizaron en tres bloques de días, del 9 a 11 de septiembre, del 16 al 20 de septiembre y el día 28 de septiembre, (...).*

Asimismo, dado que el ataque realizado usando números de teléfono fijo consecutivos (o aleatorios) supuso más de 16 millones de solicitudes, de las que consiguió el acceso a los datos personales de 1.407.257 de clientes cuando el número de teléfono fijo coincidía con el de un cliente de Telefónica, no hace sino poner de manifiesto que no conocía previamente esas numeraciones de teléfonos fijos. No obstante, y a mayor abundamiento, a la vista de lo que sucedió, no resulta relevante si conocía previamente o no los teléfonos fijos de los clientes de Telefónica, ni tampoco en cómo se produjo el ataque concreto en cuanto a la forma de realizar las consultas y a los datos a los que no pudo acceder el atacante, o si, como afirma Telefónica, fue muy sofisticado y con conocimientos previos de datos de los empleados, etc., sino que lo relevante es que con las credenciales de un único empleado de Telefónica (usuario y contraseña) realizó consultas masivas a la aplicación afectada, consiguiendo finalmente datos personales de más de 1.400.000 clientes, pudiendo haberse evitado el mismo con la existencia de un doble factor de verificación para los usuarios empleados de Telefónica, de cualquier otra medida que actuara ante peticiones masivas de información, cuando menos, haberse mitigado muy considerablemente el impacto del mismo si hubiesen existido medidas de control y monitorización que hubiesen detectado y alertado del ataque de forma temprana, tal y como se indicará de forma más pormenorizada más adelante.

En cuanto a que ha habido otras entidades que han sufrido ataques similares, se significa que, además de poner de manifiesto que este tipo de ataques están a la orden del día y por tanto previsibles en gran medida, cada ataque es diferente pues, incluso aunque el ataque fuese similar, en cada uno las empresas que lo sufren son distintas, con tratamientos de datos personales diferentes y particulares y en cada caso hay que analizar las medidas existentes (si existían, si eran adecuadas para garantizar un nivel de seguridad apropiado al riesgo concreto en cada caso, si fueron eficientes, si se observaron, etc).

Segundo. - Del incidente en *****APP.1** y las medidas de seguridad. Telefónica considera que contempla medidas técnicas y organizativas que resultan apropiadas para garantizar una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito.

En el presente apartado, Telefónica realiza una serie de alegaciones tendentes a indicar fundamentalmente que el ataque fue muy sofisticado, que el delincuente conocía el funcionamiento de la aplicación *****APP.1**, que consiguieron las credenciales de los empleados mediante un *smishing* muy sofisticado y, sobre todo, que ha quedado sobradamente demostrado que las medidas de seguridad de Telefónica son apropiadas y resultan razonables para garantizar una seguridad adecuada. Para ello, señala la metodología de análisis de los riesgos que utiliza, que cuenta con certificados que acreditan la gestión de la seguridad, con medidas de concienciación a empleados (fundamentalmente *antiphishing*), y procede a señalar las medidas de seguridad con que cuenta, para lo cual nos remitimos al Antecedente Noveno, donde se ha transcrito de forma más amplia todo lo alegado por Telefónica.

Frente a ello, se significa que, en contra de lo señalado por Telefónica, del análisis del ataque y de toda la documentación generada y aportada en la fase de investigaciones previas, así como en la fase de prueba practicada en el presente procedimiento sancionador, que obra en el expediente y al cual nos remitimos, se concluye lo contrario, pues se ha evidenciado la ausencia de las siguientes medidas que hubieran evitado el ataque, o al menos mitigado considerablemente su impacto en los datos personales de los clientes en caso de ataque exitoso:

1.- (...).

En segundo lugar, el análisis o evaluación de los riesgos para los derechos y libertades de los interesados debe tener en cuenta el tratamiento en su conjunto: contexto (en este caso, acceso desde un portal público desde internet), tipo de tratamiento, alcance del tratamiento (por ejemplo, si es tratamiento masivo o no, como es el caso), riesgos de probabilidad y gravedad para los derechos y libertades de las personas, etc, y no sólo, por tanto, atendiendo al tipo o categoría de datos personales tratados (si son o no sensibles).

No debe olvidarse la existencia de riesgos de conocer el número teléfono: se podría usar para llamar a su titular o contactar con él mediante sms, etc y mediante phishing o ingeniería social conseguir más datos identificativos (domicilio) y al tener, además, el

nombre de la wifi y las contraseñas, entrar en la misma y suplantar identidad, utilizarlos para fraude, estafa informática, etc.

Incluso en el supuesto de que, tal y como sostiene Telefónica, se pudiera aceptar que la probabilidad acceder a la wifi de los usuarios clientes es baja, el impacto de ello es muy alto sobre los derechos y libertades de las personas: robo identidad, hackeo de dispositivos conectados a esa wifi y obtener datos como de salud, de rutinas, consumos, etc., por lo que el riesgo final no puede considerarse bajo.

Asimismo, es continuo y está a la orden del día los intentos y los fraudes realizados por los ciberdelincuentes con objeto de conseguir las credenciales de acceso a aplicaciones y otros datos de las personas, sobre todo a través de técnicas de *phishing*, en sus diferentes modalidades (*phishing* propiamente dicho, *smishing*, *qrishing*, etc), por lo que es siempre alto o al menos considerable el riesgo de conseguirlas y, en consecuencia, producirse un acceso no autorizado, no siendo suficiente las campañas de concienciación anti *phishing* de los empleados para entender significativamente mitigado el riesgo. Por tanto, no puede compartirse que existiera un riesgo residual bajo de acceso no autorizado a credenciales de usuario legítimas, con las solas medidas de mitigación del riesgo realmente implementadas por Telefónica.

En el presente caso, el ataque, tal y como se produjo, podría haberse evitado, por ejemplo, si se hubiese contado con la exigencia de un doble factor de verificación para el acceso a la aplicación afectada, medida perfectamente existente y conocida, según el estado de la técnica en el momento del incidente, siendo viable y al alcance de una empresa como Telefónica, así como necesaria teniendo en cuenta (...).

2. (...).

(...)

Ello pone de manifiesto que en el momento del incidente no se contaba con un sistema de bloqueo de conexiones potencialmente inseguras -o de existir el mismo no era eficaz- en base a, por ejemplo, país de origen (denegar, por defecto, el tráfico entrante para todos los orígenes, excepto aquellos que son necesarios para la prestación de los servicios de la entidad; orígenes maliciosos conocidos (nodos de la red TOR, direcciones IP de baja reputación o identificadas como potencialmente maliciosas, etc.).

(...)

Por tanto, no existían medidas adecuadas para impedir el acceso a la infraestructura de Telefónica desde direcciones de Internet que pudieran resultar maliciosas o, de existir, no resultaron eficaces

Muestra de ello es que posteriormente al ataque sufrido, una de las medidas a implantar ha sido precisamente una consistente en (...).

3.-Medidas tendentes a la detección, despliegue de alertas y de reacción ante situaciones o conductas sospechosas o anómalas.

En relación con el ataque producido en el período del 16 al 20 de septiembre de 2022, tanto si se tiene en cuenta que las solicitudes masivas a *****APP.1** se estaban detectando desde el primer día no fue hasta el último (como sostiene Telefónica), el hecho es que no se produjo, ante tal elevado número de solicitudes, recordemos, muy superior a las habituales (de 55.000 diarias a 4 millones al día) y desde un único usuario, ninguna alerta de seguridad.

Ante tal nivel de solicitudes -totalmente alejadas de las normales en un día-, no se desplegó ninguna alerta de seguridad, ni ninguna medida de bloqueo, siendo así que durante cuatro días no se hizo nada o no se advirtió nada hasta que una persona de ... (...) envía un correo electrónico preguntando si eso va a seguir así para poder adoptar las medidas necesarias para poder mantener la aplicación.

Con posterioridad al incidente, Telefónica implantó medidas precisamente dirigidas a detectar, desplegar alertas y de reacción inmediata ante situaciones anómalas. Entre ellas:

-(...).

Lo anteriormente expuesto refleja, tal y como se indicó en el Acuerdo de Inicio del presente procedimiento sancionador que, con anterioridad al incidente, no se contaban con medidas técnicas y organizativas apropiadas para garantizar una seguridad adecuada en el tratamiento de los datos personales en relación con los riesgos asociados. O bien, en caso de existir, no fueron eficaces o no fueron observadas. Ello es así por cuanto:

a) En la aplicación atacada, a la cual se accedía mediante un portal publicado en Internet, y que permitía el acceso a datos personales, (...).

b) Precisamente El CSIRT de Telefónica (Equipo de Respuesta ante Incidentes de Seguridad) y que tiene como objetivo, en caso de que se materialice algún ataque, responder de forma urgente y coordinada al objeto de mitigar el impacto y, por ende, las consecuencias, no tuvo conocimiento del incidente hasta 5 días más tarde, lo cual supuso un considerable retraso tanto en la adopción de posibles medidas de contención y mitigación del ataque, así como en el análisis y valoración del mismo como brecha de seguridad de datos personales. Asimismo, no debe olvidarse que el ataque producido en el período comprendido entre el 9 y el 11 de septiembre de 2022, no se detectó el mismo ni se generó tampoco alerta alguna, lo que impidió cualquier actuación o medida de reacción o contención, siendo conocedora Telefónica de ello cuando el CSIRT analiza con posterioridad el incidente producido entre el 16 y el 20 de septiembre.

En conclusión, Telefónica no contaba o no tenía debidamente implantados sistemas o medidas adecuadas para generar alertas de seguridad ante situaciones sospechosas cuando no alarmantes como el hecho de que durante 4 días se estuvieran realizando una media de 4 millones al día de solicitudes a una aplicación que de forma habitual recibe unas 55 mil solicitudes diarias, y todo ello, además, desde un único usuario se

indica en el Correo1), lo cual, a todas luces resultaba obvio que no estaba siendo realizado por un ser humano.

Asimismo, procede reseñar que en la fase de pruebas Telefónica no ha aportado información respecto a por qué no se detectó en su momento el ataque sufrido entre el 9-11 septiembre de 2022. Así las cosas, no detectaron los accesos que se realizaron y fueron desde un único usuario (*****USUARIO.1**) que, además, resulta ser el mismo que en el ataque producido entre los días 16 al 20 sept 2022.

4.- No estaban los datos cifrados

Los datos personales de los clientes a los que se accedía mediante una aplicación desde internet no estaban cifrados de forma segura, anonimizados o protegidos de forma que fueran ininteligibles en casos de accesos no autorizados o que no se pueda identificar a las personas físicas, lo cual hubiera mitigado considerablemente los riesgos para los derechos y libertades de las personas.

Con posterioridad, se produce la adopción por parte de Telefónica consistente en la (...).

Por todo lo anteriormente expuesto, se concluye que, según el estado de la técnica ya existían medidas dirigidas de modo preciso a . Sin embargo, no fue hasta después de producida la brecha de datos personales cuanto se implementaron tales medidas.

De todo lo anterior, se concluye que las medidas técnicas y organizativas implantadas con anterioridad a la brecha no eran apropiadas para garantizar un nivel de seguridad adecuado al riesgo que el tratamiento de datos personales llevado a cabo suponía, y ello con independencia del concreto ataque sufrido -el cual lo que hace es poner de manifiesto estas deficiencias una vez que el riesgo se ha materializado- medidas que, según el estado de la técnica en el momento del incidente, ya existían y eran conocidas, cuyos costes de aplicación eran perfectamente asumibles por una empresa como Telefónica que, además, realiza tratamientos de datos a gran escala y con aplicaciones con acceso desde internet y que contienen datos personales, por lo que está obligada a adoptar medidas técnicas y organizativas de seguridad adecuadas a estos riesgos.

Tercero.- Superación de la esfera de responsabilidad de Telefónica: Circunstancias excepcionales que han hecho posible la superación por terceras personas de las políticas de seguridad implantadas.

Bajo esta rúbrica, Telefónica alega cuestiones relativas a lo sofisticado del ataque que sufrió, así como su posición de víctima de un delito realizado por ciberdelincuentes.

A este respecto, procede señalar que en ningún caso se ha exigido una infalibilidad total de las medidas que se pueden adoptar para garantizar una protección adecuada en el tratamiento de los datos personales. Sin embargo, una vez producido el ataque, que supuso una la brecha de datos personales debe evaluarse la diligencia del responsable del tratamiento en la aplicación de las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, teniéndose en

cuenta el estado de la técnica, los costes de aplicación, la naturaleza, el alcance, el contexto y los fines del tratamiento.

En el apartado anterior ya se ha indicado y argumentado que Telefónica no contaba, en el momento de producirse la brecha de protección de datos, con las medidas adecuadas en relación con los riesgos del tratamiento para la protección de los datos personales, las cuales hubieran evitado el ataque - tal y como se produjo- o cuanto menos hubieran mitigado considerablemente el impacto del mismo.

Por último, en cuanto a la condición de Telefónica de haber sido víctima de un delito, de conformidad con la Sentencia de 22 de junio de 2021- Rec. 1210/2018, y la Sentencia de 5 de noviembre de 2011 -Rec. 1796/2019, en la que se valora el elemento subjetivo o culpabilístico, se insiste en que la culpabilidad de la parte actora no puede considerarse excluida ni atenuada por el hecho de que haya mediado la actuación fraudulenta de un tercero, pues la responsabilidad de la parte actora no deriva de la actuación de éste, sino de la suya propia.

Se recuerda que, ciertamente, el principio de responsabilidad previsto en el artículo 28.1 de la Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público, dispone que: "Sólo podrán ser sancionadas por hechos constitutivos de infracción administrativa las personas físicas y jurídicas, así como, cuando una Ley les reconozca capacidad de obrar, los grupos de afectados, las uniones y entidades sin personalidad jurídica y los patrimonios independientes o autónomos, que resulten responsables de los mismos a título de dolo o culpa."

No obstante, según lo dictaminado en la STS 7887/2011 de 24 de noviembre de 2011, Rec. 258/2009, "(...) desde su sentencia 76/1990, de 26 de abril, el Tribunal Constitucional viene declarando que no cabe en el ámbito sancionador administrativo la responsabilidad objetiva o sin culpa, doctrina que se reafirma en la sentencia 164/2005, de 20 de junio de 2005, en cuya virtud se excluye la posibilidad de imponer sanciones por el mero resultado, sin acreditar un mínimo de culpabilidad aun a título de mera negligencia. Ahora bien, el modo de atribución de responsabilidad, a las personas jurídicas no se corresponde con las formas de culpabilidad dolosas o imprudentes que son imputables a la conducta humana."

Sucede así que, en el caso de infracciones cometidas por personas jurídicas, aunque haya de concurrir el elemento de la culpabilidad (véase la sentencia de esta Sala del Tribunal Supremo de 20 de noviembre de 2011 (recurso de casación en interés de ley 48/2007), éste se aplica necesariamente de forma distinta a como se hace respecto de las personas físicas. Según la STC 246/1991 "(...) esta construcción distinta de la imputabilidad de la autoría de la infracción a la persona jurídica nace de la propia naturaleza de ficción jurídica a la que responden estos sujetos. Falta en ellos el elemento volitivo en sentido estricto, pero no la capacidad de infringir las normas a las que están sometidos. Capacidad de infracción y, por ende, reprochabilidad directa que deriva del bien jurídico protegido por la norma que se infringe y la necesidad de que dicha protección sea realmente eficaz y por el riesgo que, en consecuencia, debe asumir la persona jurídica que está sujeta al cumplimiento de dicha norma."

A lo expuesto debe añadirse, siguiendo la sentencia de 23 de enero de 1998, parcialmente transcrita en la STS 6262/2009, de 9 de octubre de 2009, Rec 5285/2005,

y STS 6336/2009, de 23 de octubre de 2009, Rec 1067/2006, que *"aunque la culpabilidad de la conducta debe también ser objeto de prueba, debe considerarse en orden a la asunción de la correspondiente carga, que ordinariamente los elementos volitivos y cognoscitivos necesarios para apreciar aquélla forman parte de la conducta típica probada, y que su exclusión requiere que se acredite la ausencia de tales elementos, o en su vertiente normativa, que se ha empleado la diligencia que era exigible por quien aduce su inexistencia; no basta, en suma, para la exculpación frente a un comportamiento típicamente antijurídico la invocación de la ausencia de culpa"*.

Cuarta.- Sobre las cuestiones previas planteadas por la AEPD.

Bajo esta rúbrica, Telefónica insiste de nuevo en alegar que el Teléfono fijo no puede considerarse un dato personal y que sin ningún otro dato o información adicional es un dato seudónimo, en la medida que no puede atribuirse a un interesado sin utilizar información adicional.

Consideración del número de teléfono fijo como dato personal

Frente a ello, procede, en primer lugar, remitirnos a todo lo indicado en el Fundamento de Derecho III de la propuesta de resolución, el cual también aparece transcrito en el Acuerdo de Inicio, al que nos remitimos de forma íntegra en aras de evitar reiteraciones innecesarias.

Con la dicción actual del RGPD se infiere de forma automática que el número de teléfono fijo es un dato de carácter personal respecto del titular de la línea -es un identificador-, que se basta y se sobra para hacerle identificable.

El Dictamen 4/2007 sobre el concepto de datos personales del Grupo de Trabajo del Artículo 29, adoptado el 20 de junio de 2007, determina respecto de lo que es identificable que *"la persona física es «identificable» cuando, aunque no se la haya identificado todavía, sea posible hacerlo (que es el significado del sufijo «ble»)." (...) La identificación se logra normalmente a través de datos concretos que podemos llamar «identificadores» y que tienen una relación privilegiada y muy cercana con una determinada persona..."*.

En este sentido, en el supuesto del número de teléfono fijo, procede recordar lo ya indicado en el Fundamento de Derecho III respecto de las guías de abonados, previstas en el art. 72 de la Ley 11/2002, de 28 de junio, General de Telecomunicaciones, LGTel, y desarrolladas mediante el Real Decreto 424/2005 de 15 abril, por el que se aprueba el Reglamento sobre condiciones para prestación de servicios de comunicaciones electrónicas, servicio universal y protección de usuarios (vigente en lo que no se oponga a la LGTel de conformidad con lo previsto en la disposición derogatoria única, apartado c)).

Así el artículo 30.4 del citado RD 424/2005 indica que *"Sin perjuicio de lo dispuesto en el artículo 67, en relación con los datos relativos a cada abonado, deberá figurar, al menos, la siguiente información: a) Nombre y apellidos o razón social. B) Número o números de abonado. C) Dirección postal del domicilio, excepto piso, letra y escalera. D) Terminal específico que deseen declarar, en su caso. ..."*

En relación con el Informe Jurídico 0285/2006 de la AEPD, que reseña Telefónica resaltando que en el mismo se indica que “el número de teléfono constituirá un dato de carácter personal cuando resulte adscrito al concreto titular del mismo, o se asocie a datos identificativos adicionales como pueden ser la dirección y esta se almacene con el número llamante, de acuerdo con la definición de datos personales incluida en el artículo 3.a) de la Ley Orgánica, que comprende “cualquier información concerniente a personas físicas identificadas o identificables”, procede contextualizar el objeto de la consulta a que hace respuesta tal informe, e indicar que del mismo no se concluye que el número de teléfono fijo no sea un dato personal en sí mismo y que para ello necesite que venga asociado a información adicional.

En dicho informe, la consulta versa sobre si se le aplica la Ley Orgánica 15/1999, de 13 de diciembre, de Protección de Datos de Carácter Personal al registro en una base de datos de los números del terminal telefónico (fijo o móvil) desde el que se efectúan las llamadas telefónicas recibidas en la prestación de un servicio de atención a los usuarios del taxi a través del teléfono (tele-taxi).

Así, en dicho Informe se indica, tal y como ha señalado Telefónica, lo siguiente:

“En este sentido, debe indicarse que, desde el punto de vista de la protección de datos personales, el número de teléfono constituirá un dato de carácter personal cuando resulte adscrito al concreto titular del mismo, o se asocie a datos identificativos adicionales como pueden ser la dirección y esta se almacene con el número llamante, de acuerdo con la definición de datos personales incluida en el artículo 3.a) de la Ley Orgánica, que comprende “cualquier información concerniente a personas físicas identificadas o identificables”.”

Hay que tener en cuenta que en dicha consulta se estaban almacenando en una misma base de datos teléfonos fijos y también teléfonos móviles, junto con la dirección indicada por los clientes a la que tenía que acudir el taxi. Y en el momento de emitirse ese informe (año 2006), no era obligatorio aún que en los teléfonos móviles que funcionaban con tarjetas prepago debiera registrarse la identificación del titular del mismo. Por eso el párrafo indica dos posibilidades para considerar el número de teléfono como dato personal: o bien cuando resulte adscrito al concreto titular del mismo (como sucede respecto de los números de teléfonos fijos o de móviles con contrato), o bien, si no es así (como en los números de teléfonos móviles con tarjetas prepago), que se asocie a datos identificativos adicionales como pueden ser la dirección y esta se almacene junto con el número llamante (tal y como estaba haciendo la empresa de tele-taxi).

Por tanto, no procede aceptar la conclusión a la que llega Telefónica respecto de que junto a los números de teléfono (sean fijos o móviles) deba asociarse otro tipo de información adicional para que sean considerados datos personales.

Asimismo, debe tenerse en cuenta lo que también se indica en dicho informe:

“Este criterio ha sido ratificado por la Audiencia Nacional en sentencia de 8 de marzo de 2002. Según se cita en la misma, “para que exista un dato de carácter personal (en contraposición con dato disociado) no es imprescindible una plena coincidencia entre el dato y una persona concreta, sino que es suficiente con que tal identificación pueda

efectuarse sin esfuerzos desproporcionados” y “para determinar si una persona es identificable, hay que considerar el conjunto de los medios que puedan ser razonablemente utilizados por el responsable del tratamiento o por cualquier otra persona, para identificar a dicha persona”. (el subrayado es nuestro)

Por otro lado, conviene señalar que el artículo 1.4 del Real Decreto 1332/1994 de 20 de junio por el que se desarrollan algunos de los preceptos de la Ley Orgánica, considera datos de carácter personal a “toda información numérica, alfabética, gráfica, fotográfica, acústica o de cualquier otro tipo susceptible de recogida, registro, tratamiento o transmisión concerniente a una persona física identificada o identificable”.

El artículo 1.5 del Real Decreto citado cierra el concepto definiendo o describiendo la identificación del afectado como “cualquier elemento que permita determinar, directa o indirectamente, la identidad física, fisiológica, psíquica, económica, cultural o social de la persona física afectada”.

A su vez, el artículo 2.a) de la Directiva 95/46/CE considera identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un número de identificación o uno o varios elementos característicos de su identidad física, fisiológica, psíquica, económica, cultural o social”. El Considerando 26 de la propia Directiva advierte que para determinar si una persona es identificable, hay que considerar el conjunto de medios que puedan ser razonablemente utilizados por el responsable del tratamiento, o por cualquier otra persona, para identificar al interesado.”

(el subrayado es nuestro)

A este respecto, actualmente es fácil asociar los teléfonos fijos con el titular de los mismos y con su dirección postal por cuanto, tal y como se ha señalado, existen las guías de abonados, previstas en el art. 72 de la LGTel, y desarrolladas mediante el Real Decreto 424/2005 de 15 abril. Además, tras casi 20 años después, con los avances tecnológicos, con la posibilidad de herramientas mucho más sofisticadas para relacionar datos personales existentes en diferentes lugares y de diferentes bases de datos.

En relación a la Sentencia Sentencia de la Audiencia Nacional, Sala de lo Contencioso-administrativo, Sección 1ª, de 17 de septiembre de 2008 (rec. 353/2007) mencionada por Telefónica para argumentar nuevamente que el teléfono fijo no es un dato personal si no va asociado a otro tipo de información, procede analizar el contenido de la misma.

Dicha sentencia resuelve un recurso contencioso-administrativo interpuesto contra una resolución del Director de la AEPD de 15 de junio de 2007, relativa a unos hechos acaecidos en el año 2005 y respecto del número de teléfono móvil. Por tanto, no se debatía si el teléfono fijo es o no un dato personal, respecto del cual ya se ha indicado que es un dato personal y que actualmente es muy fácil asociar los teléfonos fijos con la dirección de sus titulares a través de las guías de abonados.

En este sentido, como quiera que el número de teléfono fijo es un dato de carácter personal en sí mismo, cuestión que resulta incontrovertida en la AEPD, en los

tribunales y, hasta ahora, por todos los operadores de telecomunicaciones, es la razón de que no existan informes o resoluciones judiciales en las que se cuestione la configuración del número de teléfono fijo como dato de carácter personal, lo que no ha acontecido con otros datos de los que se ha dudado inicialmente si eran o no de carácter personal (como por ejemplo el teléfono móvil).

No obstante, y a mayor abundamiento, se procede al análisis de dicha Sentencia por cuanto de la misma se recogen argumentos sobre que los teléfonos móviles sí son datos personales y que igualmente sirven para afianzar más si cabe el hecho de que el teléfono fijo es un dato personal en sí mismo, sin necesidad de información adicional sobre el titular del mismo.

Así, en el fundamento de derecho cuarto se destaca: (el subrayado es nuestro)

“Pues bien, el primer problema que se suscita en el presente caso es si el número de teléfono móvil puede incluirse en el concepto de “datos personales” que recoge el artículo 3.a) de la LOPD que identifica como tales “cualquier información concerniente a personas físicas identificadas o identificables”. Es claro que un número telefónico asociado a un nombre y apellidos es un dato de carácter personal pues nos proporciona información sobre una persona identificada. Es más, el propio número de teléfono, sin aparecer directamente asociado a una persona, puede tener la consideración de dato personal si a través de él se puede identificar a su titular.”

En el presente caso la Agencia Española de Protección de Datos no ha razonado, y menos ha acreditado, que a través del número de teléfono móvil se haya identificado al titular del mismo o que a partir del citado número fuese posible tal identificación, de forma que el citado número de teléfono ayuno de otras circunstancias que identifiquen o pudiesen permitir identificar al titular del mismo impide que pueda encajarse en la definición legal de dato de carácter personal.”

Desde el año 2005 (fecha de los hechos que dieron lugar a la resolución del Director de la AEPD de 15 de junio de 2007) hasta la actualidad han transcurrido casi 20 años durante los cuales se han producido importantes cambios.

Por una parte, la regulación de la protección de datos de carácter personal ha sufrido una importante transformación, impulsada por el RGPD. Norma europea que aboga por una interpretación amplia de conceptos tales como, dato de carácter personal, tratamiento, responsable del tratamiento, etc... En este nuevo contexto normativo, cabe entender superada la concepción anterior, en base a la cual se consideraba que un número de teléfono móvil, que no fuera acompañado de más datos, no podía ser considerado un dato de carácter personal.

Por otra parte, se han producido importantes avances, tanto normativos como tecnológicos, que permiten que, a partir del número de teléfono, sea posible llegar a identificar a la persona a la que pertenece dicho número.

Regulación contenida en el RGPD: (el subrayado es nuestro)

El artículo 4.1) del RGPD define datos personales como: *“toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona*

física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona;

Tal y como determina el Dictamen 4/2007 del Grupo de Trabajo del Artículo 29 sobre el concepto de datos personales, WP136, adoptado el 20 de junio de 2007, “esta definición refleja la intención del legislador europeo de mantener un concepto amplio de «datos personales».” y a continuación afirma “La expresión «toda información» utilizada en la Directiva indica claramente la voluntad del legislador de dar un sentido amplio al concepto «datos personales». Esta redacción exige una interpretación amplia.”

Por su parte el considerando 26 del RGPD dispone: (el subrayado es nuestro)

“(26) Los principios de la protección de datos deben aplicarse a toda la información relativa a una persona física identificada o identificable. Los datos personales seudonimizados, que cabría atribuir a una persona física mediante la utilización de información adicional, deben considerarse información sobre una persona física identificable. Para determinar si una persona física es identificable, deben tenerse en cuenta todos los medios, como la singularización, que razonablemente pueda utilizar el responsable del tratamiento o cualquier otra persona para identificar directa o indirectamente a la persona física. Para determinar si existe una probabilidad razonable de que se utilicen medios para identificar a una persona física, deben tenerse en cuenta todos los factores objetivos, como los costes y el tiempo necesarios para la identificación, teniendo en cuenta tanto la tecnología disponible en el momento del tratamiento como los avances tecnológicos. Por lo tanto los principios de protección de datos no deben aplicarse a la información anónima, es decir información que no guarda relación con una persona física identificada o identificable, ni a los datos convertidos en anónimos de forma que el interesado no sea identificable, o deje de serlo. En consecuencia, el presente Reglamento no afecta al tratamiento de dicha información anónima, inclusive con fines estadísticos o de investigación.”

En este sentido, el Dictamen 4/2007 del Grupo de Trabajo del Artículo 29 sobre el concepto de datos personales, WP136, adoptado el 20 de junio de 2007, expone: (el subrayado es nuestro)

“De modo general, se puede considerar «identificada» a una persona física cuando, dentro de un grupo de personas, se la «distingue» de todos los demás miembros del grupo. Por consiguiente, la persona física es «identificable» cuando, aunque no se la haya identificado todavía, sea posible hacerlo (...)

La identificación se logra normalmente a través de datos concretos que podemos llamar «identificadores» y que tienen una relación privilegiada y muy cercana con una determinada persona.
(...)

«Directa» o «indirectamente» identificable

Esta idea se aclara aún más en los comentarios a los artículos de la propuesta modificada de la Comisión, en donde se afirma que «una persona puede ser identificada directamente por su nombre y apellidos o indirectamente por un número de teléfono, la matrícula de un coche, un número de seguridad social, un número de pasaporte o por una combinación de criterios significativos (edad, empleo, domicilio, etc.), que haga posible su identificación al estrecharse el grupo al que pertenece.»»

A mayor abundamiento, tras la entrada en vigor de la Ley 25/2007, de 18 de octubre, es posible identificar aún más a través del número de teléfono (fijo y móvil) a la persona a la que pertenece (si bien es cierto que dicha información se facilita a los agentes facultados, tras la correspondiente autorización judicial).

Asimismo, el 58.5 de la Ley 11/2022, de 28 de junio, ha establecido una correlación entre el número de teléfono y la identidad de la persona a la que pertenece dicho número.

A continuación, se procede al análisis de dicha normativa:

Ley 25/2007, de 18 de octubre, de conservación de datos relativos a las comunicaciones electrónicas y a las redes públicas de comunicaciones y artículo 58.5 de la Ley 11/2022, de 28 de junio, General de Telecomunicaciones (el subrayado es nuestro)

La Ley 25/2007, de 18 de octubre, transpuso al ordenamiento jurídico español la Directiva 2006/24/CE, del Parlamento Europeo y del Consejo, de 15 de marzo, sobre la conservación de datos generados o tratados en relación con la prestación de servicios de comunicaciones electrónicas de acceso público o de redes públicas de comunicaciones, y por la que se modifica la Directiva 2002/58/CE, del Parlamento Europeo y del Consejo, de 12 de julio.

El artículo 1, que determina el objeto de la Ley, dispone:

“1. Esta Ley tiene por objeto la regulación de la obligación de los operadores de conservar los datos generados o tratados en el marco de la prestación de servicios de comunicaciones electrónicas o de redes públicas de comunicación, así como el deber de cesión de dichos datos a los agentes facultados siempre que les sean requeridos a través de la correspondiente autorización judicial con fines de detección, investigación y enjuiciamiento de delitos graves contemplados en el Código Penal o en las leyes penales especiales.

2. Esta Ley se aplicará a los datos de tráfico y de localización sobre personas físicas y jurídicas y a los datos relacionados necesarios para identificar al abonado o usuario registrado. (...)”

El artículo 3 (Datos objeto de conservación), dispone:

1. Los datos que deben conservarse por los operadores especificados en el artículo 2 de esta Ley, son los siguientes:

“a) Datos necesarios para rastrear e identificar el origen de una comunicación:

1.º Con respecto a la telefonía de red fija y a la telefonía móvil:

- i) Número de teléfono de llamada.
- ii) Nombre y dirección del abonado o usuario registrado.

(...)

b) Datos necesarios para identificar el destino de una comunicación:

1.º Con respecto a la telefonía de red fija y a la telefonía móvil:

- i) El número o números marcados (el número o números de teléfono de destino) y, en aquellos casos en que intervengan otros servicios, como el desvío o la transferencia de llamadas, el número o números hacia los que se transfieren las llamadas.
- ii) Los nombres y las direcciones de los abonados o usuarios registrados.

(...)"

Avances en el ámbito de las comunicaciones durante los últimos 19 años

Nadie discute la trascendencia de los cambios que se han producido en los últimos 19 años en el ámbito de las comunicaciones, tanto partiendo de una perspectiva basada en la innovación, como desde una perspectiva exclusivamente tecnológica.

Además del mecanismo regulado en la Ley 25/2007, de 28 de octubre, existen otras posibilidades, que permiten en la actualidad identificar a la persona a la que pertenece un número de teléfono fijo o móvil (motores de búsqueda online, apps, páginas web con directorios telefónicos, e incluso, utilizando el perfil, en algunas redes sociales).

En este sentido, el Dictamen 4/2007 del Grupo de Trabajo del Artículo 29 sobre el concepto de datos personales, WP136, adoptado el 20 de junio de 2007, aclara en relación con la posibilidad de identificar a la persona: (el subrayado es nuestro)

"se trata de una prueba dinámica, por lo que debe tenerse en cuenta el grado de avance tecnológico en el momento del tratamiento y su posible desarrollo en el período durante el cual se tratarán los datos. Puede que la identificación no sea factible hoy con el conjunto de los medios que puedan ser razonablemente utilizados en la actualidad. Si lo previsto es que los datos se conserven durante un mes, puede que no sea factible adelantar la identificación para que esté terminada dentro del «período de vida» de la información y, por lo tanto, esa información no debe considerarse como datos personales. Ahora bien, si el período de conservación previsto es de diez años, el responsable del tratamiento debe barajar la posibilidad de que la identificación pueda producirse al cabo de nueve años, con lo que adquiriría en ese momento la categoría de datos personales. Es preciso que el sistema sea capaz de adaptarse a los progresos tecnológicos a medida que éstos se produzcan y que introduzca las medidas técnicas y organizativas apropiadas a su debido tiempo."

Por todo lo expuesto, cabe afirmar que en la actualidad el número de teléfono ya sea fijo o móvil encaja a la perfección en la definición de lo que es un dato de carácter personal según el artículo 4.1) del RGPD.

Por una parte, permite, por sí solo, hacer identificable a la persona a la que pertenece, aun cuando no venga acompañado de ningún otro dato.

Por otra, es posible llegar a identificar, a través del número de teléfono, a la persona a la que pertenece sin realizar esfuerzos desproporcionados.

Además, olvida Telefónica que para que una persona sea identificable no es necesario que toda la información que permita identificar al interesado deba encontrarse en poder de una sola persona. Al respecto, la Sentencia del TJUE de 19 de octubre de 2016, en el asunto C-582/14, en el procedimiento entre Patrick Breyer y Bundesrepublik Deutschland, señala que *“para que un dato pueda ser calificado de «dato personal», en el sentido del artículo 2, letra a), de dicha Directiva, no es necesario que toda la información que permita identificar al interesado deba encontrarse en poder de una sola persona.”* (el subrayado es nuestro).

Por tanto, las Resoluciones, Informes y Sentencias que trae a colación Telefónica para intentar argumentar que el número del teléfono no se considera un dato personal si no viene acompañado de información adicional que permita identificar a sus titulares o que los haga identificables, son de hace 15 años o más y se refieren a los teléfonos móviles que en aquél entonces existía discrepancia o dudas sobre su carácter de dato personal por sí solos, cuestión que actualmente está superada por todo lo anteriormente indicado. Máxime para los números de teléfonos fijos que siempre están y han estado adscritos a un titular concreto y con gran facilidad de identificar a los mismos.

En cuanto a las Sentencias del Tribunal de Justicia de la UE indicadas por Telefónica para entender que, extrapolando lo que indican, un dato sólo puede tener la consideración de dato personal para un tercero cuando éste disponga de medios legales que le permitan identificar a la persona interesada gracias a la información adicional que tuviese el tercero de dicha persona, se significa que estas conclusiones se han sacado sin tener en cuenta el contexto de las mismas, así como que tal conclusión contradice frontalmente la definición que realiza el RGPD de dato personal, así como todo lo que se ha argumentado anteriormente, pues ello supondría que si se accede de forma ilegal a los datos personales ello haría que los mismos no tuvieran tal condición, lo cual es inadmisibile, pues permitiría incluso llegar a la conclusión de que no sería necesario ninguna medida de seguridad frente a cualquier riesgo de ser vulnerada la confidencialidad, integridad y disponibilidad de los datos personales, por cuanto que para que exista tal vulneración es necesario que se realice de forma no lícita y por tercero no autorizado.

En cuanto a los datos técnicos y de configuración a los que los atacantes accedieron, indica Telefónica que por la naturaleza de los mismos y porque sólo vienen asociados al número de teléfono fijo y, entendiendo que este último no es un dato personal relativo a una persona identificable, no pueden ser tampoco considerados datos de carácter personal.

A este respecto procede recordar que entre los datos a los que los atacantes tuvieron acceso, Telefónica indicó los siguientes:

- MAC y detalles del fabricante del dispositivo;
- Configuración de los puertos de la conexión asociada al teléfono fijo;
- Nombres de la red wifi y su contraseña

En este sentido, procede remitirse a todo lo reseñado anteriormente respecto a la consideración del número de teléfono fijo como dato personal en sí mismo. Por tanto, dado que el resto de datos a los que se accedió lo fueron asociados al teléfono fijo de sus titulares, Por tanto, toda información relativa a una persona física identificada o identificable, son datos personales.

Asimismo, en relación con la información de direcciones MAC, cabe señalar que el Grupo de Trabajo del Artículo 29, en su Dictamen 13/2011, sobre los servicios de geolocalización en los dispositivos móviles inteligentes, puso de manifiesto los riesgos que conlleva la recopilación de direcciones MAC mediante el barrido de señales y a la posibilidad de asociar esa información a personas físicas:

“Barrido pasivo: registro de las señales transmitidas periódicamente por cada punto de acceso (generalmente 10 veces por segundo). Como alternativa y excepcionalmente, algunos dispositivos registran todas las señales WiFi transmitidas por los puntos de acceso, incluidos los que no emitan señales de baliza. Si este tipo de barrido se realiza sin aplicar adecuadamente la protección de la intimidad desde el diseño, ello puede desembocar en la obtención de datos intercambiados entre los puntos las direcciones MAC de los ordenadores, ordenadores portátiles e impresoras de acceso y los aparatos conectados a ellos. De esta manera podrían registrarse. Este tipo de barrido también podría conducir al registro ilegal del contenido de las comunicaciones. Estos contenidos son fácilmente legibles en caso de que el propietario del punto de acceso WiFi no haya activado un cifrado WiFi (WEP/WPA/WPA2).”

(...)

“Puntos de acceso WiFi. Esta forma indirecta de identificabilidad se aplica asimismo a los puntos de acceso WiFi. La dirección MAC de un punto de acceso WiFi, en combinación con su ubicación calculada, está íntimamente ligada a la ubicación del propietario del punto de acceso.

Un responsable del tratamiento de datos razonablemente equipado puede calcular cada vez con mayor precisión la localización de un punto de acceso WiFi haciendo uso de la intensidad de la señal y de las actualizaciones de localización que estén efectuando los usuarios de sus servicios de geolocalización.

Con estos recursos, en muchos casos puede identificarse un pequeño grupo de apartamentos o casas en los que viviría el propietario del punto de acceso. La facilidad con la que será posible identificar a este titular de la dirección MAC dependerá del entorno:

. En zonas poco pobladas, en donde la dirección MAC apunta a una sola casa, el propietario de la residencia puede ser identificado directamente con herramientas como, por ejemplo, los registros del catastro, las páginas blancas telefónicas, los censos electorales o incluso un simple motor de búsqueda.

. En zonas más densamente pobladas y con ayuda de recursos como, por ejemplo, la intensidad de señal o la SSID (que cualquier persona con un dispositivo WiFi puede detectar), es posible determinar la localización precisa del punto de acceso y así, en muchos casos, la identidad de la persona que vive en el lugar concreto (casa o apartamento) en el que está situado el punto de acceso.

. En zonas muy densamente pobladas, incluso contando con la ayuda de información sobre intensidad de la señal, la dirección MAC indicará varios apartamentos como posible localización del punto de acceso. En estas circunstancias, no es posible determinar con precisión y sin esfuerzo excesivo la identidad de la persona que vive en el apartamento en donde está situado el punto.

El hecho de que, en algunos casos, el propietario del dispositivo no pueda ser identificado en ese momento sin un esfuerzo no razonable, no obsta a la conclusión general de que la combinación de una dirección MAC de un punto de acceso WiFi con su ubicación calculada debe ser tratada como datos personales.

En estas circunstancias, y teniendo en cuenta que es improbable que el responsable del tratamiento de datos sea capaz de distinguir entre los casos en los que el propietario del punto de acceso WiFi es identificable y en los que no, el responsable deberá considerar todos los datos sobre encaminadores WiFi como datos personales.

Es importante recordar que no es necesario que la finalidad del tratamiento de estos datos de geolocalización sea identificar a los usuarios. El que ello requiera un esfuerzo irrazonable para identificar a los propietarios de los puntos de acceso WiFi está muy influenciado por las posibilidades técnicas de que disponga el responsable del tratamiento de datos o cualquier otra persona para identificarlos”.

Por tanto, atendiendo a la definición contenida en las normas citadas, que consideran dato de carácter personal “cualquier información concerniente a personas físicas identificadas o identificables”, la información recabada en este caso se ajusta a dicho concepto, al tratarse de información concerniente a personas físicas identificadas o identificables, ya que con los datos afectados por la quiebra es posible la identificación de los titulares de los mismos sin un esfuerzo exagerado o desproporcionado.

Quinto.- Sobre las presuntas infracciones cometidas por parte de Telefónica. Vulneración del principio de tipicidad.

Bajo este epígrafe, Telefónica alega lo siguiente:

5.1.- La conducta de Telefónica en ningún caso podría considerarse subsumible en ninguno de los preceptos que esta Agencia considera vulnerados

Señala Telefónica que se le ha imputado una infracción del artículo 5.1.f) del RGPD y una infracción del artículo 32 del RGPD, pero que considera que su conducta en ningún caso es subsumible en ninguno de esos preceptos que se ha considerado que ha vulnerado, pues entiende que cuenta con unas medidas técnicas y organizativas apropiadas en lo que respecta al tratamiento de datos personales en sus sistemas, tal y como ha quedado probado.

Frente a ello, se significa que de todo lo argumentado en el apartado Segundo del presente Fundamento de Derecho, al cual nos remitimos íntegramente, ha quedado probado y acreditado lo contrario, es decir, que Telefónica no contaba con medidas apropiadas que garantizaran un nivel de seguridad adecuado al riesgo, teniendo en cuenta la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas.

Así, teniendo en cuenta que la aplicación *****APP.1** permitía acceder a datos personales de alrededor de 6 millones de clientes (según manifestó Telefónica en sus dos notificaciones a esta Agencia de la brecha de datos personales), y que a la misma se accedía a través de un portal publicado en Internet, no existía un factor de doble verificación para el acceso a la misma, no existían medidas o herramientas cuya funcionalidad estuviera dirigida a bloquear a los usuarios en caso de accesos masivos en un breve espacio de tiempo o dirigidas a monitorizar el funcionamiento y generar eventos de seguridad de forma automática, todo lo cual permitió el ataque tal y como se configuró. Ni siquiera, en caso de que hubiera sido un ataque inevitable, Telefónica o detectó nada de esas consultas masivas durante el ataque realizado entre los días 9 y 11 de septiembre de 2022 y tampoco se generaron alertas o avisos tempranos en el ataque sufrido entre los días 16 y 20 de septiembre que le hubieran permitido acometer de forma inmediata medidas tendentes a paliar el ataque (bloqueo del usuario/s comprometidos; bloqueo de la IP extranjera desde la que se estaba atacando) y mitigar así considerablemente el impacto del ataque, en el cual, finalmente, se vio afectada la confidencialidad de los datos personales de más de 1.400.000 personas. Incluso una medida sencilla, (...) hubiera impedido la brecha de datos personales acaecida.

Posteriormente, Telefónica implantó medidas cuyas funcionalidades iban dirigidas precisamente a evitar la utilización de las credenciales de usuarios para realizar un ataque masivo (bloqueo del usuario al producirse un número elevado de solicitudes en un tiempo corto) o bien, a detectar situaciones anómalas sospechosas de maliciosas mediante herramientas de detección temprana y generadoras de alertas de seguridad, así como herramientas de reacción, como bloqueos de accesos desde direcciones IP sospechosas.

Por tanto, todo ello pone de manifiesto la comisión de las infracciones imputadas del artículo 5.1.f) y del artículo 32 del RGPD que son distintas, tal y como se explicará posteriormente.

El artículo 5.1.f) indica que:

1. Los datos personales serán:

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).

Por su parte, el artículo 32, señala:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

a) la seudonimización y el cifrado de datos personales;

b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;

c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;

d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

(...)”

Asimismo, la tipificación de la infracción del artículo 5.1.f) del RGPD se encuentra en el artículo 83.5 del RGPD cuando indica:

5. Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9;

Mientras que la tipificación de la infracción del artículo 32 del RGPD se encuentra en el artículo 83.4 del RGPD:

4. Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43;

Por tanto, las infracciones están perfectamente tipificadas en el RGPD, siendo la conducta de Telefónica perfectamente subsumibles en las mismas, habiendo sido además antijurídica y culpable. Por tanto, no se considera vulnerado el principio de tipicidad

Asimismo, señala Telefónica que los preceptos indicados como infringidos no exigen la infalibilidad de las medidas de seguridad, sino que estas sean apropiadas, alegando que la normativa aplicable no establece una obligación de resultado respecto de las medidas de seguridad, sino sólo de medios y que lo contrario supondría aceptar una responsabilidad objetiva o sin culpa, trayendo para ello a colación la Sentencia del Tribunal Supremo STS 543/2022 (recurso de casación nº 7359/2020), de 15 de febrero de 2022.

Segundo, y en relación con la Sentencia citada, esta efectivamente indica, sobre las medidas de seguridad en materia de protección de datos, que “... *la obligación que recae sobre el responsable y sobre el encargado del tratamiento respecto a la adopción de medidas necesarias para garantizar la seguridad de los datos de carácter personal no es una obligación de resultado sino de medios, sin que sea exigible la infalibilidad de las medidas adoptadas. Tan solo resulta exigible la adopción e implantación de medidas técnicas y organizativas, que conforme al estado de la tecnología y en relación con la naturaleza del tratamiento realizado y los datos personales en cuestión, permitan razonablemente evitar su alteración, pérdida, tratamiento o acceso no autorizado.*”

Sin embargo, continúa la Sentencia indicando, en el caso concreto que se analiza en la misma, que “...*el programa utilizado para la recogida de los datos de los clientes no contenía ninguna medida de seguridad que permitiese comprobar si la dirección de correo electrónico introducida era real o ficticia y si realmente pertenecía a la persona cuyos datos estaban siendo tratados y prestaba el consentimiento para ello. El estado de la técnica en el momento en el que se produjeron estos hechos permitía establecer medidas destinadas a comprobar la veracidad de la dirección de email, condicionando la continuación del proceso a que el usuario recibiese el contrato en la dirección proporcionada y solo desde ella prestase el consentimiento necesario para su recogida y tratamiento. Medidas que no se adoptaron en este caso.*

(...) De modo que, en el momento en que se produjeron estos hechos, existían medidas técnicas referidas al proceso de registro, que hubiesen evitado la filtración de datos personales producida. Ello implica que las medidas técnicas adoptadas incumplían las condiciones de seguridad en los términos exigidos en el art. 9.1 de la LO 15/1999, incurriéndose por tanto en la infracción prevista en el art. 44.3.h) consistente en "Mantener los ficheros, locales, programas o equipos que contengan datos de carácter personal sin las debidas condiciones de seguridad que por vía reglamentaria se determinen [...]".

(...) Se afirma que las medidas técnicas de seguridad referidas al programa informático incumbían a Telefónica Consumer Finance que diseñó el programa y era la responsable del fichero y del tratamiento, y que la empresa sancionada tan solo actuaba por cuenta de ésta recabando los datos de los clientes que optaban por la financiación. Lo cierto es que el encargado del tratamiento -la persona física o jurídica que, sólo o conjuntamente con otros, trate datos personales por cuenta del responsable del tratamiento, art. 4 apartado 8 del Reglamento, como el art. 3.g) de la LOPD 15/1999, y la recogida de datos implica un tratamiento (art. 3.c),-también deberá adoptar las medidas de índole técnica y organizativas necesarias para garantizar la seguridad de los datos de carácter personal, así lo dispone el art. 32.1 del Reglamento (UE) 2016/679 del Parlamento y del Consejo y el art. 9.1 de la LOPD y está sujeto al régimen sancionador establecido en la Ley (art. 43 de la LOPD 15/1999).

La empresa recurrente trataba los datos de los clientes por cuenta del responsable del fichero por lo que implantó y utilizó dicho programa siendo conocedora, o hubiera debido serlo, de que éste carecía de las medidas de seguridad necesarias..." (el subrayado es nuestro)

En primer lugar, procede señalar que esta sentencia se dicta al amparo de la normativa anterior al RGPD, en la que, conforme al sistema previsto en la LOPD y en el RLOPD, las medidas de seguridad estaban perfectamente estandarizadas. Se ha pasado de un sistema con medidas de seguridad estándar y estáticas para cualquier responsable a medidas de seguridad propias para cada organización (adaptadas a sus características e idiosincrasia), que considera los riesgos específicos de la entidad de que se trate; además ahora son dinámicas, de tal forma que no se agota con la implementación de las medidas de seguridad adecuadas al riesgo al inicio de los tratamientos, sino que debe de ir adaptándose a los riesgos que vayan apareciendo.

La nueva regulación prevista en el RGPD amplía notablemente las obligaciones del responsable del tratamiento y su ámbito de acción y responsabilidad, extendiéndose ahora de manera clara a las actuaciones realizadas por sus encargados del tratamiento, que quedan dentro de su ámbito de responsabilidad.

En la sentencia no se delibera sobre la adecuación de las medidas de seguridad de la entonces responsable del fichero, sino que se denunció a un encargado del tratamiento, quien no tenía implementadas las medidas de seguridad adecuadas, obligación que devenía de manera clara del art. 79 y siguientes del RLOPD, en la que se indicaba cuáles, en concreto, eran las medidas de seguridad que, conforme al Título VIII del citado Reglamento, debían implantar los encargados. No obstante lo

anterior, además, la sentencia indica que no fue utilizado el sistema de forma adecuada, lo que hubiera evitado la filtración.

En segundo lugar, debe señalarse que la Sentencia del Tribunal Supremo citada considera, en relación con una infracción del art. 9 de la LOPDP que *“la obligación que recae sobre el responsable del fichero y sobre el encargado del tratamiento respecto a la adopción de medidas necesarias para garantizar la seguridad de los datos de carácter personal no es una obligación de resultado sino de medios, sin que sea exigible la infalibilidad de las medidas adoptadas. Tan solo resulta exigible la adopción e implantación de medidas técnicas y organizativas, que conforme al estado de la tecnología y en relación con la naturaleza del tratamiento realizado y los datos personales en cuestión, permitan razonablemente evitar su alteración, pérdida, tratamiento o acceso no autorizado”*.

Sobre ello precisa que *“No basta con diseñar los medios técnicos y organizativos necesarios también es necesaria su correcta implantación y su utilización de forma apropiada, de modo que también responderá por la falta de la diligencia en su utilización, entendida como una diligencia razonable atendiendo a las circunstancias del caso”*.

Por tanto, tal y como se ha señalado, las infracciones están perfectamente tipificadas en el RGPD, siendo la conducta de Telefónica perfectamente subsumibles en las mismas, habiendo sido además antijurídica y culpable. Por tanto, no se considera vulnerado el principio de tipicidad.

5.2.- Sobre la redacción de la normativa que resulta de aplicación: conceptos jurídicos indeterminados que contribuyen a incrementar la inseguridad jurídica e indefensión de Telefónica.

Afirma Telefónica que es destacable la ambigüedad e indeterminación de los conceptos recogidos en los artículos del RGPD que se han considerado infringidos, tales como “seguridad adecuada”, “medidas técnicas y organizativas apropiadas” o “nivel de seguridad adecuado al riesgo”. Dichos conceptos no son definidos en el RGPD ni en el resto de normativa de protección de datos, entendiendo Telefónica, por tanto, que esta Agencia actúa de manera arbitraria exigiendo una responsabilidad objetiva, al centrarse tan solo en el resultado producido en un incidente concreto y sin tener en cuenta que no puede exigir la infalibilidad de las medidas adoptadas.

Entiende que ello vulnera el principio de seguridad jurídica y de la interdicción de la arbitrariedad de los poderes públicos consagrados en el artículo 9.3 de la Constitución Española, y que está propiciando la AEPD una situación de inseguridad jurídica y dificultando la defensa de Telefónica.

A este respecto, procede señalar que si bien la normativa constitucional exige, en el ámbito punitivo (penal y administrativo), que exista el suficiente grado de certeza en la determinación de las conductas infractoras, ello no significa que no puedan usarse conceptos jurídicos indeterminados, como los señalados por Telefónica, que sin embargo, resultan de fácil concreción por parte del órgano competente -en este caso,

por esta Agencia- que haya de aplicar la norma al caso, sobre la base ya sea de elementos circunstanciales cognitivos o ya valorativos, siempre de carácter objetivo.

En este sentido, procede señalar la Sentencia del Tribunal Constitucional 13/2021, de 28 de enero (Recurso de Inconstitucionalidad 3848/2015) en la que se indica lo siguiente: (el subrayado es nuestro)

“Entrando ya en el análisis del apartado objeto de impugnación, el abogado del Estado se refiere a la alegación del recurso sobre imprecisión de los términos jurídicos utilizados, oponiendo a la misma que ya el Consejo de Estado en su dictamen 557/2014, de 30 de marzo, emitido respecto del proyecto de ley, consideró que es posible, sin incurrir en arbitrariedad o falta de tipificación, la utilización de conceptos jurídicos indeterminados porque «[l]a razón jurídica no es una razón mecánica y, por ello, el legislador no puede prever detalladamente todas y cada una de las circunstancias del caso al que hay que aplicar la ley, especialmente en materia tan fluida como es el mantenimiento de la seguridad ciudadana. Por eso, es adecuado y razonable tanto el recurso a conceptos jurídicos indeterminados como a lo razonable de la interpretación de la norma y la valoración de los hechos en presencia».

(...)

a) El principio de tipicidad recogido en el artículo 25.1 CE requiere que, mediante su predeterminación normativa, se asegure que la reacción sancionadora sea previsible y no sorpresiva. Esta exigencia de lex certa, como se desarrolló en el fundamento jurídico 4 a), no se opone a la utilización de un concepto jurídico indeterminado como el de «perturbación de la seguridad ciudadana» en la definición de la conducta infractora, siempre que su concreción sea razonablemente previsible en virtud de criterios lógicos, técnicos o de experiencia.

Conforme a los términos en que la demanda cumple con la carga de alegar que incumbe a quien promueve un recurso de inconstitucionalidad, el tribunal debe centrar su atención en si el artículo 36.1 es suficientemente preciso en dos extremos: (i) el nivel de perturbación de la seguridad ciudadana que integra el tipo infractor, y en particular si alcanza a las perturbaciones no graves; y (ii) si la conducta típica exige la producción de un resultado y cuál ha de ser este.

Procede resaltar, en cuanto a la primera cuestión, que el artículo 36.1 LOPSC ha de interpretarse en el contexto del ordenamiento jurídico en que se inserta con el fin de identificar cuál es el nivel de perturbación de la seguridad ciudadana que es constitutivo de la conducta infractora y si comprende o no las alteraciones leves de la seguridad ciudadana. Dicho con otras palabras, una norma punitiva puede aparecer incompleta en sí misma considerada, pero no por ello desconocerá el principio de tipicidad ex artículo 25.1 CE si cabe completarla por referencia al contexto legal en que se integra (STC 89/1993, FJ 2).

El tribunal, en atención a que la presente impugnación ha quedado delimitada por las partes en los términos expuestos, entiende procedente desestimarla con arreglo a los mismos argumentos utilizados para considerar que el artículo 36.1 LOPSC no vulneraba la dimensión del principio de tipicidad invocada en el recurso de inconstitucionalidad. Dicho con otras palabras, el artículo 36.8 LOPSC no desconoce la vertiente del principio de tipicidad invocada en el recurso de inconstitucionalidad porque el término «perturbación», interpretado en el contexto de otras normas sancionadoras de la LOPSC (entre otros, los artículos 35.2, 36.2 y 36.3) y a la luz de los preceptos relevantes del Código penal (los artículos 557.1 y 557 bis.1.3), es un concepto jurídico indeterminado cuya concreción es razonablemente previsible en virtud de criterios lógicos, técnicos o de experiencia.”

No obstante, el propio artículo 32, ya ofrece mucha información sobre qué hay que hacer para cumplir con él y tener implantadas medidas de seguridad adecuadas para garantizar un nivel de seguridad apropiado, reduciendo así esa posible indeterminación inicial. Así, el mismo indica que para implantar dichas medidas hay que tener en cuenta *el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas* que en su caso incluya, entre otros:

- a) la seudonimización y el cifrado de datos personales;*
- b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;*
- c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;*
- d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.*

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos. (el subrayado es nuestro)

Asimismo, los preceptos que se han considerado infringidos pueden ser también interpretados en el contexto de otros preceptos del RGPD tales como los artículos 24, 25 y 35 y muchos Considerandos que se refieren a los riesgos que hay que tener en cuenta (como los Considerandos 39, 51, 71, 75, entre otros) y a las medidas que pueden implantarse (Considerandos 28, 29, 83, 94, entre otros).

Por lo expuesto, si bien inicialmente los conceptos incluidos en los preceptos que se han considerado infringidos en el presente caso pueden tener aparentemente cierta indeterminación, cierto margen de apreciación, ello no impide, a la luz de lo indicado,

que se pueda realizar una razonable interpretación de la norma y valoración, máxime cuando dicha interpretación se realiza por la AEPD debidamente motivada.

Así, en el caso que nos ocupa, una vez analizadas las circunstancias concretas del caso, se ha podido determinar sin incurrir en ningún tipo de valoración o interpretación arbitraria la falta de medidas técnicas y organizativas adecuadas, de todo tipo, incluyendo las de seguridad para garantizar, por una parte el principio de integridad y confidencialidad, y por otro, un nivel de seguridad adecuado al riesgo de los tratamientos de datos personales realizados por Telefónica(pues carecía de medidas de seguridad adecuadas y razonables en cuanto a la tecnología disponible y costes de aplicación en el momento del incidente, que hubieran impedido, cuando no minimizado o mitigado considerablemente el impacto del incidente sobre los datos personales). Para ello, en aras de no incurrir en reiteración, nos remitimos a todo lo indicado en el apartado Segundo del presente Fundamento de Derecho, donde pormenorizadamente se ha argumentado todo ello, sin arbitrariedad alguna.

5.3.- Error en la tipificación y calificación de la infracción y consecuente determinación de la sanción

Alega Telefónica no estar de acuerdo con que la infracción del artículo 5.1.f) se haya calificado como una infracción muy grave de conformidad con el artículo 72.1 y la del 32 haya sido calificada como grave, de conformidad con el artículo 73.f

A este respecto, procede señalar que el RGPD tipifica las infracciones en su artículo 83, sin calificarlas como leves, graves o muy graves.

Así, el artículo 83, en su apartado 4 determina:

4. Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43;

5. Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5,6, 7 y 9;

Sin embargo, la calificación como grave o muy grave establecida en los citados preceptos de la LOPDGDD lo son únicamente a los efectos de la prescripción de las sanciones, y no a los efectos de la calificación de las infracciones.

En cuanto a lo sostenido por Telefónica respecto de que también se ha incurrido en un error en la graduación de las sanciones propuestas, ya que se reiteran de forma constante las mismas y, en consecuencia, se duplican para las dos infracciones, lo que refleja una clara reiteración en la voluntad de agravar las dos presuntas infracciones con los mismos fundamentos, procede señalar que, respecto de la aplicación de idénticos agravantes en ambas infracciones, las circunstancias previstas en el art. 83.2 del RGPD y las dispuestas en el art. 76.2 de la LOPDGDD son las únicas que se pueden aplicar por la AEPD para cualquier infracción.

Lo determinante en este caso, respecto de las que se han tenido en cuenta, no es que coincidan en su uso, sino la fundamentación que se establezca para su consideración.

Sexta. - La conducta de Telefónica no es antijurídica

Telefónica argumenta que su conducta no ha sido antijurídica por cuanto cuenta con medidas técnicas y de seguridad diseñadas para garantizar una seguridad adecuada de los datos personales de sus clientes, así como que no se puede exigir infalibilidad de dichas medidas, sino que las mismas contribuyan a reducir el riesgo.

Frente a ello, procede remitirse nuevamente a lo ya argumentado anteriormente sobre que ha quedado probado lo contrario, la falta de medidas adecuadas, y sobre que en modo alguno se ha exigido la infalibilidad de las medidas.

Séptima. - Ausencia de culpabilidad

Alega Telefónica la falta de culpabilidad en su actuación, por cuanto no hubo intencionalidad alguna de infringir la norma y teniendo siempre voluntad de cumplimiento. Asimismo, indica que actuó de buena fe y con total diligencia profesional en la gestión del incidente

Asimismo, indica Telefónica de nuevo que la AEPD parece estar centrándose sólo en el resultado, al considerar que existe infracción por el hecho de sufrir un ataque informático, de lo cual no es responsable Telefónica, sino que los responsables de la comisión de un delito son *los autores y los cómplices*, siendo autores *quienes realizan el hecho por sí solos, conjuntamente o por medio de otro del que se sirven como instrumento* (artículo 28 del Código Penal).

Por ello, concluye Telefónica que se está ante acciones de terceros con voluntad de causar perjuicio mediante la comisión de conducta delictivas y que ella ha actuado en todo momento de buena fe y con la diligencia debida frente a circunstancias que en ningún momento estuvo en ocasión de evitar, lo que supone que estamos ante un supuesto de fuerza mayor, lo que determina la falta de responsabilidad o culpabilidad en la conducta infractora.

Frente a ello, se significa, tal y como ya se ha indica anteriormente, Telefónica pone el foco en su condición de víctima de un delito informático (ciberataque por un tercero) y que no pudo o no fue posible prevenirlo.

Frente a ello, debe señalarse, de nuevo, que en caso alguno se ha exigido una infalibilidad total de las medidas que se pueden adoptar para garantizar una protección adecuada en el tratamiento de los datos personales. Sin embargo, una vez producido el ataque, debe evaluarse la diligencia del responsable del tratamiento en la aplicación de las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, teniéndose en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, el alcance, el contexto y los fines del tratamiento.

En el presente caso, como ya se ha reiterado, Telefónica no contaba, en el momento de producirse la brecha de datos personales, con las medidas adecuadas en relación con los riesgos del tratamiento para la protección de los datos personales, pues tal y como se indicó en el Acuerdo de Inicio del presente procedimiento sancionador, y que se reseña nuevo en el apartado Segundo del presente Fundamento de Derecho y al que nos remitimos, no existían medidas adecuadas en relación con el control de accesos a la aplicación (...).

Todas estas medidas eran, en el momento del incidente, conocidas según el estado de la técnica y de costes asequibles de aplicación, lo cual pone de manifiesto una conducta negligente de Telefónica y, por tanto, culpable, sin necesidad de exigir la existencia de intencionalidad. Ello, asimismo, es contrario con la situación de fuerza mayor alegada, pues de las circunstancias del presente caso, ya expuestas reiteradamente, no se puede deducir que el ataque fuera del todo imprevisible e inevitable, pues como se ha señalado, el mismo podría haber sido evitado y, en caso contrario, desde luego mitigado su impacto considerablemente.

Por tanto, se estaba ante un riesgo conocido y, por ende, previsible, en los que, atendidas y analizadas las circunstancias concretas, se dan suficientes elementos para entender que el nivel de diligencia de Telefónica para prevenirlo o bien mitigarlo, no fue el suficientemente elevado como para descartar que su conducta no pueda calificarse como negligente.

Así, de conformidad con la Sentencia de 22 de junio de 2021- Rec. 1210/2018, y la Sentencia de 5 de noviembre de 2011 -Rec. 1796/2019, en la que se valora el elemento subjetivo o culpabilístico, se insiste en que la culpabilidad de la parte actora no puede considerarse excluida ni atenuada por el hecho de que haya mediado la actuación fraudulenta de un tercero, pues la responsabilidad de la parte actora no deriva de la actuación de éste, sino de la suya propia.

Noveno. - Incumplimiento del principio de proporcionalidad

Entiende Telefónica que en la propuesta de sanción se ha vulnerado el principio de proporcionalidad por cuanto no está de acuerdo en las agravantes tenidas en cuenta y tampoco en las circunstancias atenuantes que no se han aplicado.

En cuanto a las circunstancias agravantes tenidas en cuenta:

9.1 Naturaleza, gravedad y duración de la infracción, en relación con la infracción del artículo 5.1.f) (art. 83.2.a RGPD)

No está de acuerdo Telefónica con la aplicación de esta agravante reiterando que la pérdida de confidencialidad es el resultado del delito cometido por un tercero y que ello queda fuera de la espera de responsabilidad de Telefónica. Asimismo, indica que el incidente no ha supuesto ninguna pérdida de control irremediable sobre los datos personales de los clientes, teniendo en cuenta la categoría de datos afectados y los posibles riesgos para ellos.

En este sentido, procede remitirse a todo lo argumentado a lo largo del presente Fundamento de Derecho relativo tanto a la responsabilidad, y por ende, la culpabilidad, exigida a Telefónica no deriva de la actuación fraudulenta de un tercero, sino de su propia actuación y responsabilidad en relación con el cumplimiento del RGPD, especialmente en cuanto a medidas de seguridad se refiere.

En cuanto a que no está de acuerdo con que se tenga en cuenta el número de personas afectadas fue muy elevado, por cuanto sostiene Telefónica que los datos obtenidos no permiten que un tercero pueda identificar a dicha persona física, ya que se trata de datos que sólo son usados para soporte y mantenimiento del router de Telefónica. Asimismo, vuelve a reiterar Telefónica que ni siquiera se obtuvo el número de teléfono fijo, pues los atacantes ya contaban con ese dato, ya lo conocían.

A este respecto, en cuanto a que los datos a los que accedieron los atacantes no son datos personales, procede remitirse a todo lo ya argumentado en esta Propuesta de Resolución al respecto.

En relación a que los atacantes ya conocían, ya tenían en su poder el dato personal del número de teléfono fijo, se significa que, analizando el *modus operandis* del ataque, la realidad es que los atacantes introdujeron de forma aleatoria o secuencial números de teléfonos que, cuando coincidían con un número abonado de un cliente de Telefónica, conseguían acceder al resto de los datos personales almacenados en la aplicación. De ello no puede deducirse, como indica Telefónica, que los atacantes ya conocían y ya contaban con el dato personal del teléfono fijo, sino que lo que se deduce es que aplicaron números secuenciales o aleatorios sin saber si correspondían a un abonado, pero que cuando conseguían hacerlo coincidir con el de un número abonado, entonces sí que obtenían realmente el teléfono fijo de un cliente de la compañía y, por ende, el dato personal que el mismo supone. Prueba de ello lo es también el hecho de que de alrededor de 16 millones de consultas (teléfonos aleatorios o secuenciales usados) únicamente lograron hacer coincidir y, por ende obtener, los números de algo más de 1.400.000 clientes abonados.

En este sentido, no debe olvidarse que fue Telefónica quien indicó, en su “*Informe incidente de privacidad acceso no autorizado a ***APP.1*”, aportado el 26/10/2022 junto con la segunda notificación de brecha de datos personales a la AEPD (Número de registro: REGAGE22e00048156613), que los accesos maliciosos se produjeron *realizando peticiones a las aplicaciones internas de Telefónica utilizando numeraciones de teléfono fijo consecutivas para conseguir aquellas que fueran numeraciones de clientes de Telefónica, obteniendo datos técnicos o de configuración de los equipos Movistar asociados a la numeración fija consultada*”

Asimismo, vuelve Telefónica a argumentar que la categoría de los datos afectados no eran datos sensibles de los recogidos en el artículo 9 y que tampoco son datos cuya pérdida de control pudiera implicar graves consecuencias para los interesados.

A este respecto, procede remitirse de nuevo a lo ya argumentado anteriormente sobre los riesgos que suponen para las personas afectadas el conocimiento del número de teléfono fijo asociado a datos de configuración y del nombre de la wifi y de su contraseña, riesgos que no disminuyen por el hecho de que más de un año después, según indica Telefónica, no haya tenido constancia de ningún tipo de publicación ni explotación de estos datos por parte de terceros ajenos, pues lo que se tiene en cuenta en dicha agravante es el daño y riesgo que supone en sí mismo a pérdida de confidencialidad, que conlleva una total pérdida de control sobre los propios datos personales y el alto riesgo que conlleva de que se usen de forma fraudulenta, pues han sido sustraídos por un ciberdelincuente.

9.2. Negligencia en la infracción (artículo 83.2.b) RGPD)

Rechaza Telefónica la aplicación de esta circunstancia agravante volviendo a alegar que la AEPD concluye erróneamente que, por el hecho de haberse producido un incidente de seguridad no existían medidas adecuadas, exigiendo, por tanto, una obligación de resultados (infalibilidad de las medidas) y, en consecuencia, una responsabilidad objetiva, considerando la existencia de negligencia por el resultado provocado por terceros ajenos Telefónica, indicando de nuevo la Sentencia 543/2022 de 15 de febrero de 2022, del Tribunal Supremo.

En este sentido, procede reiterarse de nuevo a todo lo argumentado anteriormente respecto de la negligencia y responsabilidad de Telefónica en cuanto a la falta de medidas adecuadas que hubieran permitido bien impedir el ataque, bien haberlo mitigado considerablemente, poniendo ello de manifiesto el incumplimiento del deber de cuidado exigible por la ley, así como a todo lo argumentado respecto de que no se ha exigido en modo alguno una obligación de resultado analizándose la Sentencia reseñada.

9.3. Vinculación de la actividad del infractor con la realización de tratamientos de datos personales

Reprocha Telefónica que se le aplique la circunstancia de tratar datos de millones de personas como agravante sin tener en cuenta las circunstancias concretas de lo sucedido, además de que entiende que no tiene ningún sentido ni puede sustentarse jurídicamente que por el solo hecho de tratar un volumen elevado de datos, cualquier infracción que se cometa deriva en la aplicación directa y objetiva de circunstancias agravantes.

A este respecto, se significa que en dicho precepto se tiene en consideración la vinculación con la realización de tratamientos de datos personales, ya que realiza tratamientos masivos y a gran escala (de millones de clientes), a través de aplicaciones informáticas y aplicativos webs y de forma continua.

En este sentido, el legislador español ha considerado incluir en el artículo 76 de la LOPDGGD que: “2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

(...)

b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.”

Esta Agencia simplemente toma en consideración esa circunstancia, prevista por el legislador, a la hora de decidir la imposición de la multa administrativa.

En cuanto a las atenuantes que entiende Telefónica deberían haber sido apreciadas:

9.4. La intencionalidad o negligencia en la infracción (art. 83.2.b RGPD)

Entiende Telefónica que como no concurre en el presente caso los requisitos de intencionalidad en la comisión de las infracciones o una actitud negligente, sino más bien la diligencia demostrada por ella, debería tenerse en cuenta como atenuante.

Frente a ello, procede señalar dos cosas. En primer lugar, ha quedado argumentado a lo largo de esta Propuesta de Resolución que, si bien no ha existido intencionalidad, sí ha existido una actuación negligente por parte de Telefónica. Debe tenerse en cuenta que «no intencional» significa que no hubo intención de causar la infracción, pero sí incumplió el deber de cuidado exigido por la ley.

En segundo lugar, que esta circunstancia, establecida en el apartado b del artículo 83.2 del RGPD, sólo puede, en su caso, operar como circunstancia agravante, por cuanto la ausencia de intencionalidad y de negligencia supondría directamente la ausencia de culpabilidad.

Llegados a este punto, procede aclarar que una cosa es que, para poder imputar una infracción administrativa sea necesario la existencia de intención o negligencia y otra, que pueda utilizarse como agravante la existencia de una negligencia especialmente puesta de relieve, por las circunstancias del caso. Lo opuesto sería contrario al propio artículo 83.2.b) que establece que “Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

b) la intencionalidad o negligencia en la infracción”

Así, como se ha señalado, en cualquier infracción de la normativa en materia de protección de datos ha de concurrir la existencia de intencionalidad o de negligencia. Y ello tanto a un responsable de tratamiento persona física, como persona jurídica, ya sea una pequeña empresa con poca vinculación con el tratamiento de datos personales, ya sea una gran empresa, una multinacional, etc, y con tratamientos de datos personales de forma continua y a gran escala, por ejemplo.

Por tanto, una vez determinado que, como premisa, concurre este elemento subjetivo culpabilístico de base, ello no obsta que se pueda considerar esta circunstancia como agravante por considerar que, de conformidad con las circunstancias concretas del caso, se considere un diferente grado de intencionalidad o de negligencia en el actuar del sujeto infractor. Pero, en ningún caso, esta circunstancia puede considerarse como

un atenuante en el sentido que argumenta Telefónica por cuanto, como se ha dicho, supondría.

9.5. Cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados (artículo 83.2.c)

Alega Telefónica que procedió a comunicar a todos los interesados lo sucedido, indicándoles las medidas que debían adoptar.

En este sentido, debe señalarse que comunicar la brecha de datos personales en el caso de un probable riesgo alto para los derechos y libertades de los afectados es una obligación impuesta por el RGPD en su artículo 34, cuya infracción es susceptible de un procedimiento sancionador ulterior.

Asimismo, procede recordar que Telefónica no procedió motu proprio a comunicar la brecha de datos personales a los afectados, sino que procedió a comunicar a todos los afectados como obligación impuesta por esta Agencia mediante Resolución de 30 de septiembre de 2022, por la que se le ordena que lleve a cabo la comunicación de la brecha de datos personales a los interesados conforme al artículo 34 del Reglamento, ante la negativa mostrada por Telefónica de realizarlo.

Por lo expuesto, no procede tener esta circunstancia como atenuante de la responsabilidad en la que se ha incurrido.

9.6. Las categorías de los datos de carácter personal afectados por la infracción (art. 83.2. g) RGPD)

Alega Telefónica que como no han sido afectados datos personales de categorías especiales de datos del artículo 9 del RGPD, y que sólo eran datos de configuración de algunos equipos de conectividad, sin permitir la identificación directa del interesado, debe aplicarse esta circunstancia como atenuante.

Frente a ello se significa que el artículo 83.2.g) indica como circunstancia para graduar la sanción “*Las categorías de los datos de carácter personal afectados por la infracción*”, tratándose, por tanto, de una circunstancia a tener en cuenta en función de la tipología o categoría de los datos afectados, que se aplicaría como agravante, por ejemplo, si se han visto afectadas categorías especiales de datos, pero no está circunscrito únicamente a las categorías especiales de datos, pues es susceptible de aplicarse también como agravante dependiendo de la tipología de los datos afectados.

En el presente caso, teniendo en cuenta la naturaleza de los datos personales afectados por la brecha (cuyo riesgo es mucho mayor y desdeña Telefónica) y el considerable número de personas afectadas por la misma, con el probable alto riesgo de su uso fraudulento y el riesgo alto para los derechos y libertades de los afectados, no procedería en ningún caso ser tomada en consideración como un atenuante.

9.7. La forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida. (art. 83.2.h RGPD)

Sostiene Telefónica que fue ella la que puso en conocimiento de la AEPD la existencia de este incidente dentro del plazo legalmente establecido.

A este respecto, procede señalar que no puede considerarse ello un atenuante toda vez que notificar a esta Agencia la existencia de una brecha de datos personales y sin dilación indebida es de obligado cumplimiento conforme a lo dispuesto en el artículo 33 del RGPD. La consideración de la notificación a la Agencia de la brecha como atenuante, tal y como pretende Telefónica, no está ligada a ninguno de los supuestos en los que pueda existir una obligación por mor de un mandato legal, cuando las actuaciones son debidas y obligadas por la Ley, como en el caso que nos ocupa.

9.8. Beneficios financieros obtenidos o las pérdidas evitadas directa o indirectamente a través de la infracción.

Alega Telefónica que no obtuvo ningún beneficio financiero, sino que fue víctima de un delito que le ha provocado daños reputacionales.

Frente a ello, procede señalar que, sobre este criterio, el artículo 76.2 de la LOPDGDD, en su letra c), incluye entre los criterios que deben sopesarse a la hora de fijar la cuantía de la sanción “los beneficios obtenidos como consecuencia de la comisión de la infracción” y no la ausencia de estos beneficios. La Sentencia de la Audiencia Nacional, de 05/05/2021, se refiere a la necesidad de que concurra el “presupuesto” de hecho contemplado en la norma para que pueda aplicarse un determinado criterio de graduación, y, como se ha dicho, la ausencia de beneficios no está entre las circunstancias reguladas en el artículo citado.

Este criterio de graduación se establece en la LOPDGDD de acuerdo con lo previsto en el artículo 83.2.k) del RGPD, según el cual las multas administrativas se impondrán teniendo en cuenta cualquier “factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”, entendiéndose que evitar una pérdida tiene la misma naturaleza a estos efectos que la obtención de beneficios.

Si a esto añadimos que las sanciones deberán ser “en cada caso individual” efectivas, proporcionadas y disuasorias, conforme a lo previsto en el artículo 83.1 del RGPD, admitir la ausencia de beneficios como una atenuante no solo es contrario a los presupuestos de hechos contemplados en el artículo 76.2.c), sino también contrario a lo establecido en el artículo 83.2.k) del RGPD y a los principios señalados. Así, valorar la ausencia de beneficios como una atenuante anularía el efecto disuasorio de la multa, en la medida en que minora el efecto de las circunstancias que inciden efectivamente en su cuantificación, reportando al responsable un beneficio al que no se ha hecho merecedor. Sería una rebaja artificial de la sanción que puede llevar a entender que infringir la norma sin obtener beneficios, financieros o del tipo que fuere, no le producirá un efecto negativo proporcional a la gravedad del hecho infractor. En todo caso, las multas administrativas establecidas en el RGPD, conforme a lo

establecido en su artículo 83.2, se imponen en función de las circunstancias de cada caso individual y, en el presente, no se estima que la ausencia de beneficios sea un factor de graduación adecuado y determinante para valorar la gravedad de la conducta infractora.

Como consideración general y final, procede señalar que ninguna de las sanciones aplicadas vulnera el principio de proporcionalidad. Así, debe recordarse que los artículos 83.4 y 83.5 del RGPD, donde se encuentran tipificadas respectivamente la infracción del artículo 32 y la del artículo 5.1.f), establecen unos límites en las cuantías de las multas que se pueden imponer muy alejados de las que finalmente se han establecido.

Así, el artículo 83.4 del citado Reglamento, establece que se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía. A este respecto, de conformidad con el informe recogido de la herramienta AXESOR, el volumen de negocios para 2021 de Telefónica fue de *****CANTIDAD.1** de euros, lo que hubiera permitido imponer una sanción de hasta *****CANTIDAD.2** de euros, por la infracción del artículo 32.

Por su parte, el artículo 83.5 del RGPD establece que se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía. A este respecto, de conformidad con el volumen de negocios indicado, hubiera permitido imponer una sanción de hasta *****CANTIDAD.3** de euros, por la infracción del artículo 5.1.f).

Por tanto, teniendo en cuenta lo anterior, así como la negligencia de Telefónica al no tener implantadas medidas adecuadas control de accesos a un aplicativo publicado en internet (doble factor de verificación; bloqueo de accesos desde direcciones IP sospechosas o no confiables), así como medidas tendentes a generar alertas y bloqueos ante situaciones totalmente anómalas, no generándose ninguna alerta o evento de seguridad, con advertencia inmediata al CSIRT-TE de que se estaban produciendo durante 4 días unas solicitudes masivas muy superiores a las habituales (de 55.000 al día a 4 millones diarias) y además desde un único usuario, lo cual es reflejo de una clara conducta anómala y sospechosa de ser maliciosa,. Asimismo, tampoco se detectó el ataque sufrido entre los días 9 al 11 de septiembre de 2022 y que afectaron a datos personales de más de medio millón de personas clientes de Telefónica.

Por tanto, no puede decirse que las sanciones finalmente impuestas vulneren el principio de proporcionalidad, teniendo en cuenta que “Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 5 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias”. (el subrayado es nuestro)

V Alegaciones a la propuesta de resolución

En respuesta a las alegaciones presentadas por Telefónica se debe señalar, según el orden expuesto, lo siguiente:

Antes de dar respuesta a lo alegado frente a la propuesta de resolución, se indica que, dada la reiteración en las argumentaciones presentadas respecto a las aducidas frente al acuerdo de inicio y en aras a no reiterarse, se dan por reproducidas las mismas.

Previa. Sobre la continuación del presente expediente sancionador.

En relación con esta alegación se procede a reiterar que, tal y como se ha venido señalando a lo largo de todo el procedimiento, no se considera que se haya cumplido con la normativa en materia de protección de datos. Y es que no es cierto que los datos afectados en el incidente objeto del presente expediente no tengan el carácter de datos personales. Parece preciso manifestar nuevamente que la propia definición de datos personales dada en el artículo 4 del RGPD recoge como tales *toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona.*

De ello se desprende que el concepto de dato personal requiere la concurrencia de un doble elemento: por una parte, la existencia de una información o dato y, por otra, que dicho dato pueda vincularse a una persona física identificada o identificable.

No ha lugar a dudas, por tanto, del carácter de dato personal que ostenta el teléfono fijo que permite identificar a su titular o el resto de datos que se vieron afectados en esta brecha que asimismo permiten identificarlo.

Asimismo, se insiste en que, dado que el ataque realizado usando números de teléfono fijo consecutivos (o aleatorios) supuso más de 16 millones de solicitudes, de las que consiguió el acceso a los datos personales de 1.407.257 de clientes cuando el número de teléfono fijo coincidía con el de un cliente de Telefónica, no hace sino poner de manifiesto que no conocía previamente esas numeraciones de teléfonos fijos. No obstante, y a mayor abundamiento, a la vista de lo que sucedió, no resulta relevante si conocía previamente o no los teléfonos fijos de los clientes de Telefónica, ni tampoco en cómo se produjo el ataque concreto en cuanto a la forma de realizar las consultas y a los datos a los que no pudo acceder el atacante, o si, como afirma Telefónica, fue muy sofisticado y con conocimientos previos de datos de los empleados, etc., sino que lo relevante es que con las credenciales de un único empleado de Telefónica (usuario y contraseña), que hay que recordar, se encontraba de vacaciones, realizó consultas masivas a la aplicación afectada (pasando de las 50.000 consultas diarias a 4 millones de consultas diarias y por un único usuario), desde Lituania, consiguiendo finalmente datos personales de más de 1.400.000 clientes, pudiendo haberse evitado el mismo con la existencia de alguna alternativa tecnológica que lo hubiera impedido, como por ejemplo un doble factor de verificación para los usuarios empleados de Telefónica, y

también de cualquier otra medida que actuara ante peticiones masivas de información, que detectara flujos de información totalmente inhabituales y extraordinarios, que hubieran permitido o cuando menos, mitigado muy considerablemente el impacto del mismo si hubiesen existido medidas de control y monitorización que hubiesen detectado y alertado del ataque de forma temprana, tal y como se indicará de forma más pormenorizada más adelante.

Por otra parte, y en relación con las afirmaciones vertidas por Telefónica conforme a las cuales la AEPD no ha tenido en cuenta las medidas existentes en el momento en el que se produjo la brecha, sino que viene a considerar como válidas únicamente las sugeridas por ella en la propuesta de resolución hay que aclarar que no es esta la intención de esta Agencia. Lo que se ha plasmado a lo largo del procedimiento es que las medidas con las que contaba Telefónica no garantizaban ni el principio de integridad y de confidencialidad previsto en el art. 5.1.f) del RGPD ni garantizaban un nivel de seguridad adecuado, procediendo a citar distintos ejemplos de medidas que podían haber coadyuvado a alcanzar dicho nivel. En este sentido, parece necesario precisar que en ningún momento se ha determinado por esta Agencia la oportunidad de bloquear arbitrariamente el acceso desde una IP extranjera, sino que lo que se ha sugerido es el establecimiento de sistemas que permitieran bloquear eficazmente conexiones potencialmente inseguras denegando, por defecto, el tráfico entrante para aquellos orígenes que no fueran necesarios para la prestación de los servicios de la entidad. A ello se añade el hecho de que, aun cuando alega que necesita contar con acceso a sus redes desde IPs extranjeras debido a que bien sus trabajadores bien empresas subcontratadas necesitan hacer uso de ello en ningún momento queda probada dicha necesidad en relación con el país desde el que se originó el incidente más allá de la mera afirmación genérica referida a territorios no nacionales.

Primera. Aclaración sobre la descripción de hechos probados realizada por la AEPD.

Respecto a la primera de las afirmaciones realizada sobre la fecha del incidente, se reiteran las afirmaciones vertidas en la propuesta de inicio y recogidas en los hechos probados. Y ello por cuanto, tal y como consta en el expediente, el día 16 de septiembre de 2022 ya hubo un incremento masivo de consultas que no fue detectado y corregido hasta el día 20, tal y como la propia Telefónica reconoce. Consecuentemente, transcurrieron cuatro días desde que se produjo el primer incidente hasta que se empezaron a llevar a cabo medidas.

Segunda. Del incidente en *APP.1 y las medidas de seguridad: Telefónica contempla medidas técnicas y organizativas que resultan apropiadas para garantizar una seguridad adecuada de los datos personales de sus clientes, incluida la protección contra el tratamiento no autorizado o ilícito.**

A este respecto se reitera lo ya indicado en a lo largo del procedimiento sancionador.

A lo anterior cabe añadir que es claro que, conforme a la normativa de protección de datos, el responsable del tratamiento está obligado a tratar los datos personales de tal modo que garantice el principio de integridad y confidencialidad previsto en el artículo 5.1.f) del RGPD, “incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental”, mediante la aplicación de medidas

técnicas u organizativas apropiadas. Esta garantía impuesta por el ordenamiento jurídico se ha de lograr a través de la aplicación de medidas técnicas u organizativas apropiadas, de todo tipo. No son estrictamente o sólo medidas de seguridad. Diversas y múltiples son las medidas técnicas y organizativas que no son de seguridad y que puede implementar el responsable del tratamiento como cauce para garantizar este principio. Así, se ha citado anteriormente, a título de ejemplo, la medida “no de seguridad” consistente en concienciar y formar a los empleados en materia de protección de datos.

El cumplimiento de las obligaciones en materia de protección de datos exige que el responsable del tratamiento focalice en los riesgos en los derechos y libertades de los interesados que los tratamientos de datos personales pueden llevar aparejados, identificándoles, evaluándoles y valorándoles a los efectos de determinar las medidas técnicas y organizativas apropiadas de todo tipo (no sólo medidas de seguridad) para evitar que dichos riesgos, en muchas ocasiones muy graves, irreparables e irreversibles, se materialicen en daños para los interesados.

En muchas ocasiones las medidas estrictas de seguridad de la información (sólo de la información) se confrontan con las medidas técnicas y organizativas apropiadas de todo tipo, incluidas las específicas de seguridad, de protección de datos, hasta el punto de que aplicadas unas pueden chocar con las otras.

Así, por ejemplo, esta confrontación se puede producir en el marco del Esquema Nacional de Seguridad (ENS), regulado en el Real Decreto 311/2022. Recordemos que, para justificar un correcto análisis de riesgos respecto del supuesto examinado y la correlativa adopción de medidas de seguridad adecuadas en materia de protección de datos, Telefónica aduce el cumplimiento, de entre otros certificados, del ENS.

Pues bien, el ENS tiene por objeto la seguridad de la información, tal y como dispone el art. 1.2 del Real Decreto citado y no la protección de datos personales.

Por otro lado, sólo resulta aplicable a entidades privadas, como Telefónica, en tanto en cuanto, tal y como se determina en su artículo 2.3 “... cuando, de acuerdo con la normativa aplicable y en virtud de una relación contractual, presten servicios o provean soluciones a las entidades del sector público para el ejercicio por estas de sus competencias y potestades administrativas”.

Además, en tales supuestos tasados por el ordenamiento jurídico -una entidad del sector privado que mantiene una relación contractual con una entidad del sector público prestándole un servicio o una solución-, el cumplimiento del ENS no es genérico ni general, sino que sus previsiones han de cumplirse para tratamientos de datos personales concretos, al corresponderse las medidas de seguridad con las de la entidad del sector público que se trate y acorde con el ENS. Y ello porque la DA 1ª de la LOPDGGD, establece: “Disposición adicional primera. Medidas de seguridad en el ámbito del sector público... En los casos en los que un tercero preste un servicio en régimen de concesión, encomienda de gestión o contrato, las medidas de seguridad se corresponderán con las de la Administración pública de origen y se ajustarán al Esquema Nacional de Seguridad.”.

A lo anterior se ha de sumar, como indicábamos previamente, que cumplir con el ENS no implica cumplir con el RGPD, puesto (i) el cumplimiento del ENS no exime el cumplimiento de las obligaciones (distintas) en materia de protección de datos y que (ii) las medidas resultantes del ENS pueden confrontarse con las del RGPD (prevaleciendo estas últimas), lo que se pone de manifiesto en el artículo 3 del Real Decreto citado:

“Artículo 3. Sistemas de información que traten datos personales.

1. Cuando un sistema de información trate datos personales le será de aplicación lo dispuesto en el Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento General de Protección de Datos) y en la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, o, en su caso, la Ley Orgánica 7/2021, de 26 de mayo, de protección de datos personales tratados para fines de prevención, detección, investigación y enjuiciamiento de infracciones penales y de ejecución de sanciones penales, el resto de normativa de aplicación, así como los criterios que se establezcan por la Agencia Española de Protección de Datos o en su ámbito competencial, por las autoridades autonómicas de protección de datos, sin perjuicio de los requisitos establecidos en el presente real decreto.

2. En estos supuestos, el responsable o el encargado del tratamiento, asesorado por el delegado de protección de datos, realizarán un análisis de riesgos conforme al artículo 24 del Reglamento General de Protección de Datos y, en los supuestos de su artículo 35, una evaluación de impacto en la protección de datos.

3. En todo caso, prevalecerán las medidas a implantar como consecuencia del análisis de riesgos y, en su caso, de la evaluación de impacto a los que se refiere el apartado anterior, en caso de resultar agravadas respecto de las previstas en el presente real decreto.”

Sin perjuicio de no denostar la importancia que las medidas de seguridad de la información suponen para una empresa atendiendo a los riesgos de su organización (proteger sus activos, evitar pérdida de información relacionada con la propiedad industrial o el secreto comercial, o demandas por perjuicios, etc.), no podemos obviar que las medidas técnicas y organizativas apropiadas de todo tipo de protección de datos responden a la protección de las personas físicas y del derecho fundamental a la protección de datos del que son titulares.

Sin el debido enfoque, como se ha puesto de manifiesto a lo largo de este procedimiento, resulta imposible que se detecten los riesgos realmente previstos en el tratamiento de datos personales, pues donde no se mira no se ve.

Telefónica afirma que la pérdida de control de la información por el sistema no genera un alto riesgo para los derechos y libertades de los usuarios sin tener en cuenta que cualquier pérdida de control sobre los propios datos personales se traduce, necesariamente, en una vulneración del derecho fundamental a la protección de datos reconocido en el artículo 18. 4 de la Constitución Española, pues tal y como ha indicado el Tribunal Constitucional (Sentencia 292/2000, de 30 de noviembre de 2000): *“el derecho fundamental a la protección de datos persigue garantizar a la persona un*

poder de control sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y lesivo para la dignidad y derecho del afectado (...)”, toda vez que el derecho a la protección de datos garantiza a los individuos un poder de disposición sobre esos datos, que solo pueden estar en manos de personas autorizadas por alguna base de licitud prevista en la normativa de protección de datos. Se insiste en que conocer un número de teléfono genera una serie de riesgos, como pueda ser su uso para llamar a su titular o contactar con él mediante sms, etc y mediante phishing o ingeniería social conseguir más datos identificativos (domicilio) y al tener, además, el nombre de la wifi y las contraseñas, entrar en la misma y suplantar identidad, utilizarlos para fraude, estafa informática, etc. Imaginemos si la wifi y la contraseña corresponden, no a una persona anónima, sino a una personalidad importante del país. Se desconoce a todo punto qué información o datos estaba “buscando” el delincuente y qué otros tenía en su poder, mas estas cuestiones también deben considerarse en el análisis de riesgos, independientemente de la categorización del riesgo.

Incluso en el supuesto de que, tal y como sostiene Telefónica, se pudiera aceptar que la probabilidad acceder a la wifi de los usuarios clientes es baja, el impacto de ello es muy alto sobre los derechos y libertades de las personas: robo identidad, comisión de delitos a través de esa wifi que se imputarían al titular de la línea, hackeo de dispositivos conectados a esa wifi y obtener datos como de salud, de rutinas, consumos, etc., por lo que el riesgo final no puede considerarse bajo.

Así, a simple vista y sin grandes esfuerzos se observa la presencia, por ejemplo, de un riesgo respecto del derecho fundamental al secreto de las comunicaciones que no ha sido ni identificado ni analizado.

Tercera. Superación de la esfera de responsabilidad de Telefónica: circunstancias excepcionales que han hecho posible la superación por terceras personas de las políticas de seguridad implantadas.

A este respecto, y puesto que no se han aportado nuevos argumentos a los ya respondidos en la propuesta, se procede a reiterar lo ya indicado en respuesta a las alegaciones presentadas frente al acuerdo de inicio.

Cuarta. Sobre las cuestiones previas que han sido planteadas por la AEPD en el marco de este expediente.

En su alegación cuarta, Telefónica descarta la aplicabilidad del Dictamen 13/2011 al que aludía esta Agencia en la propuesta por venir referido a la geolocalización en los dispositivos móviles sin tener en cuenta que, aun cuando en el presente caso la información afectada viniera referida esencialmente a los servicios de geolocalización en los dispositivos móviles inteligentes, tal y como indican, en él se concluye sin lugar a la duda el carácter de dato personal que debe recibir la información relativa a la dirección MAC puesto que hace identificable a la persona física.

Por otro lado, sorprende el extracto resaltado por la parte infractora del Auto emitido por el Juzgado pues, como bien debe saber, el hecho de que no se proceda a una imputación penal por no concurrir los requisitos para ello, en concreto en este caso, la existencia de una denuncia previa para poder imputar a un sujeto un delito de

revelación de secretos, no conlleva necesariamente la inexistencia de un incumplimiento de carácter administrativo.

Quinta. Sobre las presuntas infracciones cometidas por parte de Telefónica: vulneración del principio de tipicidad.

Nuevamente, y en aras a no repetirse, se procede a reiterar lo ya señalado a este respecto en la propuesta de resolución.

En relación con la inaplicabilidad de lo dispuesto en el artículo 5.1.f) al caso objeto del expediente, parece necesario aclarar nuevamente tanto su redacción como su aplicabilidad. Y es que lo que determina el artículo 5.1.f) del Reglamento es un principio mediante el cual se atribuye al responsable de cualquier tratamiento de datos personales la obligación, la garantía, de impedir tratamientos no autorizados o ilícitos de estos datos, su pérdida o destrucción. Dicho de otro modo, un responsable del tratamiento no debe tratar datos personales si no está en disposición de garantizar la confidencialidad e integridad de estos e impedir que un tercero acceda a datos que no le conciernen, así como evitar su pérdida o destrucción.

En virtud de lo antedicho, el responsable del tratamiento está obligado a tratar los datos personales de tal modo que garantice una seguridad adecuada, “incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas”.

El acceso no autorizado a datos personales por un tercero supone que éstos puedan ser utilizados para usos no conocidos, incluso fraudulentos, conllevando una pérdida total y absoluta de control sobre los mismos.

Esta pérdida de control sobre los propios datos personales se insiste, supone una vulneración del derecho fundamental a la protección de datos reconocido en el artículo 18. 4 de la Constitución Española, pues tal y como ha indicado el Tribunal Constitucional (Sentencia 292/2000, de 30 de noviembre de 2000): “el derecho fundamental a la protección de datos persigue garantizar a la persona un poder de control sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y lesivo para la dignidad y derecho del afectado (...)”, toda vez que el derecho a la protección de datos garantiza a los individuos un poder de disposición sobre esos datos, que solo pueden estar en manos de personas autorizadas por alguna base de licitud prevista en la normativa de protección de datos.

Asimismo, la pérdida o destrucción de los datos personales también puede producir perjuicios al interesado, como la falta de prestación de un servicio (pensemos en un servicio sanitario) o la prestación incorrecta de dicho servicio (si no se cuenta con todos los datos personales del interesado).

Sobre las eventuales consecuencias de una pérdida de confidencialidad y de integridad, se ha de citar las contenidas en el Dictamen 03/2014 sobre la notificación de violación de datos personales del Grupo de Trabajo del Artículo 29.

La garantía impuesta por el ordenamiento jurídico se logrará a través de la aplicación de medidas técnicas u organizativas apropiadas, de todo tipo. No son estrictamente o

sólo medidas de seguridad. Diversas y múltiples son las medidas técnicas y organizativas que no son de seguridad y que puede implementar el responsable del tratamiento como cauce para garantizar este principio.

En este sentido, la referida la Guía de la AEPD sobre “Gestión del riesgo y evaluación de impacto en tratamientos de datos personales”, dispone que, “Como interpreta la Declaración WP218, hay que subrayar que abordar los riesgos que pudiera entrañar un tratamiento de datos para los derechos y libertades de las personas no puede limitarse a aplicar exclusivamente medidas de seguridad. Por lo tanto, la gestión de los riesgos de seguridad es una más de las actividades para la gestión de los riesgos para los derechos y libertades y se tiene que supeditar a esta última. Además, desde el punto de vista del RGPD, las medidas de mitigación han de estar orientadas a reducir el impacto y la probabilidad de que las brechas de datos personales afecten al interesado”.

Si sólo se tuvieran en consideración en relación con el art. 5.1.f) del RGPD las medidas de seguridad, sería tanto como simplificar la esencia del RGPD cuyo cumplimiento no se limita a la implantación de medidas técnicas y organizativas de seguridad; significaría, en nuestro caso, reducir la garantía exigida mediante el principio de integridad y confidencialidad a su logro únicamente con medidas de seguridad. Por supuesto que las medidas técnicas u organizativas adecuadas a las que hace mención el art. 5.1.f) del RGPD pueden ser medidas de seguridad, pero no únicamente.

Se puede producir una vulneración de este precepto, una pérdida de confidencialidad o integridad, sin ausencia o deficiencia de las medidas de seguridad.

Y es que las medidas técnicas y organizativa apropiadas de todo tipo que deben aplicarse para garantizar una el principio de integridad y confidencialidad en los términos del artículo 5.1.f) del RGPD, ninguna es citada por Telefónica en relación con la brecha de datos personales ni en sus alegaciones ni en la documentación aportada a lo largo del procedimiento sancionador. Y es que el análisis de los riesgos que ha llevado a cabo Telefónica, tal y como se pone de manifiesto en sus alegaciones, se centra en riesgos para la seguridad de la información en relación con la organización y no en los riesgos en los derechos y libertades de los interesados derivados del tratamiento de datos personales.

Con el enfoque de riesgos incorrecto y no centrado en los derechos y libertades de los interesados, difícilmente se van a identificar, evaluar y valorar los riesgos del tratamiento, de lo que se determinará qué concretas medidas técnicas y organizativas de todo tipo se deben implementar en la organización para evitar la pérdida de integridad y confidencialidad de los datos personales.

Todas las medidas a las que hace referencia Telefónica en su descargo son de seguridad, en concreto, además, de seguridad de la información (enfoque de riesgos en la organización). Sin embargo, son múltiples las medidas técnicas y organizativas apropiadas que, en atención a los riesgos en los derechos y libertades presentes en un tratamiento de datos personales, puede implementar una organización y que no son de seguridad (ni de seguridad de la información), a través de las cuales puede el responsable del tratamiento garantizar el principio de integridad y confidencialidad. Por

ejemplo, citaremos una genérica (pues no contamos con un análisis de riesgos elaborado por Telefónica en los términos del art. 5.1.f) del RGPD) aplicable a cualquier responsable tratamiento es la relativa a la concienciación y formación de los empleados en materia de protección de datos, que no únicamente en materia de seguridad.

Telefónica tampoco ha mencionado con posterioridad medidas técnicas y organizativas apropiadas que haya implantado en relación con el art. 5.1.f) del RGPD que no sean estrictamente de seguridad.

No se puede, por tanto, estar de acuerdo con las afirmaciones vertidas por Telefónica acerca de la no vulneración de lo dispuesto en el artículo 5.1.f) ya que la pérdida de confidencialidad es clara en el asunto que nos ocupa.

Por otro lado y en cuanto a la necesidad de que no existieran medidas técnicas y organizativas de seguridad se procede a indicar que, para que se produzca una vulneración del art. 32 del RGPD, el responsable del tratamiento no debe de haber establecido medidas de seguridad adecuadas al nivel de riesgo en relación con un tratamiento concreto, incluyendo, no sólo supuestos de la falta de implementación de medidas de seguridad sino también aquellos supuestos en que las medidas de seguridad son superadas (quiebra de las medidas de seguridad).

En este sentido, la STS de 15 de febrero 2022 (Rec. 7359/2020) indica que *“No basta con diseñar los medios técnicos y organizativos necesarios también es necesaria su correcta implantación y su utilización de forma apropiada, de modo que también responderá por la falta de la diligencia en su utilización, entendida como una diligencia razonable atendiendo a las circunstancias del caso”*.

En el presente caso, se insiste, no se trata de que no existieran medidas de seguridad, sino que éstas no eran adecuadas para garantizar un nivel de seguridad adecuado al riesgo, teniendo en cuenta la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas. Tal y como ya se expuso en la propuesta, no existían medidas suficientes para garantizar la seguridad, citando como posibles ejemplos el establecimiento de un doble factor de verificación para el acceso a los datos personales recogidos en la aplicación *****APP.1** o la posibilidad de bloquear a los usuarios en caso de accesos masivos en un breve espacio de tiempo, o medidas dirigidas a monitorizar el funcionamiento y generar eventos de seguridad de forma automática.

No se puede olvidar que, Telefónica no detectó nada de esas consultas masivas que generaron un tráfico extraordinario (de 55.000 consultas diarias a 4 millones por día por un único usuario (lo que también es totalmente excepcional) que estaba de vacaciones y desde de Lituania) y que deberían de haber hecho saltar todas las alarmas (de haber existido) durante el ataque realizado entre los días 9 y 11 de septiembre de 2022 y tampoco se generaron alertas o avisos tempranos en el ataque sufrido entre los días 16 y 20 de septiembre que le hubieran permitido acometer de forma inmediata medidas tendentes a paliar el ataque (por ejemplo, bloqueo del usuario/s comprometidos; bloqueo de la IP extranjera desde la que se estaba atacando) y mitigar así considerablemente el impacto del ataque, en el cual, finalmente, se vio afectada la confidencialidad de los datos personales de más de

1.400.000 personas. Incluso una medida sencilla, perfectamente al alcance de Telefónica, como es el ***MEDIDA.2 hubiera impedido la brecha de datos personales acaecida.

En lo referente a una supuesta imputación de una responsabilidad objetiva, precisar que esta no se impone por el RGPD ni consecuentemente es exigida por la AEPD.

La obligación de confidencialidad que el artículo 5.1.f) del RGPD impone al responsable del tratamiento es una obligación de resultado, de tal manera que para que el precepto se encuentre infringido es preciso que se quiebre la confidencialidad de los datos (lesión de un bien jurídico protegido). Y ello a diferencia de la obligación de seguridad que impone al responsable del tratamiento el artículo 32 del RGPD.

Mas, en ninguno de los dos casos, la responsabilidad es objetiva.

Como precisa la STS de 15/02/2022 (rec. de casación 7359/2020) "En las obligaciones de medios el compromiso que se adquiere es el de adoptar los medios técnicos y organizativos, así como desplegar una actividad diligente en su implantación y utilización que tienda a conseguir el resultado esperado con medios que razonablemente puedan calificarse de idóneos y suficientes para su consecución, por ello se las denomina obligaciones "de diligencia" o "de comportamiento". (El subrayado es nuestro)

Tal y como se ha acreditado y argumentado a lo largo del presente procedimiento sancionador, Telefónica (i) no contaba con medidas técnicas y organizativa apropiadas para garantizar el principio de integridad y confidencialidad en los términos del artículo 5.1.f) del RGPD, esto es que los datos personales fueran, tratados de tal manera que se garantizara una seguridad, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, y (ii) no contaba con medidas técnicas y organizativas apropiadas que garantizaran un nivel de seguridad adecuado al riesgo, teniendo en cuenta la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, conforme prescribe el artículo 32 del RGPD.

Hay que destacar que no existían ni estaban implementadas medidas técnicas y organizativas estrictamente de seguridad del artículo 32 del RGPD, con lo que se ha producido la infracción de este precepto de manera independiente y con carácter previo a la producción de la brecha de datos personales acaecida.

Al respecto, esta Agencia desea señalar que de ninguna manera considera que la obligación de implementación de medidas técnicas y organizativas de todo tipo, incluyendo las de seguridad impuestas por la normativa de protección de datos tenga una naturaleza de obligación de resultado y no de medios. Pero no es menos cierto que Telefónica no contaba, antes de que se produjera el incidente, con medidas apropiadas en los términos antes expuestos.

Por otro lado, y en relación con lo alegado respecto a la redacción de la normativa de aplicación y su insistencia se reitera igualmente lo ya dicho en la respuesta a su alegaciones dada en la propuesta de resolución, A ello cabe añadir que, en todo caso

ha sido el legislador comunitario quien ha incluido en la norma conceptos jurídicos indeterminados, y no la AEPD, con lo que la eventual inseguridad jurídica en relación con la redacción del RGPD ha de imputarse a aquellos y no a la AEPD.

Ello no obsta para que, aun cuando inicialmente los conceptos incluidos en los preceptos que se han considerado infringidos en el presente caso pueden tener aparentemente cierta indeterminación, cierto margen de apreciación, se pueda realizar una razonable interpretación de la norma y valoración, máxime cuando dicha interpretación se realiza por la AEPD debidamente motivada.

Interpretación primigenia que, por cierto, correspondía a Telefónica, quien al ser el responsable del tratamiento es quien estaba obligado a cumplir el RGPD integrando los conceptos jurídicos indeterminados del mismo en la realidad de sus tratamientos de datos personales, en atención a los riesgos en los derechos y libertades de los interesados presentes en los mismo y a determinar e implementar las medidas apropiadas de todo tipo para evitar su materialización.

Y ello teniendo en consideración tanto el principio de responsabilidad proactiva, al que está obligado por mor del 5.2 del RGPD y el enfoque de riesgos.

Así, la responsabilidad proactiva implica la implantación de un modelo de cumplimiento y de gestión del RGPD que determina el cumplimiento generalizado de las obligaciones en materia de protección de datos. Comprende el análisis, planificación, establecimiento, mantenimiento, actualización y control de las políticas de protección de datos en una organización, especialmente si es una gran empresa, -entendidas como el conjunto de directrices que rigen la actuación de una organización, prácticas, procedimientos y herramientas, entre otros-, desde la privacidad desde el diseño y por defecto, que garanticen el cumplimiento del RGPD, que eviten la materialización de los riesgos y que permitan al responsable demostrar su cumplimiento.

Pivota sobre la gestión del riesgo en los derechos y libertades de los interesados respecto del tratamiento de datos personales que lleve a cabo un responsable del tratamiento.

Tal y como ha señalado reiteradamente la AEPD (Informe 17/2019, entre otros muchos) y se recoge en la Exposición de motivos de la LOPDGDD: *“la mayor novedad que presenta el Reglamento (UE) 2016/679 es la evolución de un modelo basado, fundamentalmente, en el control del cumplimiento a otro que descansa en el principio de responsabilidad activa, lo que exige una previa valoración por el responsable o por el encargado del tratamiento del riesgo que pudiera generar el tratamiento de los datos de carácter personal para, a partir de dicha valoración, adoptar las medidas que procedan”*.

De esta forma, comprendiendo realmente lo que es e implica el RGPD, en un sistema de gestión de riesgos es lógico que la norma comprenda conceptos jurídicos indeterminados que puedan responder a la multiplicidad de responsables del tratamiento que puedan existir (con su propia idiosincrasia) y tratamientos de datos personales que puedan llevarse a cabo; conceptos jurídicos indeterminados que lo que suponen es una mayor flexibilidad para el responsable del tratamiento (con la finalidad última de proteger a las personas físicas) quien deberá desplegar la debida diligencia

integrando dichos conceptos jurídicos indeterminados en su realidad en el cumplimiento de sus obligaciones en materia de protección de datos

A mayor abundamiento, respecto de la tipicidad del RGPD se ha de significar que tal y como determina el Dictamen del Consejo de Estado de 26 de octubre de 2017 relativo al Anteproyecto de Ley Orgánica de Protección de Datos de Carácter Personal *“El Reglamento Europeo sí tipifica, por más que lo haga en un sentido genérico, las conductas constitutivas de infracción: en efecto, los apartados 4, 5 y 6 de su artículo 83 arriba transcritos contienen un catálogo de infracciones por vulneración de los preceptos de la norma europea que en tales apartados se indican”*.

La AEPD ha ejercido la potestad sancionadora respecto de comportamientos que se hayan comprendidos en las normas que los tipifican tal y como impone, entre otras, la STC 151/1997, de 29 de septiembre.

Los hechos acreditados en el expediente administrativo se encuadran perfectamente en los elementos del tipo previsto en el artículo 83.5 del RGPD, limitándose la AEPD a integrar los hechos en el mismo sin ningún tipo de arbitrariedad, que tampoco ha sido acreditada por Telefónica.

Así, en el caso que nos ocupa, una vez analizadas las circunstancias concretas del caso, se ha podido determinar sin incurrir en ningún tipo de valoración o interpretación arbitraria la falta de medidas técnicas y organizativas adecuadas, de todo tipo, incluyendo las de seguridad para garantizar, por una parte el principio de integridad y confidencialidad, y por otro, un nivel de seguridad adecuado al riesgo de los tratamientos de datos personales realizados por Telefónica(, pues carecía de medidas de seguridad adecuadas y razonables en cuanto a la tecnología disponible y costes de aplicación en el momento del incidente, que hubieran impedido, cuando no minimizado o mitigado considerablemente el impacto del incidente sobre los datos personales).

Sexta. La conducta de Telefónica no es antijurídica.

Una vez más, Telefónica reitera lo alegado frente al acuerdo de inicio en lo referente a la inexistencia de antijuricidad en su conducta. En este sentido, insiste en que cuenta con medidas técnicas y organizativas diseñadas para garantizar una seguridad adecuada de los datos personales (Certificados, protocolos y manuales que acreditan la gestión de la seguridad, medidas de concienciación de empleados, de protección de los dispositivos, etc) y con múltiples mecanismos para detectar el acceso ilegítimo a datos personales. Respecto a dichas afirmaciones, no queda sino reiterarse en lo ya transcrito a lo largo del procedimiento.

Séptima. Ausencia de culpabilidad.

En su siguiente alegación reitera nuevamente los argumentos ya planteados sobre la inexistencia de culpa en su conducta. Insiste en que ha actuado de buena fe con toda la diligencia profesional exigible, y que las circunstancias que han dado lugar a los hechos objeto del presente expediente son imputables a terceros que actuaron en la comisión de un delito.

Respecto de la infracción del principio de culpabilidad, decir que resulta de aplicación el artículo 70 de la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales (LOPDPGDD), según el cual *“1. Están*

sujetos al régimen sancionador establecido en el Reglamento (UE) 2016/679 y en la presente ley orgánica:

- a) Los responsables de los tratamientos.*
- b) Los encargados de los tratamientos.*
- c) Los representantes de los responsables o encargados de los tratamientos no establecidos en el territorio de la Unión Europea.*
- d) Las entidades de certificación.*
- e) Las entidades acreditadas de supervisión de los códigos de conducta.*

Por su parte, el art. 28 de la Ley 40/2015 reza “1. Sólo podrán ser sancionadas por hechos constitutivos de infracción administrativa las personas físicas y jurídicas, así como, cuando una Ley les reconozca capacidad de obrar, los grupos de afectados, las uniones y entidades sin personalidad jurídica y los patrimonios independientes o autónomos, que resulten responsables de los mismos a título de dolo o culpa”.

Por otro lado, y en lo relativo a la aducida buena fe de Telefónica se debe precisar que, siendo clara la necesidad de que concurra dolo o culpa en la actuación del infractor, no podemos confundir dichos elementos con la concurrencia o ausencia de la buena fe, como pretende la entidad actora, y ello porque la voluntariedad del resultado de la acción no es elemento constitutivo esencial de la infracción administrativa, sino un factor de graduación, para que la misma guarde la debida proporcionalidad con el hecho que la motiva, lo que enlaza con el principio de proporcionalidad cuya infracción asimismo se denuncia.

El Tribunal Supremo (Sala de lo Contencioso-Administrativo, Sección 5ª) en Sentencia num. 179/2023, de 15 de febrero 2023 establece: Sentencia (STS 354/2023)

(...) debemos comenzar por recordar que la culpabilidad constituye, en efecto, una exigencia de las infracciones administrativas, ínsito en el artículo 25 de la Constitución, que ha tenido una elaborada construcción doctrinal en el ámbito del Derecho Penal del que el Administrativo Sancionador es tributario. Dicha exigencia comporta, en apretada síntesis a los efectos del debate suscitado, que el hecho que se tipifica en el tipo de la infracción pueda y debe serle imputable al sujeto que se sanciona, al que se considera culpable del mismo, es decir, responsable, conforme a la terminología de la Ley de Procedimiento Administrativo Común de las Administraciones Públicas. Esa imputación comporta un elemento intelectual conforme al cual la acción típica no solo se ejecuta por el propio sujeto, sino que se hace a conciencia y voluntad, es decir, de manera intencional, o bien por una negligencia más o menos intensa, en cuanto se ha omitido la diligencia que sería exigible en la ejecución del acto para evitar el efecto pernicioso.

En este mismo sentido, procede aludir a la Sentencia del Tribunal de Justicia de la Unión Europea, de 5 de diciembre de 2023, recaída en el asunto C-807/21 (Deutsche Wohnen), que indica:

“76 A este respecto, debe precisarse además, por lo que atañe a la cuestión de si una infracción se ha cometido de forma intencionada o negligente y, por ello, puede sancionarse con una multa administrativa con arreglo al artículo 83 del RGPD, que un responsable del tratamiento puede ser sancionado por un comportamiento

comprendido en el ámbito de aplicación del RGPD cuando no podía ignorar el carácter infractor de su conducta, tuviera o no conciencia de infringir las disposiciones del RGPD (véanse, por analogía, las sentencias de 18 de junio de 2013, Schenker & Co. y otros, C 681/11, EU:C:2013:404, apartado 37 y jurisprudencia citada; de 25 de marzo de 2021, Lundbeck/Comisión, C 591/16 P, EU:C:2021:243, apartado 156, y de 25 de marzo de 2021, Arrow Group y Arrow Generics/Comisión, C 601/16 P, EU:C:2021:244, apartado 97).” (el subrayado es nuestro).

Octava. Incumplimiento del principio de proporcionalidad.

A continuación, Telefónica reproduce nuevamente de manera prácticamente literal las argumentaciones sostenidas respecto a lo que considera una vulneración del principio de proporcionalidad en la determinación de las sanciones, singularizando cada una de las circunstancias agravantes concurrentes en cada una de las dos infracciones, así como las circunstancias atenuantes que, a su juicio, deberían haber sido tenidas en cuenta.

Ante la alegación de la interesada, en la que considera que la cuantía de la sanción impuesta, superior a la cuantía mínima, no está justificada, debe señalarse que dicha sanción, está encuadrada dentro de los márgenes que la ley prevé para este tipo de infracciones, habiéndose considerado para su individualización, necesaria dentro de los márgenes legalmente establecidos, las circunstancias concretas que concurren en el presente caso. Esta adecuación de la sanción al caso concreto, no solo no vulnera el principio de proporcionalidad, sino que, como a continuación se indica, resulta exigible para dar debido cumplimiento al mismo.

Con mayor concreción se expone en la Sentencia 10488/2010 del Tribunal Superior de Justicia de Madrid (Sala de lo Contencioso, sección 6), de 22 de abril:

“Examinada la correcta apreciación jurídica de los hechos, y su perfecto encaje en el tipo infractor, se viene a alegar en la demanda una pretendida falta de proporcionalidad en la fijación del quantum de la sanción, lo cual tampoco puede apreciarse en el caso presente.

En efecto, debe partirse del hecho de que la sanción mínima imponible podía ser de 6.010'12, y que la que se ha impuesto lo ha sido por un importe de 6100. Es decir, la proporcionalidad de la sanción se demuestra atendido el hecho de que la falta de autorización es incuestionable.

En este punto debe indicarse que para que una sanción sea proporcionada la jurisprudencia exige (v.gr., SSTs 16-12-94 y de 30-9-1995) dos requisitos, que se resumen en que la actividad administrativa pondere adecuadamente las circunstancias concurrentes y que la sanción se imponga dentro de los límites establecidos por la norma. Cumpliéndose ambos requisitos, la Administración goza de una margen de discrecionalidad para imponer la sanción, sólo limitado por lo antedicho, por lo que si en el caso presente la CHT ha realizado la ponderación indicada, y la sanción se encuentra a la mitad del límite mínimo, no puede sino colegirse la proporcionalidad de la misma.

Es debido a ello que la sanción impuesta está ajustada a Derecho y procede desestimar la demanda.”

Así, en la individualización de la sanción, la Administración goza de un cierto margen de discrecionalidad, existiendo reiterada doctrina jurisprudencial al respecto, que determina que el control jurisdiccional del criterio de proporcionalidad ha de centrarse en el análisis de la corrección del grado elegido, mínimo, medio o máximo y al objeto de determinar si existe la debida adecuación entre los hechos imputados y la responsabilidad exigida. La elección de la cuantía dentro de cada grado corresponde a la Administración que discrecionalmente fijará el concreto importe de la sanción, no controlable jurisdiccionalmente, a salvo de que se alegue fundadamente arbitrariedad en la decisión administrativa.

En el presente procedimiento sancionador, ya desde el Acuerdo de Inicio, se han puesto de manifiesto las circunstancias consideradas al objeto de graduar la sanción indicada, circunstancias que, conviene no olvidar, se encuentran recogidas en el artículo 83.2 del RGPD, y en el artículo 76.2 de la LOPDPGDD, por lo que la actividad administrativa dista mucho de ser arbitraria. Así, dentro de los márgenes que la ley le otorga y acudiendo a los criterios que la misma establece, esta Agencia ha analizado las circunstancias concretas que se dan en este caso y determinado la cuantía de la sanción a imponer, procurando así la debida proporción entre los hechos imputados y la responsabilidad exigida, quedando por tanto expuesto y razonado el criterio empleado para la concreción o individualización de la sanción indicada.

En consecuencia, procede desestimar esta alegación de la interesada, considerando que la sanción impuesta resulta adecuada y proporcional a la infracción cometida, estando debidamente justificado su importe en atención a los criterios previstos en el artículo 83.2 del RGPD, y en el artículo 76.2 de la LOPDPGDD.

VI Integridad y confidencialidad

El artículo 5.1.f) “*Principios relativos al tratamiento*” del RGPD establece:

“1. *Los datos personales serán:*
(...)”

f) tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito y contra su pérdida, destrucción o daño accidental, mediante la aplicación de medidas técnicas u organizativas apropiadas («integridad y confidencialidad»).”

El principio de integridad y confidencialidad impone al responsable del tratamiento que garantice la integridad y confidencialidad de los datos personales evitando la alteración de los datos personales, su pérdida, tratamiento o acceso no autorizado o ilícito a través de medidas técnicas y organizativas apropiadas. No es posible la existencia de este derecho fundamental si no se garantizan la confidencialidad, la integridad y la disponibilidad de los datos personales.

De ahí que la integridad y la confidencialidad de los datos personales se consideren esenciales para evitar que los interesados sufran efectos negativos. Por ello, deben tratarse de un modo que se garantice una integridad y confidencialidad adecuadas de

los datos personales, especialmente para impedir el acceso tratamiento o uso no autorizados de dichos datos.

En definitiva, es el responsable del tratamiento el que tiene la obligación de integrar las garantías necesarias en el tratamiento, con la finalidad de, en virtud del principio de responsabilidad proactiva, cumplir y ser capaz de demostrar el cumplimiento, al mismo tiempo que respeta el derecho fundamental a la protección de datos.

A este respecto, debe recordarse que la confidencialidad de los datos personales se regula en el artículo 5 del RGPD siendo, por tanto, uno de los principios relativos al tratamiento. Los principios relativos al tratamiento son, por un lado, el punto de partida y la cláusula de cierre del ordenamiento jurídico de protección de datos, constituyendo verdaderas reglas informadoras del sistema con una intensa fuerza expansiva; por otro lado, al tener un alto nivel de concreción, son normas de obligado cumplimiento susceptibles de ser infringidas.

Por tanto, el principio de confidencialidad debe informar todos los aspectos, derechos y obligaciones que conlleva el tratamiento de datos personales. Ello es así, porque la vulneración de la confidencialidad conlleva para sus titulares la pérdida de control sobre los mismos, lo que puede suponer graves riesgos para sus derechos y libertades.

El artículo 5.1.f) del RGPD establece una obligación clara de cumplimiento consistente en impedir tratamientos no autorizados o ilícitos implementando medidas de seguridad adecuadas. En consecuencia, los responsables del tratamiento deben estar en disposición de garantizar la confidencialidad y la integridad de los datos personales para impedir que un tercero acceda a datos que no son de su titularidad, pues precisamente les compete tratar los datos personales conforme al RGPD y LOPDGDD. Por esta razón, es una actividad en donde la diligencia prestada por éstos es fundamental para evitar este tipo de accesos.

En el presente caso, se ha vulnerado el principio de confidencialidad pues consta que tras sufrir un ataque informático consistente en solicitudes masivas a la aplicación *****APP.1** accesible desde el portal del empleado *****PORTAL.1** de Telefónica, con acceso público desde internet a través de usuario y contraseña, se produjo un acceso ilegítimo a datos personales, lo que supuso la pérdida de confidencialidad y de control de varios datos personales: número de teléfono fijo; datos del equipo asociado al cliente (EDC): Dirección MAC, VLANs de servicios; nombre publicado de las redes wifis (SSIDS); estándar de cifrado, los rangos de direccionamiento de las redes interna y las contraseñas de las redes wifi sin cifrar. Ello afectó a 1.407.257 personas físicas clientes de Telefónica.

Lo anterior supone el incumplimiento del deber de garantizar la confidencialidad de los datos personales, pues como se ha indicado, el artículo 5.1f) señala que deben ser tratados de tal manera que se garantice una seguridad adecuada de los datos personales, incluida la protección contra el tratamiento no autorizado o ilícito.

Esta pérdida de control sobre los propios datos personales, se traduce en una vulneración del derecho fundamental a la protección de datos reconocido en el artículo 18 de la Constitución Española pues tal y como ha indicado el Tribunal Constitucional

(Sentencia 292/2000, de 30 de noviembre de 2000) *“el derecho fundamental a la protección de datos persigue garantizar a la persona un poder de control sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y lesivo para la dignidad y derecho del afectado (...) El derecho a la protección de datos garantiza a los individuos un poder de disposición sobre esos datos”.*

Por todo lo expuesto y de conformidad con las evidencias de las que se dispone en este procedimiento sancionador, se considera que los hechos conocidos podrían ser constitutivos de una infracción, imputable a Telefónica, por vulneración del artículo 5.1.f) del RGPD.

VII Tipificación de la infracción del artículo 5.1.f) del RGPD

La citada infracción del artículo 5.1.f) del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.5 del RGPD que bajo la rúbrica *“Condiciones generales para la imposición de multas administrativas”* dispone:

“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) los principios básicos para el tratamiento, incluidas las condiciones para el consentimiento a tenor de los artículos 5, 6, 7 y 9; (...)”

A este respecto, la LOPDGDD, en su artículo 71 *“Infracciones”* establece que *“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”.*

A efectos del plazo de prescripción, el artículo 72 *“Infracciones consideradas muy graves”* de la LOPDGDD indica:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

a) El tratamiento de datos personales vulnerando los principios y garantías establecidos en el artículo 5 del Reglamento (UE) 2016/679. (...)”

VII Sanción por la infracción del artículo 5.1.f) del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, de conformidad con las evidencias de que se dispone, procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como agravantes:

- Artículo 83.2.a) RGPD: Naturaleza, gravedad y duración de la infracción.

Se considera que la naturaleza de la infracción es grave puesto que acarrea una pérdida de confidencialidad y, por tanto, de disposición y control irremediable sobre los datos personales.

Número de interesados afectados: son muy numerosos los afectados, pues asciende a más de un millón de clientes de Telefónica: 1.407.257

Nivel de los daños y perjuicios sufridos: Alto. Fueron sustraídos datos personales (número de teléfono fijo asociado además a datos técnicos y de configuración del equipo del cliente (MAC del router; VLANs de los servicios; nombres de las wifis publicadas: SSIDs; contraseña de las redes wifi sin cifrar; rangos de direccionamiento de las redes interna) y de un número muy considerable de clientes, perdiendo, por tanto, todo control sobre los mismos, lo que supone un riesgo alto de uso fraudulento (usurpación de identidad, fraude, pérdidas financieras, acceso a otros datos personales mediante el acceso a otros dispositivos conectados del cliente a su red wifi, etc), vaciando así de contenido el derecho fundamental a la protección de datos personales que, como indica el Tribunal Constitucional en la Sentencia anteriormente reseñada, persigue garantizar a la persona un poder de control y disposición sobre sus datos personales, sobre su uso y destino, con el propósito de impedir su tráfico ilícito y lesivo para la dignidad y derecho del afectado.

- Artículo 83.2.b) RGPD. Negligencia en la infracción: Se observa la existencia de negligencia en el cumplimiento de la obligación de garantizar la seguridad necesaria para la protección de los datos personales, concretamente para garantizar la confidencialidad de estos. A este respecto, debe recordarse que Telefónica es una gran empresa, que realiza tratamientos a gran escala, afectando sus tratamientos a numerosas personas físicas (millones de personas clientes de Telefónica) por lo que se le exige un nivel de diligencia mayor y medidas de seguridad adecuadas para garantizar la confidencialidad de los datos personales que trata.

Procede recordar, en este sentido, la Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006), que respecto de entidades cuya actividad lleva aparejado el continuo tratamiento de datos de clientes, indica "...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las previsiones legales al respecto.

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 "Sanciones y medidas correctivas" de la LOPDGDD:

Como agravantes:

- Artículo 76.2.b) LOPDGDD. Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal: El desarrollo de la actividad empresarial que desempeña Telefónica supone un tratamiento continuo y a gran escala de datos personales, pues trata datos de millones de personas. Por tanto, se trata de una empresa grande habituada al tratamiento de datos personales.

De conformidad con las evidencias de que se dispone y teniendo en cuenta las circunstancias del caso y los criterios que establece el artículo 83.2 del RGPD con respecto a la infracción cometida al vulnerar lo establecido en el artículo 5.1.f) del RGPD, se propone una sanción de 800.000 € (ochocientos mil euros).

IX Artículo 32 del RGPD

El Artículo 32 “*Seguridad del tratamiento*” del RGPD establece:

“1. Teniendo en cuenta el estado de la técnica, los costes de aplicación, y la naturaleza, el alcance, el contexto y los fines del tratamiento, así como riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas, el responsable y el encargado del tratamiento aplicarán medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, que en su caso incluya, entre otros:

a) la seudonimización y el cifrado de datos personales;

b) la capacidad de garantizar la confidencialidad, integridad, disponibilidad y resiliencia permanentes de los sistemas y servicios de tratamiento;

c) la capacidad de restaurar la disponibilidad y el acceso a los datos personales de forma rápida en caso de incidente físico o técnico;

d) un proceso de verificación, evaluación y valoración regulares de la eficacia de las medidas técnicas y organizativas para garantizar la seguridad del tratamiento.

2. Al evaluar la adecuación del nivel de seguridad se tendrán particularmente en cuenta los riesgos que presente el tratamiento de datos, en particular como consecuencia de la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.

3. La adhesión a un código de conducta aprobado a tenor del artículo 40 o a un mecanismo de certificación aprobado a tenor del artículo 42 podrá servir de elemento para demostrar el cumplimiento de los requisitos establecidos en el apartado 1 del presente artículo.

4. El responsable y el encargado del tratamiento tomarán medidas para garantizar que cualquier persona que actúe bajo la autoridad del responsable o del encargado y tenga acceso a datos personales solo pueda tratar dichos datos siguiendo instrucciones del responsable, salvo que esté obligada a ello en virtud del Derecho de la Unión o de los Estados miembros”.

El artículo 32 no establece medidas de seguridad estáticas, sino que corresponderá al responsable determinar aquellas medidas de seguridad que son necesarias para garantizar la confidencialidad, la integridad y la disponibilidad de los datos personales, por lo tanto, un mismo tratamiento de datos puede implicar medidas de seguridad distintas en función de las especificidades concretas en las que tiene lugar dicho tratamiento de datos.

En consonancia con estas previsiones, el Considerando 75 del RGPD establece: “Los riesgos para los derechos y libertades de las personas físicas, de gravedad y probabilidad variables, pueden deberse al tratamiento de datos que pudieran provocar daños y perjuicios físicos, materiales o inmateriales, en particular en los casos en los que el tratamiento pueda dar lugar a problemas de discriminación, usurpación de identidad o fraude, pérdidas financieras, daño para la reputación, pérdida de confidencialidad de datos sujetos al secreto profesional, reversión no autorizada de la seudonimización o cualquier otro perjuicio económico o social significativo; en los casos en los que se prive a los interesados de sus derechos y libertades o se les impida ejercer el control sobre sus datos personales; en los casos en los que los datos personales tratados revelen el origen étnico o racial, las opiniones políticas, la religión o creencias filosóficas, la militancia en sindicatos y el tratamiento de datos genéticos, datos relativos a la salud o datos sobre la vida sexual, o las condenas e infracciones penales o medidas de seguridad conexas; en los casos en los que se evalúen aspectos personales, en particular el análisis o la predicción de aspectos referidos al rendimiento en el trabajo, situación económica, salud, preferencias o intereses personales, fiabilidad o comportamiento, situación o movimientos, con el fin de crear o utilizar perfiles personales; en los casos en los que se traten datos personales de personas vulnerables, en particular niños; o en los casos en los que el tratamiento implique una gran cantidad de datos personales y afecte a un gran número de interesados.” (el subrayado es nuestro)

Asimismo, el Considerando 83 del RGPD establece: “A fin de mantener la seguridad y evitar que el tratamiento infrinja lo dispuesto en el presente Reglamento, el responsable o el encargado deben evaluar los riesgos inherentes al tratamiento y aplicar medidas para mitigarlos, como el cifrado. Estas medidas deben garantizar un nivel de seguridad adecuado, incluida la confidencialidad, teniendo en cuenta el estado de la técnica y el coste de su aplicación con respecto a los riesgos y la naturaleza de los datos personales que deban protegerse. Al evaluar el riesgo en relación con la seguridad de los datos, se deben tener en cuenta los riesgos que se derivan del tratamiento de los datos personales, como la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos, susceptibles en particular de ocasionar daños y perjuicios físicos, materiales o inmateriales.” (el subrayado es nuestro)

En definitiva, el primer paso para determinar las medidas de seguridad será la evaluación del riesgo. Una vez evaluado será necesario determinar las medidas de seguridad encaminadas para reducir o eliminar los riesgos para el tratamiento de los datos.

La seguridad de los datos requiere la aplicación de medidas técnicas u organizativas apropiadas en el tratamiento de los datos personales para proteger dichos datos contra el acceso, uso, modificación, difusión, pérdida, destrucción o daño accidental, no autorizado o ilícito. En este sentido, las medidas de seguridad son claves a la hora de garantizar el derecho fundamental a la protección de datos. No es posible la existencia del derecho fundamental a la protección de datos personales si no es posible garantizar la confidencialidad, la integridad y la disponibilidad de estos.

No debe olvidarse que, de conformidad con el artículo 32.1 del RGPD citado, las medidas técnicas y organizativas a aplicar para garantizar un nivel de seguridad adecuado al riesgo deben tener en cuenta el estado de la técnica, los costes de aplicación, la naturaleza, el alcance, el contexto y los fines del tratamiento, así como los riesgos de probabilidad y gravedad variables para los derechos y libertades de las personas físicas. El enfoque debe de estar centrado en los riesgos en los derechos y libertades de las personas físicas y no en los riesgos que el tratamiento entraña en la organización centrándolo, además como en el supuesto examinado, únicamente en medidas de seguridad de la información.

Por tanto, Telefónica, a la hora de evaluar los riesgos y determinar las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo, está obligada a tener en cuenta la concreta actividad que supone su negocio, que conlleva tratar datos personales de forma continua y a gran escala (numerosos datos a recoger, procesar, almacenar...); la tipología de datos tratados: número de teléfono fijo, datos técnicos y de configuración de los equipos de acceso a redes wifi, etc; el contexto: utilización de un aplicativo con acceso a través de una portal web en internet, es decir, en un entorno no aislado, lo que conlleva riesgos derivados de la propia interconectividad que supone la red, los cuales deben atenderse de forma especializada.

Por ello, derivado de la actividad a la que se dedica, Telefónica está obligada a realizar de forma muy especializada un análisis de los riesgos y una implantación de medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo de su actividad para los derechos y libertades de las personas.

En el presente caso, como se ha señalado anteriormente, Telefónica sufrió un ciberataque a su aplicativo *****APP.1** a través de un portal de internet, causando una brecha de seguridad consistente en una brecha de confidencialidad al producirse un acceso a datos personales de sus clientes, contenidos en dichas aplicaciones.

La aplicación *****APP.1** es una aplicación de Telefónica que contiene información, entre ella datos personales de sus clientes y que se utilizan para fines de soporte y mantenimiento al cliente por parte de los equipos técnicos de Telefónica (diagnóstico y tratamiento de averías en los equipamientos de conectividad: router, decodificador de la tv, amplificador wifi, etc), a la que, como se ha señalado, se puede acceder por parte de los técnicos a través un portal publicado en Internet.

Del análisis de la documentación aportada por Telefónica en las distintas notificaciones de la brecha de seguridad y de las respuestas a los requerimientos de información respecto de las causas que hicieron posible la brecha y las medidas de seguridad existentes antes de la misma, resulta lo siguiente:

1. Cronología de los hechos:

- El 16 de septiembre de 2022, por parte del equipo responsable de APIS (...) se detecta un consumo anómalo provocado por peticiones masivas procedentes de la aplicación *****APP.1**, aplicación accesible desde el portal del empleado *****PORTAL.1** de Telefónica. Este consumo anómalo se mantiene durante los 4 días siguientes y consiste en solicitudes masivas de alrededor de 4 millones por día cuando el consumo habitual ronda las 55.000 solicitudes diarias y provienen todas de un único usuario.

- El día 20 de septiembre de 2022, se procede a bloquear el usuario del que proceden esas solicitudes tras verificarse, al volver dicho usuario de vacaciones, que no era este quien realizaba de forma legítima las peticiones.

-El día 21 de septiembre de 2022, dicho usuario traslada el incidente al equipo de seguridad de Telefónica (CSIRT).

-Durante los días 21,22 y 23 de septiembre de 2022 se analiza el incidente por parte del equipo de seguridad (CSIRT) haciendo uso del sistema centralizado de logs (SIEM).

-El día 23 de septiembre de 2022 indican que es cuando se tiene constancia de la filtración de datos tras las peticiones lanzadas por los atacantes y se califica el incidente como brecha de seguridad. Este mismo día se informa de lo sucedido al DPD de Telefónica a través de correo electrónico.

-El día 26 de septiembre de 2022 se presenta notificación inicial de la brecha de seguridad ante esta Agencia.

-El día 29 de septiembre de 2022 se detecta, gracias a las medidas de seguridad desplegadas tras el ataque, una nueva intromisión con un usuario distinto de Telefónica, cuyas credenciales también han sido comprometidas. Se cambia la contraseña y se procede a bloquear todos los usuarios de la aplicación afectada *****APP.1**.

-El día 26 de octubre de 2022 se presenta notificación completa de la brecha aportándose en adjunto un informe documentado del incidente. En el mismo se indica que, una vez concluido el análisis completo del incidente y que tras comprobar que hay otro usuario comprometido, se detecta que la fecha de inicio del ataque se produjo desde el día 9/09/2022 y que, por tanto, los accesos maliciosos se realizaron en tres bloques de días: de 9 al 11 de septiembre, del 16 al 20 de septiembre y el día 28 de septiembre de 2022.

Por tanto, ha quedado constatado que la brecha de seguridad se inició el 9 de septiembre de 2022 y se dio por resuelta el 29 de septiembre de 2022, afectó a la aplicación *****APP.1** accesible desde el portal del empleado de Telefónica (*****PORTAL.1**). Esta aplicación contiene información, entre ella datos personales, la cual es utilizada para fines de soporte técnico y mantenimiento a los clientes de Telefónica por parte de los equipos técnicos. El portal del empleado (*****PORTAL.1**) estaba expuesto en internet con la única restricción de autenticación a través de usuario y contraseña.

Según el correo electrónico enviado por el CSIRT de Telefónica al DPD el 23/09/2022, transcrito literalmente en el Antecedente de Hecho Quinto del presente Acuerdo, el día 16 de septiembre de 2022 se detectaron las consultas masivas desde un único y concreto usuario a las aplicaciones indicadas a través del portal *****PORTAL.1**, procediendo el 18 de septiembre (2 días más tarde) a contactar con dicho usuario

enviándole un correo electrónico. Dicho usuario se encontraba de vacaciones y no fue hasta el día 20 de septiembre (otros 2 días más tarde), momento en que se reincorpora a la oficina, cuando tiene constancia de lo sucedido e indica a los responsables del PIGW que no reconocía esas peticiones, por lo que proceden en ese momento a bloquear el usuario. En el momento en que el usuario cambia sus credenciales corporativas cesan las peticiones.

Este mismo empleado, con cuyo usuario se realizaron las solicitudes masivas y cuyas credenciales habían sido comprometidas, es el que el 21/09/2022 avisa mediante correo electrónico al buzón del CSIRT del incidente ocurrido, momento en el que el mismo tiene constancia por primera vez del incidente de seguridad sufrido (5 días más tarde).

En definitiva, no es hasta cuatro días más tarde que se toman las primeras medidas para contener el ataque (bloqueo del usuario), a pesar de estar produciéndose consultas masivas muy superiores a las habituales y no es hasta 5 días más tarde que se inician los primeros análisis e investigaciones del ataque por parte del CSIRT, constatándose 3 días más tarde que el incidente ha supuesto una brecha de datos personales.

2. En relación con el vector de ataque, ha quedado constatado por afirmación de Telefónica que la causa del incidente fue el compromiso de credenciales válidas (...).

A este respecto, en el documento relativo al análisis de riesgos aportado por Telefónica, realizado en el periodo de tiempo Julio-octubre de 2021, se analiza la amenaza o factor de riesgo "...". Procede señalar que se trata de un análisis de seguridad, sin tener en cuenta otros factores de riesgo para los derechos y libertades de las personas afectadas derivados de la naturaleza, ámbito, contexto o fines del tratamiento, pues identifica y evalúa exclusivamente los riesgos en materia de seguridad de la información.

3. Según afirma Telefónica, como medidas implantadas con posterioridad al incidente, indica entre otras:

(...).

Lo anteriormente expuesto refleja que, con anterioridad al incidente, no se contaban con medidas técnicas y organizativas apropiadas para garantizar una seguridad adecuada en el tratamiento de los datos personales en relación con los riesgos asociados. O bien, en caso de existir, no fueron eficaces o no fueron observadas. Ello es así por cuanto:

a) En la aplicación atacada, a la cual se accedía mediante un portal de internet, y que daba acceso a datos personales, (...).

No debe olvidarse que durante el ataque se produjeron, desde un mismo usuario, solicitudes que llegaban a los 4 millones al día, (...) y afectando a datos personales de más de 1,4 millones de personas, número que podría haber sido mucho menor si se hubiese reaccionado con mayor celeridad.

b) Precisamente El CSIRT de Telefónica (Equipo de Respuesta ante Incidentes de Seguridad) y que tiene como objetivo, en caso de que se materialice algún ataque, responder de forma urgente y coordinada al objeto de mitigar el impacto y, por ende, las consecuencias, no tuvo conocimiento del incidente hasta 5 días más tarde, lo cual supuso un considerable retraso tanto en la adopción de posibles medidas de contención y mitigación del ataque, así como en el análisis y valoración del mismo como brecha de seguridad de datos personales.

c) Los datos personales de los clientes a los que se accedía mediante una aplicación desde internet no estaban cifrados de forma segura, anonimizados o protegidos de forma que fueran ininteligibles en casos de accesos no autorizados o que no se pueda identificar a las personas físicas, lo cual hubiera mitigado considerablemente los riesgos para los derechos y libertades de las personas.

De todo lo anterior, se concluye que las medidas técnicas y organizativas implantadas con anterioridad a la brecha, y con independencia de que está se haya producido, no eran apropiadas para garantizar un nivel de seguridad adecuado al riesgo que el tratamiento de datos personales llevado a cabo suponía, y ello con independencia del concreto ataque sufrido -el cual lo que hace es poner de manifiesto estas deficiencias una vez que el riesgo se ha materializado- medidas que, según el estado de la técnica en el momento del incidente, ya existían y eran conocidas, cuyos costes de aplicación eran perfectamente asumibles por una empresa como Telefónica que, además, realiza tratamientos de datos a gran escala, por lo que está obligada a adoptar medidas técnicas y organizativas de seguridad adecuadas a estos riesgos.

A mayor abundamiento, en la notificación completa de la brecha Telefónica afirmó que se podría haber evitado la brecha adoptando medidas adicionales, aunque consideraba que las actuales eran suficientes.

Por tanto, de conformidad con las evidencias de las que se dispone, se considera que los hechos conocidos son constitutivos de una infracción, imputable a Telefónica, por vulneración del artículo 32 del RGPD y que esta infracción es independiente del ataque sufrido.

X Tipificación de la infracción del artículo 32 del RGPD

La citada infracción del artículo 32 del RGPD supone la comisión de las infracciones tipificadas en el artículo 83.4 del RGPD que bajo la rúbrica "*Condiciones generales para la imposición de multas administrativas*" dispone:

"Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:

a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43; (...)"

A este respecto, la LOPDGDD, en su artículo 71 *“Infracciones”* establece que *“Constituyen infracciones los actos y conductas a las que se refieren los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679, así como las que resulten contrarias a la presente ley orgánica”*.

A efectos del plazo de prescripción, el artículo 73 *“Infracciones consideradas graves”* de la LOPDGDD indica:

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

(...)

f) La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para garantizar un nivel de seguridad adecuado al riesgo del tratamiento, en los términos exigidos por el artículo 32.1 del Reglamento (UE) 2016/679.

XI Sanción por la infracción del artículo 32 del RGPD

A efectos de decidir sobre la imposición de una multa administrativa y su cuantía, procede graduar la sanción a imponer, de acuerdo con los siguientes criterios que establece el artículo 83.2 del RGPD:

Como agravantes:

- Artículo 83.2.b) RGPD. Negligencia en la infracción: se observa la existencia de negligencia puesto que Telefónica no contaba con las medidas técnicas y organizativas apropiadas para garantizar un nivel de seguridad adecuado al riesgo que suponen los tratamientos de datos personales contenidos en una aplicación a la cual se puede acceder a través de un portal desde internet. A este respecto, debe recordarse que Telefónica es una gran empresa operadora de telecomunicaciones que realiza tratamientos de forma continua y a gran escala, por lo que se le exige un nivel de diligencia mayor y medidas adecuadas para garantizar la seguridad de los datos personales que trata.

Procede recordar, en este sentido, la Sentencia de la Audiencia Nacional de 17/10/2007 (rec. 63/2006), que respecto de entidades cuya actividad lleva aparejado el continuo tratamiento de datos de clientes, indica *“...el Tribunal Supremo viene entendiendo que existe imprudencia siempre que se desatiende un deber legal de cuidado, es decir, cuando el infractor no se comporta con la diligencia exigible. Y en la valoración del grado de diligencia ha de ponderarse especialmente la profesionalidad o no del sujeto, y no cabe duda de que, en el caso ahora examinado, cuando la actividad de la recurrente es de constante y abundante manejo de datos de carácter personal ha de insistirse en el rigor y el exquisito cuidado por ajustarse a las previsiones legales al respecto.*

Asimismo, se considera que procede graduar la sanción a imponer de acuerdo con los siguientes criterios que establece el apartado 2 del artículo 76 *“Sanciones y medidas correctivas”* de la LOPDGDD:

Como agravantes:

- Artículo 76.2.b) LOPDGDD. Vinculación de la actividad del infractor con la realización de tratamientos de datos de carácter personal: El desarrollo de la actividad empresarial que desempeña Telefónica supone un tratamiento continuo y a gran escala de datos personales, pues trata datos de millones de personas (clientes, empleados, etc). Por tanto, se trata de una empresa grande habituada al tratamiento de datos personales.

El balance de las circunstancias contempladas en el artículo 83.2 del RGPD y el artículo 76.2 de la LOPDGDD, con respecto a la infracción cometida al vulnerar lo establecido en el artículo 32 del RGPD, permite proponer una sanción de 500.000 € (quinientos mil euros).

XII Medidas

En el texto de la resolución se establecen cuáles han sido las infracciones cometidas y los hechos que han dado lugar a la vulneración de la normativa de protección de datos, de lo que se infiere con claridad cuáles son las medidas a adoptar, sin perjuicio de que el tipo de procedimientos, mecanismos o instrumentos concretos para implementarlas corresponda a la parte sancionada, pues es el responsable del tratamiento quien conoce plenamente su organización y ha de decidir, en base a la responsabilidad proactiva y en enfoque de riesgos, cómo cumplir con el RGPD y la LOPDGDD.

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada, la Directora de la Agencia Española de Protección de Datos

RESUELVE:

PRIMERO: IMPONER a **TELEFÓNICA DE ESPAÑA SAU**, con NIF **A82018474**, por una infracción del artículo 5.1.f) del RGPD y del artículo 32 del RGPD, tipificadas en los artículos 83.4 y 83.5 del RGPD, una multa de 500.000,00 y 800.000,00 euros (OCHOCIENTOS MIL y QUINIENTOS MIL euros).

SEGUNDO: NOTIFICAR la presente resolución a **TELEFÓNICA DE ESPAÑA SAU**.

TERCERO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la LPACAP, en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17 de diciembre, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-**

0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX), abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 76.4 de la LOPDGDD y dado que el importe de la sanción impuesta es superior a un millón de euros, será objeto de publicación en el Boletín Oficial del Estado la información que identifique al infractor, la infracción cometida y el importe de la sanción.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13 de julio, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada Ley 39/2015, de 1 de octubre. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-16012024

Mar España Martí
Directora de la Agencia Española de Protección de Datos